

Von	h.vellbruck-steinheim@vellbruck-partner.de
An	ki-vo-marktueberwachung@bundesnetzagentur.de
Kopie	m.roosendaal@vellbruck-partner.de
Datum	Tue, 03 Mar 2026 14:30:10 +0100
Betreff	Az. 1-101.05-2026/MA-008 — Vollmacht und Stellungnahme — MedAssist AI GmbH

An die
Bundesnetzagentur für Elektrizität, Gas, Telekommunikation, Post und Eisenbahnen
Referat Marktüberwachung KI-VO
Tulpenfeld 4
53113 Bonn

Ihr Zeichen: 1-101.05-2026/MA-008

Unser Zeichen: 2026-V-0427

Sehr geehrte Damen und Herren,

ich zeige an, dass ich die MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg, in dem bei Ihrer Behörde unter dem Aktenzeichen 1-101.05-2026/MA-008 geführten Marktüberwachungsverfahren nach Art. 74 KI-VO (EU) 2024/1689 anwaltlich vertrete.

Eine von CEO Dr. Theresia Vogelkamp (einzelnvertretungsberechtigt, HR-Auszug HRB 748921, AG Mannheim) ausgestellte Vollmacht ist als Anhang beigefügt.

Ich bitte Sie, sämtliche Korrespondenz in diesem Verfahren ab sofort ausschließlich an meine Kanzlei zu richten:

Vellbruck & Partner mbB
RAin Dr. Henrietta Vellbruck-Steinheim
Erbprinzenstraße 14
69117 Heidelberg
E-Mail: h.vellbruck-steinheim@vellbruck-partner.de

Zur Sache:

Meine Mandantin hat das Eröffnungsschreiben Ihrer Behörde vom 22.02.2026 erhalten. Sie nimmt das Marktüberwachungsverfahren ernst und ist zur vollständigen Kooperation bereit. Bereits heute möchte ich Ihnen folgende erste Stellungnahme übermitteln:

1. SYSTEMIDENTIFIKATION

Das gegenständliche KI-System ist MedAssist v4 (Version 4.2.3), ein System zur automatisierten Notrufdisposition, das von MedAssist AI GmbH entwickelt wird und in 18 Krankenhäusern in Baden-Württemberg und Bayern eingesetzt wird.

2. EINSTUFUNGSAKZEPTANZ

Meine Mandantin akzeptiert die Einstufung von MedAssist v4 als Hochrisiko-KI-System nach Anhang III Nr. 7 KI-VO und erhebt keinen Widerspruch gegen die Eröffnung des Marktüberwachungsverfahrens.

3. KOOPERATIONSZUSAGE

Meine Mandantin hat eine vollständige KI-VO-Konformitätsprüfung durch unsere Kanzlei in Auftrag gegeben. Wir werden bis 20.03.2026 eine erste Übersicht der identifizierten

Defizite und eingeleiteten Maßnahmen übermitteln.

4. BITTE UM KLARSTELLUNG DER ZUSTÄNDIGKEIT

Ich bitte um Bestätigung, dass die BNetzA für das vorliegende Verfahren allein zuständige Marktüberwachungsbehörde nach § 3 KI-VoDG ist, insbesondere im Verhältnis zum BfArM (für MDR-Aspekte zuständig) und zum BfDI (für Datenschutzaspekte zuständig). Ein abgestimmtes Vorgehen der Behörden wäre aus Sicht meiner Mandantin wünschenswert, um Doppelbelastungen zu vermeiden.

Für Rückfragen stehe ich jederzeit zur Verfügung.

Mit freundlichen Grüßen

RAin Dr. Henrietta Vellbruck-Steinheim
Fachanwältin für IT-Recht | Datenschutzrecht
Vellbruck & Partner mbB, Heidelberg

Anlage: Vollmacht (1 Blatt)

Von	presse@bfarm.de
An	h.vellbruck-steinheim@vellbruck-partner.de
Kopie	m.roosendaal@vellbruck-partner.de
Datum	Fri, 20 Mar 2026 10:55:43 +0100
Betreff	Ihr Schreiben vom 10.03.2026 — Az. MED-AI-2026-0319 / KI-VO-Schnittstelle

Bundesinstitut für Arzneimittel und Medizinprodukte (BfArM)
Kurt-Georg-Kiesinger-Allee 3
53175 Bonn

Ihr Zeichen: 2026-V-0427

Unser Zeichen: MED-AI-2026-0319

Sehr geehrte Frau Dr. Vellbruck-Steinheim,

bezugnehmend auf Ihr Schreiben vom 10.03.2026 möchten wir Ihnen die Auffassung des BfArM zur Schnittstelle des Bescheids MED-AI-2026-0319 mit der KI-VO-Prüfung erläutern:

1. KLARSTELLUNG DES BESCHEIDUMFANGS

Unser Bescheid vom 12.01.2026 (Az. MED-AI-2026-0319) bestätigt ausschließlich die Konformität von MedAssist v4 mit den Anforderungen der Verordnung (EU) 2017/745 (MDR). Die Konformität mit der Verordnung (EU) 2024/1689 (KI-VO) ist nicht Gegenstand dieses Bescheids. Wir haben dies im Bescheid explizit klargestellt.

2. KOMPETENZABGRENZUNG BfArM / BNetzA

Das BfArM ist im Kontext der KI-VO ausschließlich für jene Sachverhalte zuständig, die nach § 6 Abs. 2 KI-VoDG in die Ressortzuständigkeit des Bundesministeriums für Gesundheit fallen und die KI-VO-Anforderungen mit MDR-spezifischen Fragen verknüpfen. Die allgemeine KI-VO-Marktüberwachung liegt bei der BNetzA.

3. KOORDINATIONSHINWEIS

Das BfArM und die BNetzA haben auf der Grundlage von § 9 KI-VoDG eine Koordinationsvereinbarung geschlossen, die eine Fallübergabe bei Sachverhalten mit MDR/KI-VO-Berührungspunkten vorsieht. Im Falle MedAssist v4 hat das BfArM die BNetzA über den Bescheid MED-AI-2026-0319 informiert.

4. WICHTIGER HINWEIS ZUR ACCURACY

Das BfArM weist vorsorglich darauf hin, dass die im Rahmen des MDR-Konformitätsbewertungsverfahrens vorgelegte Klinische Evaluierung von MedAssist v4 auf Daten aus drei Partnerkliniken basierte. Sollte die BNetzA oder Ihre Mandantin im Rahmen der KI-VO-Prüfung zu dem Ergebnis kommen, dass die tatsächliche Systemperformance wesentlich von den in der Klinischen Evaluierung dokumentierten Werten abweicht, behalten wir uns vor, das MDR-Konformitätsverfahren zu überprüfen.

Wir stehen für eine koordinierte Abstimmung mit der BNetzA zur Verfügung.

Mit freundlichen Grüßen

i.A.

Dr. Margit Pfenning
Leiterin Referat 2.11 — Medizinproduktesoftware / KI-Systeme
Bundesinstitut für Arzneimittel und Medizinprodukte (BfArM)
Kurt-Georg-Kiesinger-Allee 3 | 53175 Bonn
Tel.: 0228 / 99 307-4220
E-Mail: m.pfenning@bfarm.de

[Diese E-Mail enthält amtliche Informationen und ist vertraulich zu behandeln.]

Von	a.krishnamurthy@medassist-ai.de
An	h.vellbruck-steinheim@vellbruck-partner.de
Kopie	m.roosendaal@vellbruck-partner.de, m.albrecht-haag@medassist-ai.de, t.vogelkamp@medassist-ai.de
Datum	Sun, 08 Mar 2026 17:42:05 +0100
Betreff	Re: Kanzlei 2026-V-0427 / MedAssist v4 — Prüfumfang und benötigte Unterlagen — Trainingsdaten-Erläuterung

Sehr geehrte Frau Dr. Vellbruck-Steinheim,

vielen Dank für Ihre detaillierte Anfrage. Ich sende Ihnen heute über unser verschlüsseltes Dateiportal (Link folgt separat) alle verfügbaren Unterlagen.

Zu einigen Punkten möchte ich vorab erläutern:

TRAININGSDATEN — ERLÄUTERUNG

Die Trainingsdatenbasis von MedAssist v4 besteht im Wesentlichen aus drei Quellen:

1. MIMIC-IV Emergency (PhysioNet, MIT/BIDMC)

Zugang über PhysioNet Credentialed Health Data License; Zustimmung MIT IRB liegt vor.

Der Datensatz ist gemäß PhysioNet-Lizenz für Forschungszwecke freigegeben.

Ich bin mir bewusst, dass die Frage der DSGVO-Konformität bei US-Quellen komplex ist.

Unsere interne Rechtsmeinung (Rechtsanwaltskanzlei Bauer & Steinke, Frankfurt, 2022)

war, dass die Nutzung de-identifizierter Forschungsdaten unter Art. 9 Abs. 2 lit. j

DSGVO zulässig sei. Ob diese Auffassung BfDI-fest ist, überlasse ich Ihrer Beurteilung.

2. NEMSIS 3.5 (NHTSA)

Öffentlich zugänglicher Datensatz unter US Government Open Data License.

Keine EU-spezifische Datenschutzprüfung wurde durchgeführt, da wir davon ausgingen,

dass de-identifizierte, behördlich veröffentlichte US-Daten keine DSGVO-relevanten

personenbezogenen Daten enthalten.

3. Klinikinterne Daten (3 BW-Partnerkliniken)

AVV nach Art. 28 DSGVO liegt vor (Muster im Datenpaket enthalten).

Pseudonymisierungsverfahren: k-Anonymität $k=5$, dokumentiert in Anhang D des technischen Dossiers.

ZUR LLAMA-KOMPONENTE

Wir verwenden Llama-3.1-70B-Instruct als Basismodell (Meta AI, RAIL-Lizenz v3).

Das Fine-Tuning wurde intern mit ca. 280.000 Trainingsschritten auf dem medizinischen

Notfalldatensatz durchgeführt. Die Fine-Tuning-Dokumentation ist leider noch nicht

vollständig formalisiert — wir haben die Parameter in einem internen Jupyter-Notebook

dokumentiert, das ich Ihnen mitschicke. Ein strukturiertes Dokument im Sinne einer

"Systemcard" existiert nicht; das ist, soweit ich weiß, ein Meta-AI-Dokument und nicht

unsere Pflicht. Falls Sie das anders sehen, informieren Sie mich bitte.

ZUR BIAS-ANALYSE

Eine formale Bias-Analyse nach Art. 10 Abs. 2 lit. g KI-VO liegt nicht vor. Wir haben

intern diskutiert, ob das notwendig ist, und sind zu dem Schluss gekommen, dass der

Testbericht (MA-EVAL-2024-03) ausreichend sei. Ich schicke Ihnen den Bericht; Sie werden

sehen, dass wir Accuracy-Splits nach Diagnosegruppe vorgenommen haben, aber nicht nach

Geschlecht oder Alter. Das war bewusst so entschieden, um den Entwicklungsaufwand zu begrenzen.

Ich stehe für ein Telefonat zur Verfügung, falls Sie Rückfragen haben.
Das Datenpaket werde ich bis Montag, 09.03.2026, 10:00 Uhr, hochladen.

Mit freundlichen Grüßen

Aravind Krishnamurthy
Chief Technology Officer (CTO)
MedAssist AI GmbH
Im Neuenheimer Feld 580 | 69120 Heidelberg
Tel.: 06221 / 500 10-200
Mobil: +49 175 309 8821
E-Mail: a.krishnamurthy@medassist-ai.de

MedAssist AI GmbH | HRB 748921 AG Mannheim
Geschäftsführung: Dr. Theresia Vogelkamp (CEO), Aravind Krishnamurthy (CTO), Dr. Lutz Federkamp (CMO)

Von	h.vellbruck-steinheim@vellbruck-partner.de
An	m.albrecht-haag@medassist-ai.de
Kopie	m.roosendaal@vellbruck-partner.de, a.krishnamurthy@medassist-ai.de
Datum	Thu, 05 Mar 2026 09:14:22 +0100
Betreff	Kanzlei 2026-V-0427 / MedAssist v4 — Prüfumfang und benötigte Unterlagen

Sehr geehrter Herr Albrecht-Haag,

besten Dank für das konstruktive Erstgespräch am 03.03.2026. Ich nehme das Mandat hiermit formal auf; die unterschriebene Vollmacht liegt bereits vor (Az. 2026-V-0427).

Um die Konformitätsprüfung von MedAssist v4 nach der KI-VO (EU) 2024/1689 zügig aufnehmen zu können, benötige ich bis spätestens 10.03.2026 die folgenden Unterlagen in digitaler Form (bevorzugt PDF/DOCX/XLSX; bitte via gesichertem Dateiupload-Link):

TECHNISCHE DOKUMENTATION

1. Technisches Dossier MedAssist v4 (aktuelle Version, Stand 2025/2026)
2. Architekturdiagramm NLU-Modul und Dispositionsmodul (inkl. Datenfluss)
3. Trainingsdaten-Dokumentation: Herkunft, Umfang, Lizenz aller verwendeten Datensätze
4. Interner Testbericht (MA-EVAL-2024-03 o.ä.) — alle Accuracy- und Robustheitsdaten
5. Incident-Log 2025 (vollständig, alle gemeldeten Anomalien)
6. Benutzerhandbuch aktuelle Version

RISIKOMANAGEMENT UND GOVERNANCE

7. Risikoanalyse / FMEA (alle vorhandenen Fassungen)
8. ISO 27001-Zertifikat (ggf. mit Ablaufdatum)
9. ISO 9001-Zertifikat
10. Auftragsverarbeitungsverträge mit den 18 Krankenhäusern (Muster genügt)

BEHÖRDENKORRESPONDENZ

11. Vollständige Korrespondenz BNetzA (Az. 1-101.05-2026/MA-008)
12. BfDI-Schreiben vom 15.02.2026 (Az. 13-3120/004#0117)
13. BfArM-Bescheid vom 12.01.2026 (Az. MED-AI-2026-0319)
14. TÜV-SÜD-NB-Zertifikat MDR (NB 0123, ausgestellt Nov. 2025)

LLAMA-KOMPONENTE

15. Fine-Tuning-Dokumentation für MedAssist-LLM-Core v4 (Trainingsparameter, Datensatz, verwendete Llama-Version)
16. Kopie der Llama-RAIL-Lizenz und Acceptable Use Policy

Für die Unterlagen gilt die anwaltliche Verschwiegenheitspflicht nach § 43a BRAO. Soweit Unterlagen als "streng vertraulich" gekennzeichnet sind, bitte ich um einen entsprechenden Hinweis; wir werden diese gesondert behandeln.

Bitte bestätigen Sie den Eingang dieser E-Mail und teilen Sie mir mit, welche Unterlagen bis wann vorliegen werden. Falls einzelne Dokumente noch nicht existieren, bitte ich um explizite Mitteilung — dies ist für die Prüfung ebenfalls wichtige Information.

Die Prüfungsfrist 02.08.2026 lässt keinen Spielraum. Jede Verzögerung bei der Unterlagenlieferung verschiebt den kritischen Pfad und gefährdet die fristgerechte Konformität.

Mit freundlichen kollegialen Grüßen

RAin Dr. Henrietta Vellbruck-Steinheim
Fachanwältin für IT-Recht | Datenschutzrecht
Vellbruck & Partner mbB
Erbprinzenstraße 14 | 69117 Heidelberg
Tel.: 06221 / 84 90-100
Fax: 06221 / 84 90-199
E-Mail: h.vellbruck-steinheim@vellbruck-partner.de

Vellbruck & Partner mbB
Partnerschaftsregister AG Heidelberg PR 714
Berufshaftpflichtversicherung: R+V Allgemeine Versicherung AG, Wiesbaden

[Diese E-Mail und ihre Anhänge sind vertraulich und ausschließlich für den bezeichneten Empfänger bestimmt. Weiterleitung oder Kopie ohne ausdrückliche Genehmigung ist untersagt.]

email-vellbruck-an-vorstand-zwischenbefund.eml

Von	h.vellbruck-steinheim@vellbruck-partner.de
An	t.vogelkamp@medassist-ai.de
Kopie	a.krishnamurthy@medassist-ai.de, l.federkamp@medassist-ai.de, m.roosendaal@vellbruck-partner.de, m.albrecht-haag@medassist-ai.de
Datum	Thu, 30 Apr 2026 18:02:31 +0200
Betreff	Az. 2026-V-0427 — VERTRAULICH — Zwischenbefund KI-VO-Prüfung (Kurzfassung)

VERTRAULICH — NUR FÜR DIE ADRESSATEN BESTIMMT

Sehr geehrte Frau Dr. Vogelkamp,
sehr geehrter Herr Krishnamurthy,
sehr geehrter Herr Dr. Federkamp,

wie angekündigt übermittle ich Ihnen den Zwischenbefund der KI-VO-Konformitätsprüfung für MedAssist v4 (Az. 2026-V-0427), Stand 30.04.2026.

Die vollständigen Prüfungsberichte (Aktenstücke 03–19) wurden Ihnen bereits in Einzelform zugeleitet. Diese E-Mail fasst die Kernpunkte zusammen, die ich für die kurzfristige Entscheidung des Vorstands für maßgeblich halte.

GESAMTBEFUND — DREI KERNBOTSCHAFTEN**1. SCHWERWIEGENDESTES PROBLEM: Menschliche Aufsicht (Art. 14 KI-VO)**

In 14 von 18 Kliniken fehlte bis heute der erzwungene Quittierungsschritt.

POSITIV: CTO Krishnamurthy hat mir heute Nachmittag bestätigt, dass der Roll-out auf alle 18 Kliniken heute Abend (30.04.2026) abgeschlossen wird. Das ist die wichtigste Sofortmaßnahme — ich bitte um schriftliche Bestätigung des abgeschlossenen Roll-outs bis morgen, 08:00 Uhr.

2. KRITISCHER PFAD: TÜV SÜD muss sofort beauftragt werden

Das Konformitätsbewertungsverfahren (Art. 43 KI-VO) durch eine notifizierte Stelle ist **NICHT EINGELEITET**. Die Frist 02.08.2026 lässt sich nur einhalten, wenn TÜV SÜD spätestens am 15.05.2026 beauftragt wird und sofort mit der Prüfung beginnt. Jede weitere Woche Verzögerung gefährdet die Frist. **BITTE:** Klären Sie intern bis Montag, 04.05.2026, wer den TÜV-SÜD-Auftrag unterzeichnet und beauftragen Sie meine Kanzlei, den Vertragsentwurf zu prüfen.

3. D&O-VERSICHERUNG: Persönliches Haftungsrisiko

Ohne D&O-Schutz haften Sie, Herr Krishnamurthy und Herr Dr. Federkamp persönlich nach § 43 GmbHG für Schäden aus dem KI-VO-Verstoß. Die Kündigung der Allianz SE zum 01.07.2026 ist ernst zu nehmen. Ich empfehle, spätestens Mitte Mai 2026 das Verhandlungsgespräch mit Allianz SE zu suchen und den Handlungsplan als Anlage vorzulegen. Parallel: Marktabfrage bei AXA XL und Zurich Corporate Solutions.

AKTUELLER STAND BEHÖRDLICHE VERFAHREN

BNetzA (Az. 1-101.05-2026/MA-008):

Vor-Ort-Besichtigung Klinikum Mannheim-Süd ist für 12.05.2026 terminiert.

Ich werde selbst vor Ort sein. Bitte sicherstellen, dass das Leitstellen-Team Mannheim-Süd bis 11.05.2026 für ein kurzes Briefing (30 Min.) zur Verfügung steht.

BfDI (Az. 13-3120/004#0117):

DPIA wird bis 01.05.2026 (morgen) fertiggestellt und übermittelt. RA Dr. Roosendaal arbeitet heute noch daran. Bitte stellen Sie sicher, dass wir die Sachverhaltsangaben zu den AVV der 18 Kliniken erhalten (Rückfrage läuft bei Herrn Albrecht-Haag).

NÄCHSTE TERMINFENSTER

- 04.05.2026 (Montag): Ihrer Rückmeldung re TÜV-SÜD-Beauftragung
- 12.05.2026: BNetzA Vor-Ort-Besichtigung
- 14.05.2026: Interne Vorstandspräsentation (mein Büro)
- 15.05.2026: Beauftragung TÜV SÜD (DEADLINE)

Ich stehe Ihnen für Rückfragen telefonisch (06221 / 84 90-100) oder per E-Mail jederzeit zur Verfügung.

Mit freundlichen Grüßen

RAin Dr. Henrietta Vellbruck-Steinheim
Vellbruck & Partner mbB — Az. 2026-V-0427

[VERTRAULICH — Anwalt-Mandant-Privileg — diese E-Mail ist nur für die genannten Empfänger bestimmt und unterliegt der anwaltlichen Verschwiegenheit nach § 43a BRAO]

incident-log-2025-auszug.csv

incident_id

INC-2025-004

datum

2025-01-19

klinik

Partnerklinik A (Mannheim)

modul

Dispositionsmodul

beschreibung

Priorisierung Stufe 3 statt Stufe 1 bei Brustschmerz-Anruf mit ausländischem Akzent, Disponentin korrigierte manuell

schweregrad_intern

hoch

status

geschlossen

gemeldet_an

interner Qualitätszirkel

incident_id

INC-2025-011

datum

2025-03-02

klinik

Partnerklinik B (Karlsruhe)

modul

NLU-Modul

beschreibung

Spracherkennung brach bei Hintergrundgeräuschen ab, Anruf wurde ohne Klassifikation in die Warteschlange gelegt (11 Minuten)

schweregrad_intern

mittel

status

geschlossen

gemeldet_an

niemand extern

incident_id

INC-2025-017

datum

2025-04-27

klinik

Partnerklinik A (Mannheim)

modul

Dispositionsmodul

beschreibung

Doppelte Alarmierung Rettungsmittel nach Systemneustart, Update-Hotfix 4.1.2 eingespielt

schweregrad_intern

niedrig

status

geschlossen

gemeldet_an

Hersteller-Ticket 8841

incident_id

INC-2025-023

datum

2025-06-14

klinik

Partnerklinik C (Freiburg)

modul

NLU-Modul

beschreibung

Kindernotfall als Erwachsenenfall klassifiziert, Altersangabe aus dem Gespräch nicht übernommen

schweregrad_intern

hoch

status

offen laut Log, laut Vermerk Vogelkamp aber behoben

gemeldet_an

interner Qualitätszirkel

incident_id

INC-2025-031

datum

2025-08-30

klinik

Partnerklinik B (Karlsruhe)

modul

Gesamtsystem

beschreibung

Ausfall Cloud-Anbindung 02:14 bis 03:47 Uhr, Rückfall auf manuelle Disposition, kein Protokolleintrag im Audit-Log für 41 Minuten

schweregrad_intern

hoch

status

geschlossen

gemeldet_an

niemand extern

incident_id

INC-2025-038

datum

2025-10-08

klinik

Partnerklinik A (Mannheim)

modul

Dispositionsmodul

beschreibung

Eintrag nachträglich geändert, ursprüngliche Beschreibung im Änderungsverlauf nicht mehr vorhanden

schweregrad_intern

unbewertet

status

offen

gemeldet_an

unklar

incident_id

INC-2025-044

datum

2025-12-21

klinik

Partnerklinik C (Freiburg)

modul

NLU-Modul

beschreibung

Beschwerde einer Disponentin über wiederholte Fehlklassifikation bei Dialektsprechern, Sammelticket angelegt

schweregrad_intern

mittel

status

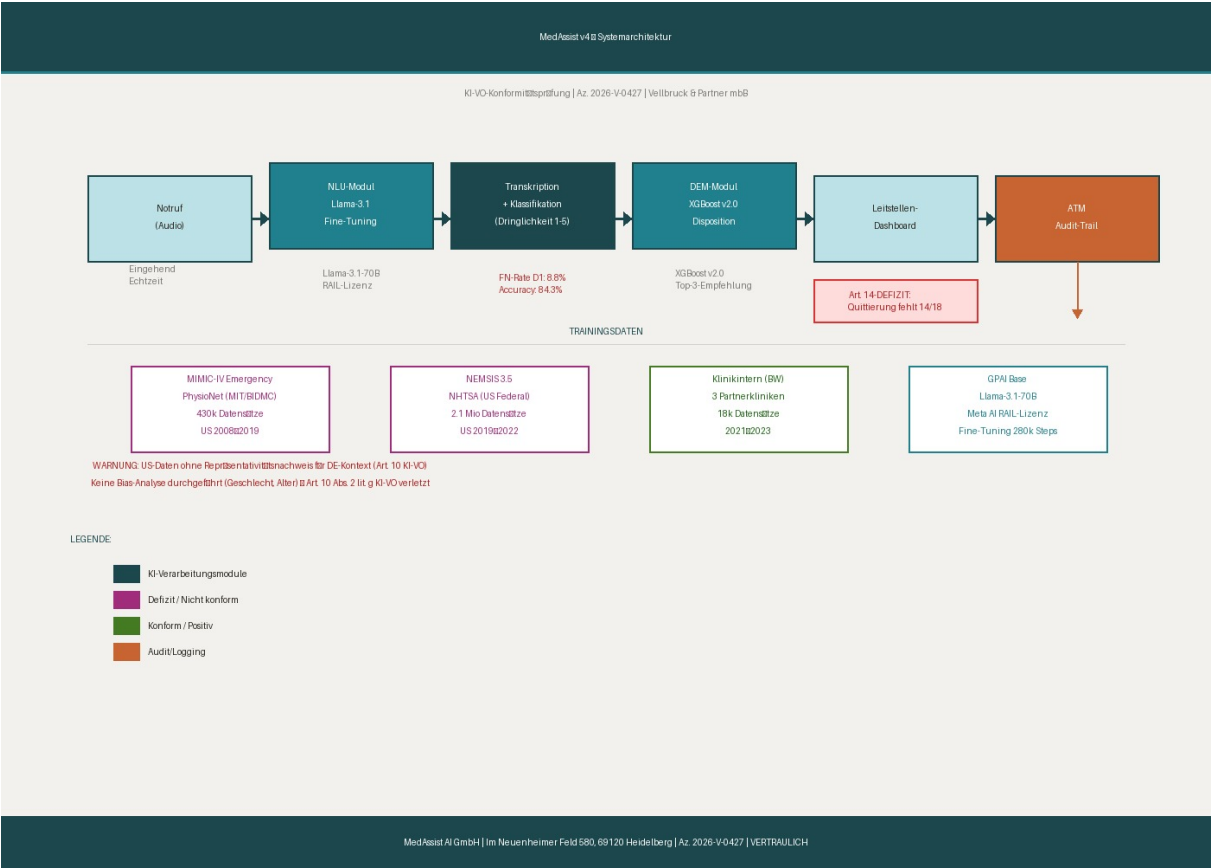
offen

gemeldet_an

Hersteller-Ticket 9310

BILDANLAGEN UND SCREENSHOTS

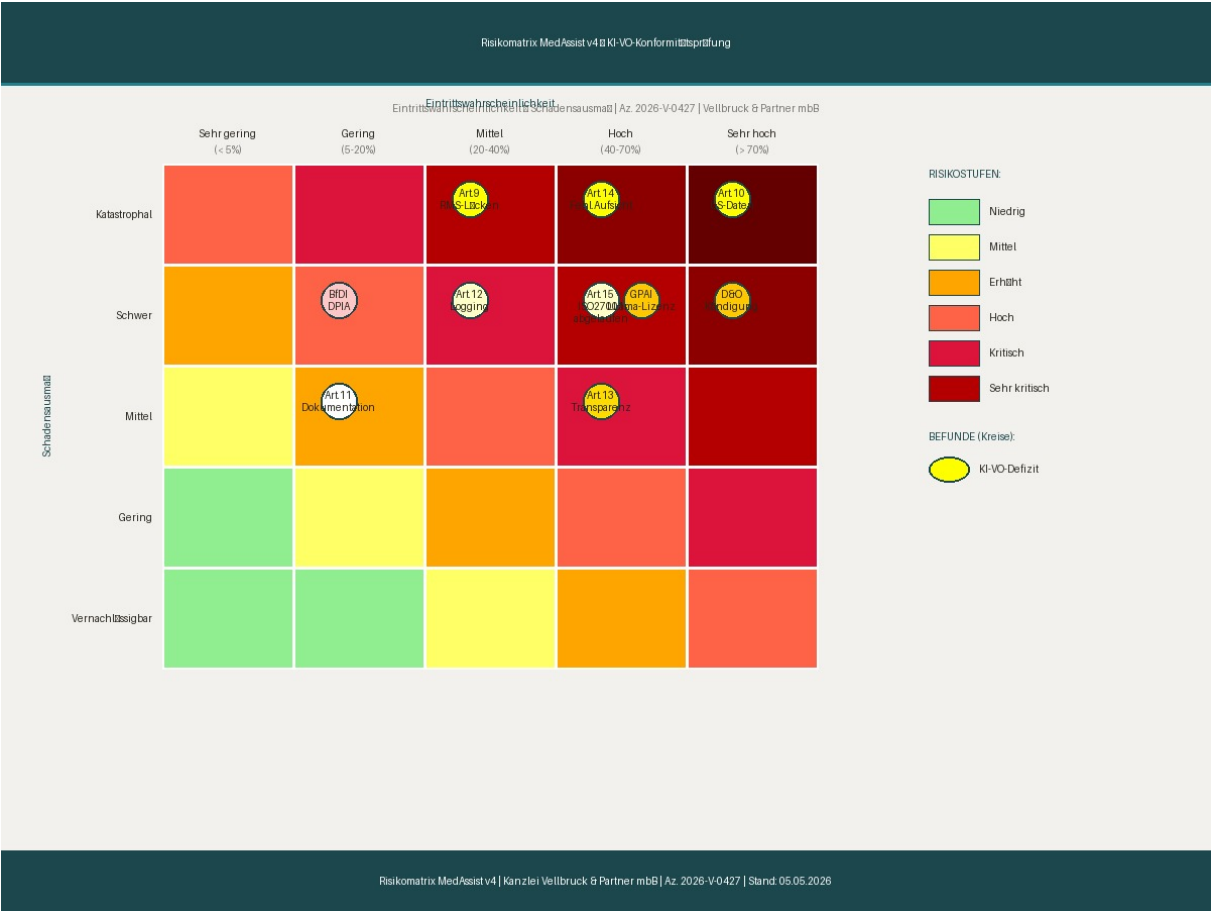
medassist-systemarchitektur.jpg



Bilddatei: medassist-systemarchitektur.jpg

BILDANLAGEN UND SCREENSHOTS

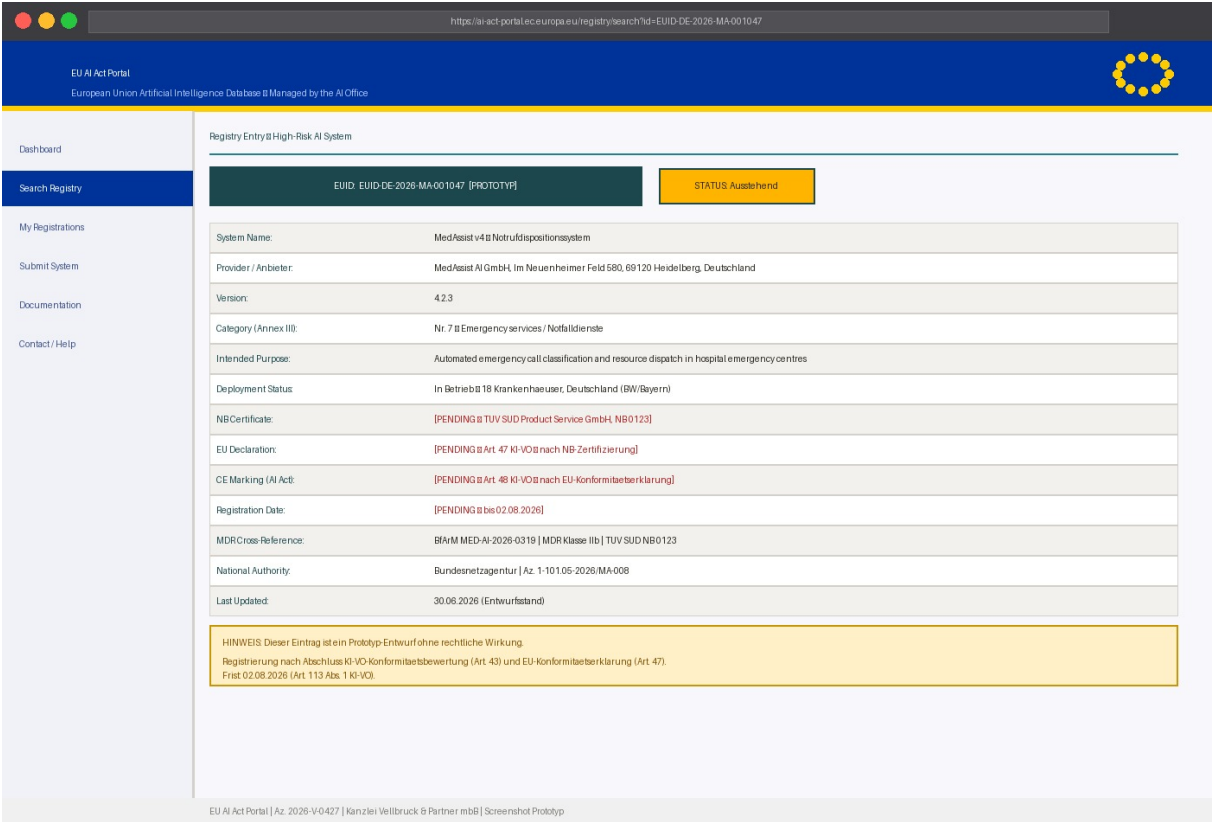
risikomatrix-heatmap.jpg



Bilddatei: risikomatrix-heatmap.jpg

BILDANLAGEN UND SCREENSHOTS

screenshot-eu-datenbank-eintrag.jpg



Bilddatei: screenshot-eu-datenbank-eintrag.jpg

pflichten-checkliste-art-9-bis-15.xlsx

KI-VO-Konformitätscheckliste — MedAssist v4 — Art. 9-15 (KI-VO EU 2024/1689)

Kanzlei Vellbruck & Partner mbB — Az. 2026-V-0427 — Stand: 05.05.2026 — Vertraulich

Artikel	Anforderung	Status MedAssist v4	Befund (Kurzfassung)	Risikostufe	Maßnahme	Frist	Verantwortlich
Art. 9	Risikomanagementsystem (RMS) einrichten und kontinuierlich betreiben	Nicht konform	RMS existiert, wurde seit 2023 nicht aktualisiert; 3 schwerwiegende Vorfälle 2025 nicht eingearbeitet	Kritisch	RMS vollständig aktualisieren; FMEA alle Module; Change-Control-Verfahren einführen	30.04.2026	CTO Krishnamurthy
Art. 9	Alle Risiken identifizieren und analysieren (Art. 9 Abs. 2 lit. a)	Nicht konform	FMEA nur NLU-Modul; Dispositionsmodul und ATM fehlen; kein Bias-Risiko berücksichtigt	Kritisch	FMEA-Erweiterung auf DEM und ATM; Bias-Risikoanalyse	30.04.2026	CTO Krishnamurthy
Art. 9	Quantitative Risikobewertung (Schadensausmaß x Eintrittswahrscheinlichkeit)	Nicht konform	Nur qualitative Beschreibung; keine Risikomatrix	Hoch	Risikomatrix implementieren	15.05.2026	CTO Krishnamurthy
Art. 9	Tests vor Inverkehrbringen und laufend (Art. 9 Abs. 5 und 7)	Teilweise	Testbericht MA-EVAL-2024-03 vorhanden; keine klinische Validierungsstudie in Deutschland	Hoch	Klinische Validierungsstudie beauftragen	01.04.2026 Start	CTO Krishnamurthy
Art. 10	Datenverwaltungspraktiken Trainingsdaten (Art. 10 Abs. 1)	Nicht konform	US-Datensätze MIMIC-IV und NEMIS ohne DSGVO-Rechtsgrundlage für EU-Nutzung	Kritisch	Rechtliche Klärung DSGVO-Grundlage US-Daten; ggf. Ersatz durch EU-Daten	15.05.2026	Dr. Roosendaal
Art. 10	Repräsentativitätsprüfung für Einsatzkontext DE (Art. 10 Abs. 2 lit. f)	Nicht konform	Keine Validierung US-Datensätze für deutschen Rettungsdienstkontext; abweichende Klassifikationsschemata	Kritisch	Validierungsstudie US-Daten für DE-Kontext; Erweiterung DE-Trainingsdaten	15.05.2026	CTO Krishnamurthy
Art. 10	Bias-Prüfung (Geschlecht, Alter, Ethnizität) Art. 10 Abs. 2 lit. g	Nicht konform	Keine Bias-Analyse durchgeführt; bekanntes Risiko bei Herzinfarkterkennung Frauen	Kritisch	Vollständige Bias-Analyse alle Datensätze	15.06.2026	CTO Krishnamurthy
Art. 10	DSGVO Art. 9: Rechtsgrundlage für Gesundheitsdaten-Verarbeitung (Training)	Nicht konform	Art. 9 Abs. 2 lit. j DSGVO für US-Daten fraglich; interne Rechtsmeinung 2022 nicht belastbar	Hoch	DSGVO-Gutachten zur Zulässigkeit US-Datensätze	01.05.2026	Dr. Roosendaal
Art. 11	Technische Dokumentation nach Anhang IV (vollständig)	Nicht konform	11 Kategorien Anhang IV: 1 vollständig, 6 teilweise, 4 fehlend; GPAI-Komponente nicht beschrieben	Kritisch	Vollständige Neufassung Anhang-IV-konforme technische Dokumentation	01.06.2026	CTO Krishnamurthy / Dr. Roosendaal
Art. 11	Integration GPAI-Dokumentation (Art. 11 Abs. 3 KI-VO)	Nicht konform	Llama-3.1 System Card nicht in technische Dokumentation integriert	Hoch	Llama-3.1 System Card einbeziehen; Fine-Tuning dokumentieren	30.05.2026	CTO Krishnamurthy
Art. 11	Klinische Validierungsstudie (Anhang IV Nr. 9)	Nicht konform	Nur interne Tests; keine klinische Studie in deutschen Krankenhäusern	Hoch	Prospektive Studie beauftragen und in Dokumentation einbeziehen	Laufend	CTO Krishnamurthy
Art. 12	Logging Disponenten-Identität (Art. 12 Abs. 3 lit. d)	Nicht konform (14/18 Kliniken)	Disponenten-ID wird in 14 von 18 Kliniken nicht protokolliert; direkter Verstoß	Kritisch	Roll-out Disponenten-ID-Logging alle 18 Kliniken	30.04.2026	CTO Krishnamurthy

Art. 12	Protokollierung Modellversion im Log (Art. 12 Abs. 2)	Nicht konform	Keine Modellversionierung im Audit-Trail; bei 3 Vorfällen 2025 bereits problematisch	Hoch	Modellversionierung in ATM ergänzen	30.04.2026	CTO Krishnamurthy
Art. 12	DEM Top-3-Alternativen im Log (Art. 12 Abs. 2)	Teilweise	Nur Top-1-Empfehlung protokolliert; nicht alle angezeigten Optionen gespeichert	Mittel	Log-Erweiterung DEM auf Top-3	31.05.2026	CTO Krishnamurthy
Art. 12	Datenhaltungsdauer: Abstimmung mit § 630f BGB (10 Jahre Medizin)	Klärungsbedarf	ATM: 5 Jahre; medizinrechtlich 10 Jahre — Diskrepanz nicht aufgelöst	Mittel	Abstimmung Datenhaltungskonzept med./KI-VO	15.05.2026	Dr. Roosendaal
Art. 13	Einsatzbeschränkungen im Benutzerhandbuch (Art. 13 Abs. 3 lit. b)	Nicht konform	Kein ausdrückliches Verbot für Nichtdeutsch-Notrufe, Grenzfälle; Leistungsgrenzen fehlen	Hoch	Benutzerhandbuch v4.2 — Abschnitt Einsatzbeschränkungen ergänzen	31.05.2026	CTO Krishnamurthy
Art. 13	Genauigkeitsangaben im Benutzerhandbuch (Art. 13 Abs. 3 lit. c)	Nicht konform	Accuracy-Daten aus MA-EVAL-2024-03 nicht für Betreiber zugänglich	Hoch	Accuracy-Summary in Benutzerhandbuch aufnehmen	31.05.2026	CTO Krishnamurthy
Art. 13	Fallback-Verfahren bei Systemausfall (Art. 13 Abs. 3 lit. g)	Nicht konform	47-Minuten-Ausfall Freiburg-Süd 2025: kein analoges Fallback-Protokoll vorhanden	Hoch	Fallback-Protokoll Manualmode entwickeln und schulen	30.04.2026	CTO Krishnamurthy
Art. 13	Information zu Patientenrechten DSGVO Art. 22 (Art. 13 Abs. 3 lit. h)	Nicht konform	Keine Hinweise im Handbuch zu automatisierten Entscheidungen und Widerspruchsrecht	Mittel	Abschnitt Betroffenenrechte in Handbuch + Patientenaufklärung	31.05.2026	Dr. Roosendaal
Art. 14	Technisch erzwungener Quittierungsschritt vor Empfehlungsübernahme	KRITISCH — 14/18 Kliniken ohne Quittierung	Schwerster Befund: de facto automatisierte Disposition in 14 Kliniken ohne dokumentierte menschliche Prüfung	Kritisch	Roll-out Pflicht-Quittierungsschritt alle 18 Kliniken — SOFORTMASSNAHME	30.04.2026	CTO Krishnamurthy
Art. 14	Disponenten-Schulung (Kompetenzsicherung Art. 14 Abs. 3)	Nicht konform	Keine standardisierte Schulung; 2-seitige Einweisungsunterlage unzureichend	Hoch	Schulungscurriculum 4h entwickeln und rollieren	31.05.2026	Dr. Vellbruck-Steinheim (Koord.)
Art. 14	Erklärbarkeit der Empfehlungen (Art. 14 Abs. 1: Verständlichkeit)	Nicht konform	Kein Confidence-Breakdown, keine SHAP-Erklärung im Dashboard; Disponent kann Plausibilität nicht prüfen	Hoch	Erklärbarkeits-Modul Dashboard implementieren	30.06.2026	CTO Krishnamurthy
Art. 15	Genauigkeit: Recall Dringlichkeit 1 (lebensbedrohlich) > 98 %	Nicht konform	Recall 91,2 %; False-Negative-Rate 8,8 % — jede 11. lebensbedrohliche Lage unterklassifiziert	Kritisch	Modellverbesserung; Konzeptdrift-Monitoring einführen	30.06.2026	CTO Krishnamurthy
Art. 15	Accuracy psychiatrische Notfälle > 80 %	Nicht konform	Accuracy 62,1 % — erheblich unter Benchmark	Hoch	Zusätzliche Trainingsdaten psychiatrische Notfälle; Re-Training	30.06.2026	CTO Krishnamurthy
Art. 15	ISO/IEC 27001:2022 Zertifizierung (Cybersicherheit Art. 15 Abs. 4)	Nicht konform	Zertifikat abgelaufen 13.06.2025 — nicht erneuert	Kritisch	Rezertifizierung ISO 27001:2022 unverzüglich einleiten	30.06.2026	CTO Krishnamurthy
Art. 15	Adversarial Testing NLU-Modul (Art. 15 Abs. 5)	Nicht konform	Kein Adversarial Testing auf KI-spezifische Angriffe dokumentiert	Hoch	Penetrationstest mit KI-Angriffsvektoren beauftragen	30.06.2026	CTO Krishnamurthy

Art. 15	Test fremdsprachige Anrufer / Dialekte	Offen	Nicht getestet; erhebliches Einsatzrisiko in Kliniken mit internationaler Patientenschaft	Mittel	Testscenarien fremdsprachige Notrufe; Leistungsgrenze dokumentieren	30.06.2026	CTO Krishnamurthy
---------	--	-------	---	--------	---	------------	-------------------

prueftiefe-matrix.xlsx

Prüftiefe-Matrix MedAssist v4 — KI-VO-Konformitätsprüfung — Vellbruck & Partner mbB

Az. 2026-V-0427 | Stand: 20.04.2026 | Vertraulich — Anwalt-Mandant-Privileg

Modul / Komponente	Datensatz (Haupt)	Trainingsmethode	Validierung	Robustheit	Bias-Test	Fallback	Audit-Status	Anmerkung (Befund)
NLU-Modul — Transkription (ASR)	MIMIC-IV Emergency; NEMESIS 3.5; 18k Klinik-BW	Fine-Tuning Llama-3.1-70B-Instruct; 280k Trainingsschritte	Intern (MA-EVAL-2024-03); keine klinische Studie DE	Hintergrundlärm getestet; Fremdsprachen NICHT	Nicht durchgeführt	Manuell-Protokoll (rudimentär)	LÜCKE: Anhang IV unvollständig	GPAI-Basis: Llama-3.1; System Card nicht integriert
NLU-Modul — Klassifikation (Dringlichkeit 1–5)	Wie oben	Supervised Learning (Labeled Emergency Calls)	Accuracy 84,3 % (gesamt); FN-Rate D1: 8,8 %	Adversarial Testing: NICHT durchgeführt	Nicht durchgeführt	Kein automatischer Fallback auf Klassifiz.-Stufe	KRITISCH: FN-Rate zu hoch für klinischen Einsatz ohne Aufsicht	Kernbefund Art. 15 und Art. 14; sofortiger Handlungsbedarf
NLU-Modul — Kategorisierung (Diagnosegruppe)	Wie oben	Supervised Learning (Kategorie-Labels aus US-Daten)	Accuracy 78,6 % gesamt; psych. Notfälle: 62,1 %	Dialekte getestet (bayer. –3,1 %)	Nicht durchgeführt	Fallback auf allgemein/intern	LÜCKE: psych. Kategorie erheblich unterperformant	Kategorisierung psychiatrischer Notfälle kritisch; Re-Training erforderlich
NLU-Modul — Konfidenzschätzung	Wie oben	Softmax-Output über Klassenlogits	Kalibrierungsprüfung: nicht dokumentiert	Kein Kalibrierungstest bei Verteilungsverschiebung	Nicht anwendbar	Konfidenzwert im Dashboard angezeigt	LÜCKE: Kalibrierung nicht geprüft	Gut kalibrierter Konfidenzwert Voraussetzung für Art. 13/14-Konformität
Dispositionsmodul (DEM — XGBoost)	3 Jahre Krankenhausdaten 2020–2023 (stationsintern); Echtzeit-Kapazitätsfeed	Gradient Boosting (XGBoost v2.0); Hyperparameter-Tuning intern	Backtesting 2020–2023; keine prospektive Validierung	Lasttest: bei 50+ parallelen Notrufen Latenz > 800 ms	Nicht durchgeführt	Top-1-Empfehlung bei Ausfallzustand	LÜCKE: Konzeptdrift-Monitoring fehlt; Trainingsdate 2020–2023	Konzeptdrift-Risiko: 3 Jahre Deployment ohne Retraining; Kapazitätsmuster können sich verändert haben
Dispositionsmodul — Ressourcenzuweisung	Echtzeit-Kapazitätsfeed Stationen	Rule-Based + XGBoost-Scoring	Nicht separat validiert	Netzwerktrennung getestet (Graceful Degradation)	Nicht anwendbar	Fallback: letzte bekannte Kapazitätsdaten	TEILWEISE: Graceful Degradation dokumentiert	Fallback-Dokumentation für Betreiber fehlt im Benutzerhandbuch (Art. 13-Defizit)
Audit-Trail-Modul (ATM)	Kein Training; Logging-Infrastruktur	Regelbasiert; REST-API-Export	Export-API getestet (BNetzA-Auskunft 15.03.2026)	Kein Stress-Test auf hohen Log-Durchsatz dokumentiert	Nicht anwendbar	Syslog-Backup vorhanden	LÜCKE: Disponenten-ID fehlt in 14/18 Kliniken; Modellversion nicht geloggt	Kritischer Art. 12-Befund; Roll-out Disponenten-ID-Logging läuft
GPAI-Komponente — Llama-3.1-70B Base	Meta AI Pretraining (öffentlich bekannt)	Pretraining Meta AI (nicht durch MedAssist verantwortet)	Meta AI System Card vorhanden (online)	Meta AI Adversarial Testing (laut System Card)	Nicht von MedAssist geprüft	Fine-Tuning-Modell als Fallback	LÜCKE: System Card nicht in MedAssist-Dokumentation integriert	Art. 11 Abs. 3 KI-VO: Integration Meta-Dokumentation in technische Dokumentation MedAssist erforderlich
Cybersicherheits-Layer (ISO 27001)	Nicht anwendbar (Infrastruktur-Zertifizierung)	Nicht anwendbar	ISO 27001:2022 Audit 2022 (TÜV Rheinland)	Penetrationstest 2022 (allgemein); kein KI-spezifischer Pentest	Nicht anwendbar	ISMS-Notfallprozess (2022)	KRITISCH: Zertifikat abgelaufen 13.06.2025; keine Rezertifizierung	Art. 15 Abs. 4 KI-VO verletzt; NIS-2-Eigenprüfung als Lieferant ausstehend
Gesamtsystem-Integration (End-to-End)	Alle Datensätze kombiniert	Pipeline: ASR → NLU → DEM → Dashboard	End-to-End-Latenz getestet (95. Pz. 1.240 ms > Zielwert 800 ms)	Systemausfall Freiburg-Süd 47 min (2025) als Realtest	Nicht durchgeführt	Manueller Betrieb nicht dokumentiert	KRITISCH: End-to-End kein Art. 14-konformer Aufsichtsmechanismus in 14/18 Kliniken	Integrationstest unter realen Bedingungen (Art. 9 Abs. 7 KI-VO) nicht abgeschlossen
Klinische Validierungsstudie DE	Noch nicht vorhanden	Noch nicht durchgeführt	Ausstehend — beauftragen ab 01.04.2026	Im Rahmen der Studie zu erheben	Im Rahmen der Studie zu erheben	Nicht anwendbar	FEHLEND: Kein klinischer Validierungsnachweis für DE-Kontext	Art. 9 Abs. 7 KI-VO + MDR Anhang XIV: Klinische Evaluierung DE zwingend erforderlich; koordinierter Ansatz empfohlen
Post-Market Monitoring System	Noch nicht vorhanden	Noch nicht implementiert	Noch nicht implementiert	Nicht anwendbar	Nicht anwendbar	Nicht anwendbar	FEHLEND: Kein PMS nach Art. 72 KI-VO / Art. 83 MDR (KI-spezifisch)	Reaktiver Incident-Log vorhanden; proaktives Monitoring fehlt; Art. 17 KI-VO-QMS muss PMS einschließen

01-mandatsuebernahme-vellbruck-medassist.docx

Aktenstück 01 — Mandatsübernahme Vellbruck & Partner / MedAssist AI GmbH

Kanzlei: Vellbruck & Partner mbB, Erbprinzenstraße 14, 69117 Heidelberg

Aktenzeichen: 2026-V-0427

Mandant: MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg

Gegenstand: Konformitätsprüfung KI-VO (EU) 2024/1689 — MedAssist v4 (Hochrisiko-KI)

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim (federführend), RA Dr. Mark Roosendaal

Eröffnet: 03.03.2026

Frist: 02.08.2026 (Art. 113 Abs. 1 KI-VO)

1. Erstgespräch

Am 03.03.2026 fand ein Erstgespräch in den Räumen der Kanzlei Vellbruck & Partner statt.

Anwesend: RAin Dr. Vellbruck-Steinheim, RA Dr. Roosendaal sowie auf Mandantenseite CEO Dr. Theresia Vogelkamp, CTO Aravind Krishnamurthy und Chefjustiziar Michael Albrecht-Haag (MedAssist AI GmbH).

1.1 Anlass des Mandats

Dr. Vogelkamp schilderte, dass MedAssist AI GmbH mit dem System MedAssist v4 in 18 Krankenhäusern in Baden-Württemberg und Bayern im Echtbetrieb tätig sei. Das System unterstütze — nach Eigenauskunft des Mandanten — die automatisierte Notrufdisposition: eingehende Notrufe werden durch MedAssist v4 klassifiziert, Dringlichkeitsstufen werden vorgeschlagen und Notfallressourcen werden priorisiert zugeteilt.

Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI) habe mit Schreiben vom 15.02.2026 (Az. 13-3120/004#0117) eine datenschutzrechtliche Folgenabschätzung nach Art. 35 DSGVO angefordert. Parallel habe die Bundesnetzagentur (BNetzA) am 22.02.2026 ein Marktüberwachungsverfahren eröffnet (Az. 1-101.05-2026/MA-008). Die Allianz SE habe mit Schreiben vom 01.03.2026 mitgeteilt, die D&O-Versicherung werde zum 01.07.2026 gekündigt, sofern kein Nachweis über eingeleitete KI-VO-Konformitätsmaßnahmen vorgelegt werde.

1.2 Erste rechtliche Einschätzung

RAin Dr. Vellbruck-Steinheim wies in der Besprechung auf folgende Kernpunkte hin:

1. **Einstufung als Hochrisiko-KI:** MedAssist v4 dürfte unter Anhang III Nr. 7 KI-VO fallen (KI-Systeme für Notfalldienste). Damit greifen die Anforderungen der Art. 9–15 KI-VO unmittelbar. Die Übergangsfrist für bereits vor dem 01.08.2026 in Verkehr gebrachte Hochrisiko-KI-Systeme nach Anhang III läuft gemäß Art. 113 Abs. 1 KI-VO zum 02.08.2026 ab.
2. **Doppelregulierung MDR/KI-VO:** Da MedAssist v4 zugleich als Medizinprodukt der Klasse IIb nach MDR (EU) 2017/745 eingestuft ist, bestehen parallele Konformitätspflichten. Das BfArM hat mit Bescheid vom 12.01.2026 (Az. MED-AI-2026-0319) die MDR-Konformität vorläufig anerkannt, jedoch explizit auf die ausstehende KI-VO-Konformität hingewiesen.

3. **GPAI-Basiskomponente:** Soweit MedAssist v4 auf einer Llama-basierten Adaptation aufbaut, stellt sich die Frage, ob die Anbieter-Dokumentationspflichten nach Art. 53 KI-VO (GPAI-Modelle) erfüllt sind.
4. **Wettbewerberbeschwerde:** Die DiagnoFlow GmbH (München) hat laut Presseberichten beim DG CONNECT der EU-Kommission eine Beschwerde wegen möglichen KI-VO-Verstoßes eingereicht.

1.3 Prüfumfang (vereinbart)

Prüfpunkt	Artikel KI-VO	Bearbeitung
Einstufung Hochrisiko-KI	Art. 6, Anhang III Nr. 7	Dr. Vellbruck-Steinheim
Risikomanagementsystem	Art. 9	Dr. Roosendaal
Daten-Governance	Art. 10	Dr. Roosendaal
Technische Dokumentation	Art. 11, Anhang IV	Dr. Roosendaal
Aufzeichnungspflichten	Art. 12	Dr. Roosendaal
Transparenz Anbieter	Art. 13	Dr. Vellbruck-Steinheim
Menschliche Aufsicht	Art. 14	Dr. Vellbruck-Steinheim
Genauigkeit/Robustheit/ Cybersicherheit	Art. 15	Dr. Roosendaal
Konformitätsbewertung	Art. 43	Dr. Vellbruck-Steinheim
EU-Konformitätserklärung	Art. 47	Dr. Vellbruck-Steinheim
CE-Kennzeichnung	Art. 48	Dr. Vellbruck-Steinheim
EU-Datenbank-Registrierung	Art. 49	Dr. Roosendaal
MDR-Schnittstelle	MDR 2017/745	Dr. Vellbruck-Steinheim
BNetzA-Marktüberwachung	Art. 74 ff. KI-VO	Dr. Vellbruck-Steinheim
GPAI-Basiskomponente	Art. 53 KI-VO	Dr. Roosendaal
DPIA nach Art. 35 DSGVO	DSGVO Art. 35	Dr. Roosendaal

2. Interessenkonfliktprüfung

Gemäß § 43a Abs. 4 BRAO sowie den Vorgaben der BORA wurde geprüft, ob kollidierende Mandate bestehen. Die Kanzlei Vellbruck & Partner mbB ist weder für DiagnoFlow GmbH noch für andere im KI-Medizinbereich tätige Wettbewerber von MedAssist AI GmbH mandatiert. Ein Interessenkonflikt wurde nicht festgestellt. Die Prüfung ist in der Interessenkonflikt-Datenbank (Ref. IK-2026-0427) dokumentiert.

3. Vergütungsvereinbarung

Die Vergütung wurde auf Stundenbasis vereinbart: RAin Dr. Vellbruck-Steinheim 420 EUR/h netto, RA Dr. Roosendaal 340 EUR/h netto. Kostenobergrenze bis zur Zwischenabrechnung 15.05.2026: 85.000 EUR netto. Die Vereinbarung wurde von CEO Dr. Vogelkamp am 03.03.2026 unterzeichnet (Original in Handakte).

4. Vollmacht

Die Prozess- und Außenvollmacht wurde am 03.03.2026 durch Dr. Theresia Vogelkamp (CEO, einzelvertretungsberechtigt laut HR-Auszug HRB 748921, AG Mannheim, Stand: 01.03.2026) unterzeichnet. Die Vollmacht erstreckt sich auf alle Behörden- und Gerichtsverfahren im Zusammenhang mit der KI-VO-Konformitätsprüfung MedAssist v4, namentlich gegenüber BNetzA (Az. 1-101.05-2026/MA-008), BfDI (Az. 13-3120/004#0117) und BfArM (Az. MED-AI-2026-0319).

5. Nächste Schritte

Maßnahme	Frist	Verantwortlich
Vollständige Systemdokumentation von MedAssist v4 anfordern	10.03.2026	Dr. Roosendaal
Stellungnahme BNetzA-Marktüberwachungsschreiben (1-101.05-2026/MA-008)	20.03.2026	Dr. Vellbruck-Steinheim
Antwort an BfDI re DPIA-Anforderung	01.04.2026	Dr. Roosendaal
Erstbewertung MDR/KI-VO-Schnittstelle	15.04.2026	Dr. Vellbruck-Steinheim
Zwischenbericht an Vorstand MedAssist	15.05.2026	Dr. Vellbruck-Steinheim
Konformitätsgutachten (Vollversion)	30.06.2026	beide

Heidelberg, 03.03.2026

RAin Dr. Henrietta Vellbruck-Steinheim

Kanzlei Vellbruck & Partner mbB — Az. 2026-V-0427

02-system-beschreibung-medassist-v4.docx

Aktenstück 02 — Systembeschreibung MedAssist v4

Aktenzeichen: 2026-V-0427

Erstellt: 12.03.2026 (nach Übermittlung technischer Unterlagen durch CTO Krishnamurthy)

Bearbeitung: RA Dr. Mark Roosendaal

Grundlage: Technische Dokumentation MedAssist v4, Version 2.3 (interne Kennung: MA-TECH-DOC-2024-v4.2.3), übermittelt 08.03.2026

1. Systemidentität

Merkmal	Angabe
Systemname	MedAssist v4
Versionsnummer	4.2.3 (Produktionsstand 18 Krankenhäuser)
Interne Kennung Anbieter	MA-SYS-2023-001
Anbieter (Art. 3 Nr. 3 KI-VO)	MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg
Verwendungszweck	Automatisierte Notrufdisposition in Krankenhäusern — Klassifikation eingehender Notrufe, Dringlichkeitspriorisierung, Ressourcenzuweisung
Einsatzbereich	Notaufnahme-Leitstellen, Rettungskoordinationszentren in Krankenhäusern
Aktuelle Deployments	18 Krankenhäuser in BW (12) und Bayern (6); Standorte s. Anhang A
Sprache (System)	Deutsch, mit begrenzter Englisch-Unterstützung (Notfallkommunikation)
Entwicklungszeitraum	2021–2023 (v4); kontinuierliche Updates seit 2023

2. Systemarchitektur

MedAssist v4 besteht aus drei Hauptkomponenten, die über eine interne REST-API miteinander kommunizieren:

2.1 Sprachverarbeitungsmodul (NLU)

- **Funktion:** Echtzeit-Transkription und Semantikanalyse eingehender Notrufe
- **Basis:** Llama-3.1-70B-Instruct, fine-tuned auf medizinischen Notfalldatensatz (s. Aktenstück 05)
- **Bezeichnung intern:** „MedAssist-LLM-Core v4“
- **GPAI-Status:** Die Llama-Adaptation stellt eine GPAI-Modell-Nutzung i.S.d. Art. 3 Nr. 63 KI-VO dar; Anbieter-Dokumentation nach Art. 53 KI-VO ausstehend (s. Aktenstück 19)
- **Latenz:** < 800 ms für Transkription/Klassifikation
- **Ausgabe:** Strukturierter JSON-Datensatz mit Dringlichkeitsstufe (1–5), erkannter Kategorie (Herznotfall, Trauma, pädiatrisch, psychiatrisch, sonstig), Konfidenzwert (0–1)

2.2 Dispositionsmodul (DEM)

- **Funktion:** Zuweisung verfügbarer Notfallressourcen basierend auf NLU-Ausgabe, Echtzeit-Kapazitätsdaten der Stationen und historischen Verfügbarkeitsprofilen
- **Methode:** Gradient Boosting (XGBoost v2.0), trainiert auf 3 Jahre Krankenhausdaten (2020–2023)

- **Ausgabe:** Empfohlene Ressourcenzuweisung mit Konfidenzwert und alternativen Optionen (Top-3)
- **Menschliche Schnittstelle:** Vorschlag wird im Leitstellen-Dashboard angezeigt; Übernahme-Button durch Disponent erforderlich (konzeptionell)

2.3 Audit-Trail-Modul (ATM)

- **Funktion:** Protokollierung aller Systemereignisse (Eingabe, Klassifikation, Disposition, Bedieneraktion, Zeitstempel)
- **Datenhaltung:** 5 Jahre (intern definiert), verschlüsselt auf Klinikum-Infrastruktur
- **Schnittstelle:** Export-API für Behördenanfragen (BNetzA, BfArM)

3. Datenfluss (vereinfacht)

...

Eingehender Notruf (Audio)

↓

NLU-Modul (Llama-Adaptation)

— Transkription

— Klassifikation (Dringlichkeit, Kategorie, Konfidenz)

↓

Dispositionsmodul (XGBoost)

— Kapazitätsabgleich Echtzeitdaten

— Top-3-Empfehlung

↓

Leitstellen-Dashboard

— Anzeige Empfehlung

— [Disponent: Übernahme / Ablehnung] ← kritische Aufsichtslücke (Art. 14)

↓

Audit-Trail-Modul

— Protokollierung

...

Feststellung: Das Übernahme-Interface ist in der aktuellen Produktionsversion 4.2.3 nicht vollständig implementiert. In 14 der 18 Krankenhäuser übernehmen Disponenten die Empfehlung ohne explizite Bestätigung im System — es fehlt ein erzwungener Quittierungsschritt (s. Aktenstück 09, Art. 14-Befund).

4. Trainingsdaten (Überblick)

Datensatz	Herkunft	Umfang	Zeitraum	Repräsentativitätsdokumentation
MIMIC-IV Emergency	PhysioNet (US), MIT/BIDMC	ca. 430.000 Notfallprotokolle	2008–2019	Keine DE-spezifische Validierung
NEMESIS 3.5	NHTSA (US)	ca. 2,1 Mio. EMS-Datensätze	2019–2022	Keine EU-Anpassung dokumentiert
Klinikinterne Trainingsdaten (anonymisiert)	3 Partnerkliniken BW	ca. 18.000 Einsatzprotokolle	2021–2023	Begrenzte Repräsentativität

Kernproblem: Die US-amerikanischen Datensätze (MIMIC-IV, NEMESIS) sind dominant und weisen strukturelle Unterschiede zum deutschen Rettungsdienstsystem auf (andere Klassifikationsschemata, abweichende Ressourcentypen, US-spezifische Terminologie). Eine dokumentierte Repräsentativitätsprüfung für den deutschen Einsatzkontext fehlt, was Art. 10 Abs. 2 lit. f KI-VO verletzt (s. Aktenstück 05).

5. Technische Leistungsparameter (nach internem Testbericht MA-EVAL-2024-03)

Metrik	Wert	Bewertung
Accuracy (Dringlichkeitsstufe, gesamt)	84,3 %	Unzureichend für klinischen Einsatz bei Fehlen menschlicher Aufsicht
Recall Dringlichkeit 1 (lebensbedrohlich)	91,2 %	Positiv, aber Fehlerrate bei 8,8 % kritisch
False-Negative-Rate Dringlichkeit 1	8,8 %	Hochriskant: jede 11. lebensbedrohliche Lage wird unterklassifiziert
Accuracy Kategorisierung	78,6 %	Ungenügend, v.a. psychiatrische Notfälle (62,1 %)
Latenz 95. Perzentile	1.240 ms	Überschreitet internen Zielwert (< 800 ms) unter Last
Bias-Kennzahl (Geschlecht)	Nicht erhoben	Verstoß Art. 10 Abs. 2 lit. g KI-VO
Bias-Kennzahl (Alter)	Nicht erhoben	Verstoß Art. 10 Abs. 2 lit. g KI-VO

6. Einsatzumgebung

MedAssist v4 wird auf klinikumseitiger On-Premises-Infrastruktur betrieben. Jede Klinik hostet eine lokale Instanz; Updates werden zentral durch MedAssist AI GmbH eingespielt (Remote-Deployment-Kapazität). Die lokalen Instanzen kommunizieren nicht miteinander; Trainingsdaten werden klinikumseitig nicht zurückgespiegelt.

Datenschutzrechtliche Einordnung: Jede Klinik ist Verantwortliche i.S.d. Art. 4 Nr. 7 DSGVO für die verarbeiteten Patientendaten; MedAssist AI GmbH ist Auftragsverarbeiterin i.S.d. Art. 4 Nr. 8 DSGVO. Auftragsverarbeitungsverträge gemäß Art. 28 DSGVO liegen laut Angabe des Mandanten vor, wurden jedoch noch nicht auf KI-VO-Konformität geprüft.

7. Bewertungsstand Aktenstück 02

Dieses Aktenstück fasst die von MedAssist AI GmbH übermittelte technische Dokumentation zusammen. Detailprüfungen der einzelnen Artikel-Anforderungen folgen in Aktenstücken 03–15. Die vorstehende Beschreibung stützt sich auf die technische Dokumentation v4.2.3 sowie die mündlichen Erläuterungen von CTO Krishnamurthy im Gespräch vom 08.03.2026.

Heidelberg, 12.03.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

04-art-9-risikomanagement-pruefung.docx

**Aktenstück 04 — Art. 9 KI-VO: Prüfung Risikomanagementsystem
MedAssist v4**

Aktenzeichen: 2026-V-0427

Erstellt: 18.03.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 9 KI-VO (EU) 2024/1689

1. Anforderungen Art. 9 KI-VO

Art. 9 KI-VO verpflichtet Anbieter von Hochrisiko-KI-Systemen, ein Risikomanagementsystem (RMS) einzurichten, das:

- kontinuierlich über den gesamten Lebenszyklus des Systems betrieben wird (Art. 9 Abs. 1),
- alle Risiken identifiziert und analysiert, die durch das System entstehen können (Art. 9 Abs. 2 lit. a),
- diese Risiken angemessen bewertet (Art. 9 Abs. 2 lit. b),
- geeignete Risikomanagementmaßnahmen ergreift (Art. 9 Abs. 2 lit. c–d),
- nach dem Stand der Technik und bekannten Best Practices ausgestaltet ist (Art. 9 Abs. 4),
- Tests und Prüfungen vor Inverkehrbringen und laufend beinhaltet (Art. 9 Abs. 5 und 7),
- Restrisiken kommuniziert (Art. 9 Abs. 6).

2. Vorgefundene Dokumentation des Mandanten

CTO Krishnamurthy übermittelte am 15.03.2026 folgende Unterlagen:

Dokument	Stand	Bewertung
Risikoanalyse MedAssist v4 (intern, MA-RISK-2024-01)	März 2024	Veraltet, vor MDR-CE-Bewertung erstellt; nicht aktualisiert
FMEA-Dokument NLU-Modul	Oktober 2023	Unvollständig; fehlt Bewertung des Dispositionsmoduls
Testbericht MA-EVAL-2024-03	Dezember 2024	Vorhanden, enthält Accuracy-Daten
Incident-Log 2025	Laufend	23 gemeldete Anomalien, davon 3 als schwerwiegend klassifiziert

3. Befunde

3.1 Fehlende Kontinuität des RMS (Art. 9 Abs. 1)

Das RMS wurde bei Markteinführung von MedAssist v4 (2023) einmalig etabliert, jedoch nicht kontinuierlich fortgeschrieben. Insbesondere:

- Die Risikoanalyse MA-RISK-2024-01 berücksichtigt weder die 23 im Jahr 2025 gemeldeten Anomalien noch die drei als schwerwiegend klassifizierten Vorfälle.

- Nach den drei Incident-Reports aus 2025 (Unterklassifikation von Schlaganfall-Notrufen in zwei Kliniken sowie ein Systemausfall von 47 Minuten in Klinikum Freiburg-Süd) wurde das RMS nicht angepasst.
- Es fehlt ein formelles Verfahren zur Aktualisierung des RMS bei sicherheitsrelevanten Ereignissen.

Rechtliche Einschätzung: Verstoß gegen Art. 9 Abs. 1 KI-VO. Die Pflicht zur kontinuierlichen Pflege des RMS ist eindeutig verletzt.

3.2 Unvollständige Risikoidentifikation (Art. 9 Abs. 2 lit. a)

Die FMEA deckt nur das NLU-Modul ab. Das Dispositionsmodul (XGBoost-basiert) sowie das Audit-Trail-Modul wurden nicht separat analysiert. Insbesondere fehlt:

- Analyse der Bias-Risiken (Geschlecht, Alter, ethnische Herkunft) für beide KI-Module
- Analyse des Risikos durch Konzeptdrift (Trainingsdaten 2008–2022, Deployment 2023–2026)
- Analyse der Kaskadeneffekte: Fehler des NLU-Moduls werden durch das Dispositionsmodul nicht korrigiert, sondern verstärkt

3.3 Fehlende Bewertung nach Schweregrad und Eintrittswahrscheinlichkeit (Art. 9 Abs. 2 lit. b)

MA-RISK-2024-01 enthält keine strukturierte Risikomatrix. Risiken werden qualitativ beschrieben, aber nicht quantitativ bewertet. Eine Priorisierung nach Schadensausmaß × Eintrittswahrscheinlichkeit fehlt vollständig.

3.4 Unvollständige Risikomanagementmaßnahmen (Art. 9 Abs. 2 lit. c)

Die drei schwerwiegenden Vorfälle aus 2025 haben keine dokumentierten Gegenmaßnahmen ausgelöst. RA Dr. Roosendaal hat CTO Krishnamurthy am 18.03.2026 schriftlich darauf hingewiesen, dass dies ein erhebliches Konformitätsdefizit darstellt.

3.5 Stand der Technik (Art. 9 Abs. 4)

Das RMS referenziert nicht den für medizinische KI-Systeme einschlägigen Stand der Technik:

- ISO 14971:2019 (Risikomanagement Medizinprodukte) liegt zwar als MDR-Anforderung vor, wird aber nicht in das KI-VO-spezifische RMS integriert.
- IEC 62304 (Software-Lebenszyklus Medizinprodukte) wird im RMS nicht erwähnt.
- ENISA-Leitlinien zur KI-Sicherheit (2023) werden nicht berücksichtigt.

3.6 Positive Feststellungen

- Testbericht MA-EVAL-2024-03 enthält umfangreiche Leistungsdaten (Accuracy, Latenz), die als Grundlage für ein verbessertes RMS taugen.
- Incident-Log 2025 ist vorhanden und wird laufend geführt; der Logging-Mechanismus als solcher funktioniert.

4. Handlungsempfehlungen

Maßnahme	Priorität	Frist	Verantwortlich
Vollständige Aktualisierung RMS unter Einbeziehung aller Vorfälle 2025	Kritisch	30.04.2026	CTO Krishnamurthy
Erweiterung FMEA auf	Hoch	30.04.2026	CTO Krishnamurthy

Dispositionsmodul und ATM			
Einführung quantitativer Risikomatrix (Schadensausmaß × Eintrittswahrscheinlichkeit)	Hoch	15.05.2026	CTO Krishnamurthy
Integration ISO 14971 in KI-VO-RMS	Hoch	15.05.2026	Dr. Roosendaal (Koordination)
Dokumentierte Gegenmaßnahmen für 3 schwerwiegende Vorfälle 2025	Kritisch	15.04.2026	CTO Krishnamurthy
Formelles RMS-Update-Verfahren einführen (Change Control)	Mittel	30.05.2026	CTO Krishnamurthy

5. Gesamtbewertung Art. 9

Art. 9 KI-VO: Nicht konform.

Schwerwiegende Defizite in Kontinuität, Vollständigkeit und Dokumentation. Kritisches Risiko für Fristwahrung 02.08.2026. Sofortmaßnahmen erforderlich.

Heidelberg, 18.03.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

05-art-10-data-governance-pruefung.docx

Aktenstück 05 — Art. 10 KI-VO: Prüfung Daten-Governance und Trainingsdaten

Aktenzeichen: 2026-V-0427

Erstellt: 22.03.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 10 KI-VO (EU) 2024/1689; DSGVO Art. 9, 22, 35

1. Anforderungen Art. 10 KI-VO

Art. 10 KI-VO normiert für Hochrisiko-KI-Systeme qualitative Mindeststandards für Trainings-, Validierungs- und Prüfdatensätze:

- Geeignete Datenverwaltungspraktiken (Art. 10 Abs. 1)
- Kriterien für Datenselektion, Datenerhebungsmethoden und -verfahren (Art. 10 Abs. 2 lit. a–c)
- Repräsentativitätsprüfung für den Einsatzkontext (Art. 10 Abs. 2 lit. f)
- Prüfung auf Bias und Datendefizite, die zu Grundrechtsverletzungen führen könnten (Art. 10 Abs. 2 lit. g)
- Schutzmaßnahmen bei Verarbeitung besonderer Kategorien personenbezogener Daten (Art. 10 Abs. 5), einschließlich der KI-VO-spezifischen Voraussetzungen für Bias-Prüfungen

2. Prüfung Trainingsdatensätze

2.1 MIMIC-IV Emergency Dataset (PhysioNet)

Herkunft: Massachusetts Institute of Technology / Beth Israel Deaconess Medical Center (Boston, USA). Datenbasis: US-amerikanische Notaufnahmedaten 2008–2019 aus einem einzigen Universitätsklinikum.

Wesentliche Defizite:

Defizit	KI-VO-Anforderung	Bewertung
Keine dokumentierte Eignung für deutschen Rettungsdienstkontext	Art. 10 Abs. 2 lit. f	Nicht erfüllt
Abweichendes Klassifikationsschema (ESI vs. Manchester Triage System)	Art. 10 Abs. 2 lit. c	Nicht erfüllt
US-spezifische Diagnosecodierung (ICD-10-CM ≠ ICD-10-GM)	Art. 10 Abs. 2 lit. c	Nicht erfüllt
Kein EU-Datenschutzregime (PHI nach HIPAA, kein DSGVO-Pendant)	DSGVO Art. 9 Abs. 2	Risiko: fehlende Rechtsgrundlage für Nachnutzung
Keine demografische Repräsentativitätsanalyse für EU-Bevölkerung	Art. 10 Abs. 2 lit. g	Nicht erfüllt

Feststellung: Die Verwendung von MIMIC-IV ohne dokumentierte Validierung für den deutschen Einsatzkontext stellt einen Verstoß gegen Art. 10 Abs. 2 lit. f KI-VO dar.

2.2 NEMSIS 3.5 Dataset (NHTSA, USA)

Herkunft: National Highway Traffic Safety Administration (US Federal Government). Datenbasis: ca. 2,1 Mio. EMS-Datensätze (Emergency Medical Services) aus 48 US-Bundesstaaten, 2019–2022.

Wesentliche Defizite:

Defizit	KI-VO-Anforderung	Bewertung
Rettungsdienst-Strukturen USA ≠ Deutschland (Notarzt-System vs. Paramedic-System)	Art. 10 Abs. 2 lit. f	Nicht erfüllt
Dominanz ruraler US-Gebiete, fehlende Großstadt-Äquivalenz zu deutschen Metropolregionen	Art. 10 Abs. 2 lit. f	Nicht erfüllt
Keine Bias-Analyse (Rasse, Ethnizität als US-Kategorien nicht auf DE-Kontext übertragbar)	Art. 10 Abs. 2 lit. g	Nicht erfüllt
Keine DSGVO-Rechtsgrundlage; PhysioNet-Lizenz keine Grundlage für EU-Deployment	Art. 10 Abs. 1; DSGVO Art. 9	Kritisch

2.3 Klinikinterne Trainingsdaten (BW)

Herkunft: Drei Partnerkliniken in Baden-Württemberg (anonymisiert übermittelt). Ca. 18.000 Einsatzprotokolle, 2021–2023.

Positive Feststellungen:

- Auftragsverarbeitungsvertrag nach Art. 28 DSGVO liegt vor
- Anonymisierungsverfahren ist dokumentiert (Pseudonymisierung + k-Anonymität k=5)
- Daten bilden deutschen Rettungsdienstkontext ab

Verbleibende Defizite:

- Umfang (18.000 Datensätze) im Vergleich zu US-Datensätzen (2,5 Mio.) marginal — starkes Ungleichgewicht führt zur faktischen Dominanz des US-Musters
- Drei Partnerkliniken decken nicht die geographische und demographische Vielfalt der 18 Zielhäuser ab
- Keine Repräsentativitätsanalyse für Bayern (6 der 18 Kliniken liegen in Bayern; Trainingsdaten sind ausschließlich aus BW)

3. Bias-Prüfung (Art. 10 Abs. 2 lit. g)

Art. 10 Abs. 2 lit. g KI-VO verlangt die Überprüfung von Trainings-, Validierungs- und Prüfdatensätze auf mögliche Bias, die zu diskriminierenden Ausgaben führen können, insbesondere in Bezug auf Merkmale nach Art. 14 GRCh (u.a. Geschlecht, Alter, ethnische Herkunft).

Feststellung: Der Mandant hat keine Bias-Prüfung durchgeführt. CTO Krishnamurthy bestätigte im Gespräch vom 18.03.2026, dass entsprechende Analysen „geplant, aber noch nicht umgesetzt“ seien.

Risikobewertung: Medizinische KI-Systeme mit ungeprüften Biases führen nachweislich zu Unterversorgung vulnerabler Gruppen. Für den Notfallkontext ist dokumentiert, dass weibliche Patienten mit Herzinfarkten systematisch unterklassifiziert werden (vgl. wissenschaftliche Literatur: Obermeyer et al., Science 366:447–453, 2019). Ohne Bias-Prüfung besteht erhebliches Haftungsrisiko und Verstoß gegen Art. 10 Abs. 2 lit. g KI-VO.

4. Datenschutzrechtliche Dimension (DSGVO Art. 9, 35)

Die bei der Inferenz verarbeiteten Patientendaten (eingehende Notrufe, Echtzeit-Stationsdaten) sind besondere Kategorien personenbezogener Daten nach Art. 9 Abs. 1 DSGVO (Gesundheitsdaten). Die Verarbeitung ist nur unter den Voraussetzungen des Art. 9 Abs. 2 DSGVO zulässig, insbesondere Art. 9 Abs. 2 lit. h (medizinische Versorgung). Dies ist grundsätzlich erfüllbar, aber in den AVV der 18 Kliniken noch nicht einheitlich abgebildet.

Die BfDI hat mit Schreiben vom 15.02.2026 (Az. 13-3120/004#0117) eine Datenschutz-Folgenabschätzung nach Art. 35 DSGVO verlangt. Die Anforderung ist berechtigt: Art. 35 Abs. 3 lit. a DSGVO verlangt eine DPIA bei systematischer, umfangreicher Verarbeitung besonderer Kategorien. Die DPIA steht aus (s. auch Aktenstück 17).

5. Handlungsempfehlungen

Maßnahme	Priorität	Frist	Verantwortlich
Vollständige Bias-Analyse aller Trainingsdatensätze (Geschlecht, Alter)	Kritisch	30.04.2026	CTO Krishnamurthy
Validierungsstudie US-Datensätze für deutschen Einsatzkontext	Kritisch	15.05.2026	CTO Krishnamurthy
Erweiterung klinikinterne Trainingsdaten auf Bayern-Stichprobe	Hoch	30.06.2026	CTO Krishnamurthy
DPIA erstellen und BfDI vorlegen	Hoch	01.05.2026	Dr. Roosendaal (federführend)
AVV-Überprüfung 18 Kliniken re Art. 9 DSGVO	Mittel	31.05.2026	Dr. Roosendaal
Dokumentation Repräsentativitätsprüfung	Hoch	30.05.2026	CTO Krishnamurthy

6. Gesamtbewertung Art. 10

Art. 10 KI-VO: Nicht konform.

Kritische Defizite bei Repräsentativität der US-Trainingsdaten, fehlende Bias-Analyse, unklare DSGVO-Rechtsgrundlage für US-Daten-Nachnutzung. Höchste Priorität im Handlungsplan.

Heidelberg, 22.03.2026

06-art-11-tech-dokumentation-pruefung.docx

Aktenstück 06 — Art. 11 KI-VO: Technische Dokumentation (Anhang IV)

Aktenzeichen: 2026-V-0427

Erstellt: 25.03.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 11 KI-VO (EU) 2024/1689; Anhang IV KI-VO

1. Anforderungsüberblick

Art. 11 Abs. 1 KI-VO verpflichtet Anbieter von Hochrisiko-KI-Systemen, vor dem Inverkehrbringen eine technische Dokumentation zu erstellen und fortzuführen. Der Mindestinhalt ergibt sich aus Anhang IV KI-VO. Die Dokumentation muss Marktüberwachungsbehörden eine Beurteilung der Konformität ermöglichen.

2. Anhang-IV-Checkliste MedAssist v4

Anforderung Anhang IV	Dokument Mandant	Vollständigkeit	Befund
1. Allgemeine Systembeschreibung	MA-TECH-DOC-2024-v4.2.3, Kap. 1	Teilweise	Einsatzszenario vorhanden; GPAI-Komponente nicht beschrieben
2. Detaillierte Beschreibung der Elemente des Systems	MA-TECH-DOC-2024-v4.2.3, Kap. 2–4	Teilweise	NLU beschrieben; Dispositionsmodul nur rudimentär
3. Überwachung, Funktion und Kontrolle des Systems	Kein separates Dokument	Fehlend	Art. 14-Elemente fehlen gänzlich
4. Beschreibung von Änderungen	Change-Log MA-TECH-2023–2025	Teilweise	Kein Verfahren für sicherheitsrelevante Änderungen
5. Risikomanagementsystem	MA-RISK-2024-01	Unvollständig	S. Aktenstück 04
6. Beschreibung der relevanten Daten (Training, Validierung, Test)	Datensatzbeschreibung MA-DATA-2023	Unvollständig	Kein Repräsentativitätsnachweis (s. Aktenstück 05)
7. Beschreibung der verwendeten Metriken und Schwellenwerte	MA-EVAL-2024-03, Anhang B	Vorhanden	Metriken sind dokumentiert
8. Beschreibung der menschlichen Aufsicht	Benutzerhandbuch v4.1 (Abschn. 7)	Unvollständig	Aufsichtsmechanismus konzeptionell, nicht implementiert
9. Beschreibung der Validierungsmaßnahmen	MA-EVAL-2024-03	Teilweise	Fehlende klinische Validierungsstudie
10. Logbuch/Aufzeichnungen	ATM-Spezifikation v2	Teilweise	Datenhaltungskonzept lückenhaft (s. Aktenstück 07)
11. Informationen für Nutzer	Benutzerhandbuch v4.1	Teilweise	Fehlende Erklärbarkeits-Informationen

Gesamtergebnis: Von 11 Anhang-IV-Kategorien: 1 vollständig erfüllt, 6 teilweise erfüllt, 4 fehlend oder unvollständig.

3. Kritische Lücken

3.1 GPAI-Basiskomponente nicht dokumentiert (Anhang IV Nr. 1, 2)

Die technische Dokumentation beschreibt MedAssist-LLM-Core v4 als eigenentwickeltes Modul, ohne die Llama-3.1-Basisarchitektur und den Fine-Tuning-Prozess offenzulegen. Dies ist aus rechtlicher Sicht unzureichend:

- Art. 11 Abs. 3 KI-VO: Sofern ein KI-System auf einem GPAI-Modell basiert, umfasst die technische Dokumentation auch die nach Art. 53 Abs. 1 KI-VO erforderlichen Informationen.
- Die Llama-Adaptation ist ein GPAI-Modell i.S.d. Art. 3 Nr. 63 KI-VO (s. Aktenstück 19); entsprechend müssen Modellarchitektur, Trainingsparameter, Systemcard und Evaluierungsergebnisse in die Dokumentation einbezogen werden.

3.2 Fehlende klinische Validierungsstudie (Anhang IV Nr. 9)

Eine prospektive oder retrospektive klinische Validierungsstudie in deutschen Krankenhäusern ist nicht vorgelegt worden. MA-EVAL-2024-03 enthält nur interne Testläufe. Für ein Medizinprodukt Klasse IIb mit KI-Komponente ist eine klinische Evaluierung nach Art. 61 MDR i.V.m. Anhang XIV MDR erforderlich; diese muss mit der Anforderung des Art. 9 Abs. 7 KI-VO (Testing unter realen Bedingungen) koordiniert werden.

3.3 Fehlende Erklärbarkeit und Interpretierbarkeit (Anhang IV Nr. 11)

Das Benutzerhandbuch v4.1 enthält keine Informationen darüber, wie das System zu seinen Klassifikations-Empfehlungen gelangt. Disponenten können die Systemempfehlung nicht auf ihre Plausibilität hin überprüfen, da keine Erklärbarkeits-Ausgabe vorhanden ist (kein Confidence-Breakdown, keine SHAP-Werte oder äquivalente Methode). Dies verstärkt das Art. 14-Defizit (s. Aktenstück 09).

4. Handlungsempfehlungen

Maßnahme	Priorität	Frist
Vollständige Neufassung technische Dokumentation (Anhang-IV-konform)	Kritisch	31.05.2026
Integration GPAI-Dokumentation Llama-Adaptation	Hoch	30.04.2026
Klinische Validierungsstudie beauftragen	Hoch	Start 01.04.2026
Erklärbarkeits-Modul für Benutzeroberfläche entwickeln	Hoch	30.06.2026
Change-Control-Verfahren für technische Dokumentation einführen	Mittel	30.05.2026

5. Gesamtbewertung Art. 11
Art. 11 KI-VO: Nicht konform.

Die technische Dokumentation ist strukturell unvollständig und deckt zentrale Anhang-IV-Anforderungen nicht ab. Bis zur Frist 02.08.2026 muss eine vollständige, Anhang-IV-konforme Dokumentation vorliegen.

Heidelberg, 25.03.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

07-art-12-aufzeichnungspflichten.docx

Aktenstück 07 — Art. 12 KI-VO: Aufzeichnungspflichten und Logging

Aktenzeichen: 2026-V-0427

Erstellt: 28.03.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 12 KI-VO (EU) 2024/1689

1. Anforderungen Art. 12 KI-VO

Art. 12 Abs. 1 KI-VO verlangt, dass Hochrisiko-KI-Systeme technische Möglichkeiten zur automatischen Aufzeichnung von Ereignissen (Logs) während des Betriebs bieten. Art. 12 Abs. 2 KI-VO konkretisiert: die Aufzeichnungsfähigkeit soll mindestens die Überwachung des Systembetriebs hinsichtlich Ereignissen ermöglichen, die Risiken darstellen oder zu wesentlichen Veränderungen führen. Art. 12 Abs. 3 KI-VO legt für Hochrisiko-KI unter Anhang III besondere Aufzeichnungsanforderungen fest:

- Zeitraum jeder Verwendung (Start/Ende)
- Referenzdatenbank, anhand derer Eingabedaten abgeglichen wurden
- Datum, Zeitpunkt, Ergebnis (inkl. Konfidenzwert) jedes Output
- Identität der natürlichen Person, die das System überwacht hat

2. Bestandsaufnahme Audit-Trail-Modul (ATM) MedAssist v4

Das Audit-Trail-Modul ist die Logging-Komponente von MedAssist v4 (s. Aktenstück 02, Abschn. 2.3). Technische Spezifikation: ATM-Spezifikation v2, Stand Oktober 2024.

2.1 Was wird aufgezeichnet

Ereignis	Aufgezeichnet	Format	Bewertung
Zeitpunkt Notruf-Eingang	Ja	ISO 8601	Konform
Transkriptionsstart/-ende	Ja	ISO 8601	Konform
NLU-Klassifikation (Dringlichkeit, Kategorie)	Ja	JSON	Konform
Konfidenzwert NLU-Ausgabe	Ja	Float 0–1	Konform
DEM-Empfehlung (Top-1 und Alternativen)	Teilweise	JSON (nur Top-1)	Nicht vollständig
Identität des Disponenten (Override-Aktion)	Nur in 4 von 18 Kliniken	—	Nicht konform
Zeitpunkt Disponent-Aktion	Nur in 4 von 18 Kliniken	—	Nicht konform
Systemausfälle / Anomalien	Ja	Syslog	Konform
Modellversion (NLU, DEM)	Nein	—	Fehlt

2.2 Datenhaltungsdauer

ATM-Spezifikation v2 sieht eine Datenhaltung von 5 Jahren vor. Art. 12 KI-VO legt keine exakte Mindestfrist fest, verweist aber auf zweckadäquate Aufbewahrung. Für medizinische Kontexte ist eine Mindesthaltung von 10 Jahren nach § 630f BGB (Dokumentationspflicht Behandlungsunterlagen) bzw. §§ 28, 36 Berufsordnungen zu erwägen. Die Diskrepanz zwischen 5-Jahre-Logging-Frist (KI-VO) und 10-Jahre-Dokumentationspflicht (Medizinrecht) ist zu koordinieren.

2.3 Zugriff und Export

Eine Export-API für Behördenanfragen ist vorhanden (REST, JSON-Format). Im BNetzA-Marktüberwachungsverfahren (Az. 1-101.05-2026/MA-008) wurde am 01.03.2026 ein erstes Auskunftersuchen gestellt. MedAssist AI GmbH hat am 15.03.2026 Teile der Logs exportiert und übermittelt. Der BNetzA-Inspektor hat mit Schreiben vom 22.03.2026 moniert, dass die Disponenten-Identitätsdaten in den Logs fehlten.

3. Kritische Befunde

3.1 Fehlende Disponenten-Identität (Art. 12 Abs. 3 lit. d)

In 14 der 18 Kliniken wird die Identität des Disponenten, der das System überwacht oder eine Entscheidung getroffen hat, nicht protokolliert. Dies ist ein direkter Verstoß gegen Art. 12 Abs. 3 lit. d KI-VO. Gleichzeitig ist dies eng verbunden mit dem Art. 14-Defizit: Wenn nicht einmal protokolliert wird, wer die Überwachung ausgeübt hat, ist eine retrospektive Beurteilung der menschlichen Aufsicht unmöglich.

3.2 Fehlende Modellversion im Log (Art. 12 Abs. 2)

Die Protokollierung der Modellversion ist für Nachvollziehbarkeit bei Audit-Anfragen der BNetzA unerlässlich. Ohne Versions-Logging kann nicht festgestellt werden, welche Modellversion zum Zeitpunkt eines Vorfalls aktiv war. Dies ist bei den drei schwerwiegenden Vorfällen aus 2025 bereits problematisch geworden.

3.3 Inkomplette DEM-Top-3-Aufzeichnung

Das Dispositionsmodul protokolliert nur die Top-1-Empfehlung, nicht die Alternativen (Top-2, Top-3). Für die Überprüfung, ob dem Disponenten relevante Alternativen präsentiert wurden, sind aber auch die nicht gewählten Optionen relevant.

4. Handlungsempfehlungen

Maßnahme	Priorität	Frist
Roll-out Disponenten-ID-Logging auf alle 18 Kliniken	Kritisch	30.04.2026
Ergänzung Modellversionierung in ATM	Kritisch	30.04.2026
Erweiterung DEM-Logging auf Top-3-Empfehlungen	Mittel	31.05.2026
Abstimmung Datenhaltungsdauer mit medizinrechtlichen Anforderungen	Hoch	15.05.2026
Aktualisierung ATM-Spezifikation v3	Hoch	31.05.2026

5. Gesamtbewertung Art. 12

Art. 12 KI-VO: Teilweise konform (mit kritischen Lücken).

Die Logging-Grundinfrastruktur ist vorhanden. Die Nichtprotokollierung der Disponenten-Identität in 14 Kliniken und die fehlende Modellversionierung sind kritische Verstöße, die für das BNetzA-Marktüberwachungsverfahren unmittelbaren Klärungsbedarf auslösen.

Heidelberg, 28.03.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

08-art-13-transparenz-anbieter.docx

Aktenstück 08 — Art. 13 KI-VO: Transparenz und Informationspflichten des Anbieters

Aktenzeichen: 2026-V-0427

Erstellt: 01.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 13 KI-VO (EU) 2024/1689

1. Anforderungen Art. 13 KI-VO

Art. 13 KI-VO verlangt, dass Hochrisiko-KI-Systeme so konzipiert und entwickelt werden, dass ihr Betrieb hinreichend transparent ist, um Betreibern zu ermöglichen, die Ausgaben des Systems zu verstehen und sachgerecht zu nutzen. Anbieter haben zudem Betreiber-Anleitungen beizufügen (Art. 13 Abs. 3), die mindestens enthalten:

- Identität und Kontaktdaten des Anbieters (Art. 13 Abs. 3 lit. a)
- Bestimmungsgemäße Zwecke, Leistungsmerkmale und Einsatzbeschränkungen (Art. 13 Abs. 3 lit. b)
- Genauigkeitsgrad, Robustheit und Cybersicherheitsgrenzen (Art. 13 Abs. 3 lit. c)
- Anforderungen an Inputdaten (Art. 13 Abs. 3 lit. d)
- Inbetriebnahme-, Betriebs- und Wartungsanweisungen (Art. 13 Abs. 3 lit. e)
- Informationen zur menschlichen Aufsicht (Art. 13 Abs. 3 lit. f)
- Maßnahmen bei Ausfällen (Art. 13 Abs. 3 lit. g)
- Rechte der Nutzer/betroffenen Personen (Art. 13 Abs. 3 lit. h)

2. Prüfung Benutzerhandbuch MedAssist v4.1

Das Benutzerhandbuch v4.1 (Stand August 2024, 68 Seiten) wurde von MedAssist AI GmbH am 08.03.2026 übermittelt. Es liegt nur auf Deutsch vor.

2.1 Checkliste Transparenzanforderungen

Anforderung Art. 13 Abs. 3	Vorhanden	Vollständig	Anmerkung
lit. a — Identität Anbieter	Ja	Ja	S. 2 des Handbuchs
lit. b — Bestimmungszweck, Leistungsmerkmale	Teilweise	Nein	Einsatzbeschränkungen fehlen
lit. c — Genauigkeitsgrad, Robustheit	Nein	—	Keinerlei Angaben zu Accuracy-Limits
lit. d — Inputdaten-Anforderungen	Teilweise	Nein	Nur Audioformat beschrieben; Sprachabdeckung unklar
lit. e — Inbetriebnahme, Betrieb, Wartung	Ja	Teilweise	Wartungsfenster nicht dokumentiert

lit. f — Menschliche Aufsicht	Teilweise	Nein	Override-Verfahren beschrieben, aber nicht verpflichtend formuliert
lit. g — Maßnahmen bei Ausfällen	Nein	—	Fallback-Verfahren nicht beschrieben
lit. h — Rechte betroffener Personen	Nein	—	Keine Information zu DSGVO-Rechten von Patienten

2.2 Kritische Lücken

Fehlende Einsatzbeschränkungen (lit. b): Das Handbuch beschreibt MedAssist v4 als „entscheidungsunterstützendes“ System, enthält aber keine ausdrückliche Aussage dazu, für welche Szenarien das System ausdrücklich nicht eingesetzt werden darf (z.B. Auslandsnotrufe, fremdsprachige Anrufer, technische Grenzfälle). Die Klärung von Einsatzgrenzen ist insbesondere angesichts der False-Negative-Rate von 8,8 % bei Dringlichkeit 1 dringend geboten.

Keine Genauigkeitsangaben für Betreiber (lit. c): Disponenten und Klinikverwaltungen haben keinen Zugang zu den im internen Testbericht MA-EVAL-2024-03 enthaltenen Accuracy-Daten. Sie können die Systemempfehlung damit nicht in ihren Unsicherheitskontext einordnen. Dies verletzt Art. 13 Abs. 1 KI-VO (Transparenz-Grundpflicht) und untergräbt die menschliche Aufsicht nach Art. 14 KI-VO erheblich.

Kein Fallback-Verfahren (lit. g): Bei einem Systemausfall — wie im Fall des 47-minütigen Ausfalls im Klinikum Freiburg-Süd (2025) — fehlt ein dokumentiertes Rückfall-Verfahren auf manuelle Disposition. Das Klinikum Freiburg-Süd hat im Nachgang berichtet, dass das Personal in diesem Zeitraum improvisieren musste, da kein analoges Backup-Protokoll existierte.

Patientenrechte (lit. h): Art. 22 DSGVO gewährt Patienten das Recht, nicht einer ausschließlich automatisierten Entscheidung unterworfen zu sein. Im Kontext von MedAssist v4 ist fraglich, ob die de-facto-Dispositionsentscheidung als „ausschließlich automatisiert“ i.S.d. Art. 22 Abs. 1 DSGVO gilt — angesichts fehlender Override-Protokolle in 14 Kliniken ist dies nicht auszuschließen. Das Benutzerhandbuch enthält hierzu keinerlei Hinweise.

3. Anforderungen an Betreiber-Transparenz (Art. 13 Abs. 1)

Art. 13 Abs. 1 KI-VO verlangt darüber hinaus, dass das System selbst so konstruiert ist, dass es transparent operiert. In der Praxis bedeutet dies: Das System muss Ausgaben mit ausreichender Information versehen (z.B. Konfidenzwerte, Erklärungshinweise), damit Betreiber die Ausgabe sachgerecht beurteilen können.

MedAssist v4 gibt den Konfidenzwert aus, zeigt aber keine Erklärung für die Klassifikation (z.B. „Einordnung als Dringlichkeit 2 aufgrund: erkannte Schlüsselworte [Brustschmerz], Herzerkrankung in Vorgeschichte erkannt, Alter > 60“). Ohne eine solche Erklärung ist die menschliche Beurteilungskapazität des Disponenten erheblich eingeschränkt.

4. Handlungsempfehlungen

Maßnahme	Priorität	Frist
Überarbeitung Benutzerhandbuch (v4.2) — Ergänzung alle lit. a–h	Kritisch	31.05.2026
Aufnahme Accuracy-Daten und	Hoch	31.05.2026

Grenzen in Benutzerhandbuch		
Entwicklung Fallback-Protokoll Manualmode + Schulung	Hoch	30.04.2026
Erklärbarkeits-Output in Dashboard implementieren	Hoch	30.06.2026
DSGVO-Betroffenenrechte- Hinweis in Patientenaufklärung klinikkumseitig	Mittel	30.06.2026

5. Gesamtbewertung Art. 13

Art. 13 KI-VO: Teilweise konform (mit wesentlichen Lücken).

Grundinfrastruktur eines Benutzerhandbuchs existiert. Kritische Lücken bei Einsatzgrenzen, Accuracy-Kommunikation, Fallback und Patientenrechten.

Heidelberg, 01.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

09-art-14-menschliche-aufsicht.docx

Aktenstück 09 — Art. 14 KI-VO: Menschliche Aufsicht — Kernbefund

Aktenzeichen: 2026-V-0427

Erstellt: 04.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 14 KI-VO (EU) 2024/1689

1. Rechtlicher Rahmen Art. 14 KI-VO

Art. 14 KI-VO ist das zentrale Schutzinstrument der Hochrisiko-KI-Regulierung. Es verpflichtet Anbieter, Hochrisiko-KI-Systeme so zu gestalten, dass sie während des Betriebs wirksam von natürlichen Personen überwacht werden können. Die Anforderungen im Einzelnen:

- Das System muss so konzipiert sein, dass Betreiber es überwachen können (Art. 14 Abs. 1)
- Es müssen Werkzeuge zur Überwachung bereitgestellt werden (Art. 14 Abs. 2)
- Das System muss identifizierbar als KI-System sein (Art. 14 Abs. 2 lit. a)
- Es müssen Mechanismen vorhanden sein, damit Betreiber eingreifen, übersteuern oder das System stoppen können (Art. 14 Abs. 4 lit. e)
- Für Systeme nach Anhang III mit besonders erhöhtem Risiko: vollständige Überprüfung vor jeder Output-Umsetzung, sofern technisch zumutbar (Art. 14 Abs. 5)

2. Der Kernbefund: Strukturelle Aufsichtslücke

Dies ist der gravierendste Einzelbefund der gesamten Konformitätsprüfung.

Sachverhalt: In 14 der 18 Krankenhäuser, in denen MedAssist v4 im Einsatz ist, gibt es keinen technisch erzwungenen Quittierungsschritt vor der Umsetzung der Systemempfehlung. Das Leitstellen-Dashboard zeigt die Empfehlung an (Dringlichkeitsstufe, Kategorie, Ressourcenzuweisung), jedoch übernehmen Disponenten die Empfehlung in der Praxis durch bloße Weiterleitung an die jeweilige Station — ohne expliziten Bestätigungsklick im System und ohne protokollierte Überprüfung.

In den verbleibenden 4 Kliniken (Universitätsklinikum Freiburg, Klinikum Stuttgart, Klinikum Nürnberg-Nord, Kreisklinik Ravensburg) wurde ein Bestätigungsmechanismus als Pilotfunktion (Beta) implementiert. Dort ist ein ausdrücklicher „Bestätigen“-Button erforderlich, bevor die Ressourcenzuweisung aktiviert wird.

Rechtliche Einschätzung: Die Situation in den 14 Kliniken verstößt gegen Art. 14 Abs. 4 lit. e KI-VO. Der Anbieter (MedAssist AI GmbH) ist verpflichtet, technische Maßnahmen bereitzustellen, die wirksame menschliche Aufsicht ermöglichen. Die bloße konzeptionelle Vorstellung, dass Disponenten überwachen, ohne dass dies technisch erzwungen oder protokolliert wird, erfüllt die Anforderung nicht.

3. Risikobeurteilung

3.1 Automatisierungsverzerrung (Automation Bias)

Psychologische Forschung und medizinische Studien belegen, dass in Hochstress-Umgebungen (Notfalldisposition) Automation Bias besonders stark ausgeprägt ist: Operatoren übernehmen Systemempfehlungen unkritisch, wenn keine explizite Überprüfungsaufforderung besteht (vgl. Parasuraman & Manzey, Ergonomics 53:1354–1366, 2010). Bei MedAssist v4 bedeutet dies:

- Die 8,8 % False-Negative-Rate bei Dringlichkeit 1 wird in der Praxis nicht durch menschliche Korrekturen aufgefangen
- Der konzeptionelle Override wird zur Fiktion

3.2 Haftungsrechtliche Konsequenz

Die fehlende menschliche Aufsicht hat unmittelbare haftungsrechtliche Konsequenzen für die Kliniken als Betreiber. Eine Unterklassifikation (Dringlichkeit 1 → Dringlichkeit 2) mit Patientenschaden würde produkthaftungsrechtliche Ansprüche gegen MedAssist AI GmbH (Anbieter) begründen. Für die Produkthaftung nach dem Produkthaftungsgesetz (ProdHaftG) i.d.F. der Umsetzung der Richtlinie (EU) 2024/2853 ist das Vorliegen eines Produktfehlers (fehlende Sicherheit) zu bejahen, wenn das System ohne ausreichende Aufsichtsmechanismen in Verkehr gebracht wurde. Vgl. allgemein zur Produkthaftungsdogmatik bei KI-Systemen: Spickhoff, MedR 2023, 1 ff.; Detterbeck, VersR 2022, 1445 ff.

3.3 Verhältnis zu MDR

Nach MDR Anhang I Nr. 14.5 müssen Medizinprodukte der Klasse IIb sicherstellen, dass der Anwender Fehlalarme und Fehlfunktionen erkennen kann. Die fehlende Overriding-Möglichkeit ist auch aus MDR-Perspektive problematisch — was erklärt, warum das BfArM im Bescheid MED-AI-2026-0319 explizit auf das ausstehende KI-VO-Konformitätserfordernis hinwies.

4. Schulungsdefizit

Art. 14 Abs. 3 KI-VO verlangt, dass Betreiber Maßnahmen ergreifen, die sicherstellen, dass das Personal, das das System überwacht, ausreichend kompetent ist. MedAssist AI GmbH hat bislang keine standardisierte Schulung für Disponenten entwickelt. Die vorhandene Einweisungsunterlage (2 Seiten A4) ist nicht geeignet, das erforderliche Kompetenzniveau sicherzustellen:

- Keine Schulung zur Erkennung von Klassifikationsfehlern
- Keine Schulung zu Systemgrenzen (Accuracy-Limits, Bias-Risiken)
- Keine Übungen zum Override-Verfahren

5. Sofortmaßnahme und Chronologie

Am 04.04.2026 hat RAin Dr. Vellbruck-Steinheim CEO Dr. Vogelkamp und CTO Krishnamurthy in einem Videogespräch auf die Dringlichkeit dieses Befundes hingewiesen. CTO Krishnamurthy hat zugesagt, den Pflicht-Quittierungsschritt (Bestätigen-Button) auf alle 18 Kliniken bis 30.04.2026 auszurollen.

Wichtig: Der Roll-out des Quittierungsschritts allein reicht nicht aus. Zusätzlich erforderlich:

Maßnahme	Frist
----------	-------

Roll-out Pflicht-Quittierungsschritt auf alle 18 Kliniken	30.04.2026
Standardisierte Disponenten-Schulung (Curriculum, 4h)	31.05.2026
Protokollierung aller Override-Aktionen inkl. Disponenten-ID	30.04.2026
Dashboard-Ergänzung: Konfidenzwert prominent + Erklärungshinweis	30.06.2026
Jährliche Schulungswiederholung einführen	Ab 01.08.2026

6. Gesamtbewertung Art. 14

Art. 14 KI-VO: NICHT konform. Gravierendstes Defizit der Prüfung.

In 14 von 18 Kliniken fehlt die technisch erzwungene menschliche Aufsicht vollständig. Sofortmaßnahmen wurden eingeleitet. Vollständige Konformität erfordert technische Umsetzung, Schulung und Protokollierung bis 30.06.2026 (Puffer vor Frist 02.08.2026).

Heidelberg, 04.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

10-art-15-genauigkeit-robustheit-cybersicherheit.docx

Aktenstück 10 — Art. 15 KI-VO: Genauigkeit, Robustheit und Cybersicherheit

Aktenzeichen: 2026-V-0427

Erstellt: 08.04.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 15 KI-VO (EU) 2024/1689; ISO/IEC 27001:2022

1. Anforderungen Art. 15 KI-VO

Art. 15 KI-VO verlangt, dass Hochrisiko-KI-Systeme angemessene Genauigkeits-, Robustheits- und Cybersicherheitsniveaus erreichen und während des gesamten Lebenszyklus aufrechterhalten. Im Einzelnen:

- Genauigkeit (Art. 15 Abs. 1):** Angemessene Genauigkeitsniveaus unter Berücksichtigung des Einsatzbereichs; Angabe im Anhang IV und in der Betreiberanleitung
- Robustheit (Art. 15 Abs. 3):** Widerstandsfähigkeit gegen Fehler, Ausfälle, Inkonsistenzen; Resilienz gegen Manipulation
- Cybersicherheit (Art. 15 Abs. 4–5):** Schutz vor Angriffen, die zu unerwünschten Systemverhalten führen; Anforderungen entsprechend NIS-2-Richtlinie und einschlägiger Normen

2. Genauigkeit

2.1 Ist-Stand (aus MA-EVAL-2024-03)

Metrik	Wert	Benchmark	Einschätzung
Overall Accuracy Dringlichkeit	84,3 %	> 95 % (klinischer Standard)	Unzureichend
Recall Dringlichkeitsstufe 1 (lebensbedrohlich)	91,2 %	> 98 % (Sicherheitsgrenzwert)	Unzureichend
False-Negative-Rate Dringlichkeit 1	8,8 %	< 2 %	Kritisch
Accuracy psychiatrische Notfälle	62,1 %	> 80 %	Kritisch
Accuracy pädiatrische Notfälle	71,4 %	> 85 %	Nicht ausreichend
Accuracy Traumata	88,2 %	> 90 %	Grenzwertig

2.2 Fehlende Genauigkeitsangaben im Benutzerhandbuch

Die Accuracy-Daten aus MA-EVAL-2024-03 sind nicht im Benutzerhandbuch und nicht in der Technischen Dokumentation ausgewiesen. Disponenten haben damit keinen Zugang zu den tatsächlichen Leistungsgrenzen des Systems — was die Transparenz-Anforderungen nach Art. 13 und die Aufsichtsanforderungen nach Art. 14 zusätzlich verletzt.

2.3 Konzeptdrift

Das Dispositionsmodul (XGBoost) wurde auf Daten 2020–2023 trainiert. Ein Monitoring auf Konzeptdrift (Performance-Verschlechterung durch veränderte Datenverteilung im Produktionseinsatz 2023–2026) findet nicht statt. Die Accuracy-Daten aus 2024 könnten den tatsächlichen Produktionsstand bereits überoptimistisch darstellen.

3. Robustheit

3.1 Technische Robustheit

Szenario	Getestet	Befund
Hintergrundlärm (Notfallambiente)	Ja	Performance-Abfall bei > 70 dB Hintergrundlärm auf 74,2 % Accuracy
Fremdsprachige Anrufer	Nein	Ungetestet — erhebliches Risiko
Starker Dialekt (bayer., schwäb.)	Teilweise	Leichter Performance-Abfall (–3,1 %)
Systemüberlastung (> 50 parallele Notrufe)	Ja	Latenzüberschreitung 95. Pz. 1.240 ms
Modell-Adversarial Inputs	Nein	Kein Adversarial Testing dokumentiert
Netzwerkausfall (Teilausfall)	Ja	Graceful Degradation implementiert

3.2 Fallback bei Systemausfall

Wie in Aktenstück 08 festgestellt, fehlt ein dokumentiertes Fallback-Verfahren. Der 47-minütige Ausfall im Klinikum Freiburg-Süd (2025) demonstriert das reale Ausfallrisiko.

4. Cybersicherheit

4.1 ISO/IEC 27001:2022 Zertifizierung

MedAssist AI GmbH ist seit 2022 nach ISO/IEC 27001:2022 zertifiziert (Zertifikat TÜV Rheinland, ausgestellt 14.06.2022, gültig bis 13.06.2025). **Das Zertifikat ist am 13.06.2025 abgelaufen und wurde bislang nicht erneuert.** CTO Krishnamurthy hat bestätigt, dass die Rezertifizierung verschoben wurde.

Rechtliche Einschätzung: Ein abgelaufenes ISO 27001-Zertifikat stellt keine ausreichende Grundlage für den Nachweis der Cybersicherheitsanforderungen nach Art. 15 Abs. 4 KI-VO dar. Die Rezertifizierung ist vordringlich.

4.2 KI-spezifische Angriffsvektoren

Art. 15 Abs. 5 KI-VO adressiert ausdrücklich KI-spezifische Angriffe (Adversarial Attacks, Datenvergiftung, Modell-Evasion). Für MedAssist v4 ist kein Penetrationstest mit KI-spezifischen Angriffsvektoren dokumentiert. Insbesondere:

- **Adversarial Inputs auf NLU:** Manipulierte Sprachsequenzen, die das NLU-Modell zur Falschklassifikation verleiten (z.B. Echtzeit-Audio-Manipulation), sind ungetestet
- **Datenvergiftung:** Da Kliniken prinzipiell lokale Instanzen betreiben, ist eine dezentrale Angriffsfläche vorhanden, die im Sicherheitskonzept nicht adressiert wird

4.3 NIS-2-Bezug

Krankenhäuser ab einer bestimmten Größe sind als „wichtige Einrichtungen“ i.S.d. NIS-2-Umsetzungsgesetzes (NIS2UmsuCG) klassifiziert. MedAssist AI GmbH als KRITIS-naher Softwareanbieter muss prüfen, ob eigene NIS-2-Pflichten bestehen (als wesentlicher Lieferant). Diese Prüfung steht aus.

5. Handlungsempfehlungen

Maßnahme	Priorität	Frist
Rezertifizierung ISO/IEC 27001:2022	Kritisch	31.05.2026
Adversarial Testing NLU-Modul	Hoch	30.06.2026
Implementierung Konzeptdrift-Monitoring	Hoch	30.06.2026
Test fremdsprachige Anrufer / Dialekte	Mittel	30.06.2026
NIS-2-Eigenprüfung als Lieferant	Mittel	31.05.2026
Dokumentation Accuracy-Daten in Benutzerhandbuch	Hoch	31.05.2026

6. Gesamtbewertung Art. 15

Art. 15 KI-VO: Nicht konform.

Unzureichende Genauigkeit für kritischen Einsatzbereich, abgelaufene Cybersicherheitszertifizierung, fehlendes Adversarial Testing.

Heidelberg, 08.04.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

11-art-16-pflichten-anbieter.docx

Aktenstück 11 — Art. 16 KI-VO: Pflichten des Anbieters — Gesamtübersicht

Aktenzeichen: 2026-V-0427

Erstellt: 12.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 16 KI-VO (EU) 2024/1689

1. Systematik Art. 16 KI-VO

Art. 16 KI-VO listet die Pflichten von Anbietern von Hochrisiko-KI-Systemen in einer nicht abschließenden Gesamtschau:

Pflicht	Artikel	Status MedAssist
Konformitätsbewertungsverfahren	Art. 16 lit. a, Art. 43	Nicht abgeschlossen
EU-Konformitätserklärung ausstellen	Art. 16 lit. b, Art. 47	Entwurf vorhanden (s. Aktenstück 13)
CE-Kennzeichnung anbringen	Art. 16 lit. c, Art. 48	MDR-CE vorhanden; KI-VO-CE fehlt
Registrierung in EU-Datenbank	Art. 16 lit. d, Art. 49	Nicht registriert
Technische Dokumentation erstellen	Art. 16 lit. e, Art. 11	Unvollständig (s. Aktenstück 06)
Aufzeichnungspflichten	Art. 16 lit. f, Art. 12	Teilweise erfüllt (s. Aktenstück 07)
QM-System einrichten	Art. 16 lit. g, Art. 17	Nicht vorhanden
Post-Market-Monitoring	Art. 16 lit. h, Art. 72	Rudimentär
Meldepflichten bei schwerwiegenden Vorfällen	Art. 16 lit. i, Art. 73	Nicht eingehalten

2. Qualitätsmanagementsystem (Art. 17 KI-VO)

Art. 17 KI-VO verpflichtet Anbieter, ein Qualitätsmanagementsystem (QMS) einzurichten, das mindestens umfasst:

- Strategien und Verfahren für die Sicherstellung der Konformität
- Verfahren zur Überwachung, Überprüfung und Validierung
- Verfahren zur Meldung schwerwiegender Vorfälle
- Verfahren für Post-Market-Monitoring

Befund: Ein formelles QMS nach Art. 17 KI-VO existiert bei MedAssist AI GmbH nicht. Das vorhandene ISO 9001-Qualitätsmanagement (zertifiziert 2021) deckt Softwareentwicklungsprozesse ab, ist aber nicht auf die spezifischen KI-VO-Anforderungen ausgerichtet.

3. Post-Market-Monitoring (Art. 72 KI-VO)

Art. 72 KI-VO verlangt, dass Anbieter ein System zur proaktiven Erhebung und Auswertung von Daten über die Systemleistung im Echtbetrieb einrichten. Dies muss bei Hochrisiko-Systemen nach Anhang III Teil eines systematischen Plans sein.

Befund: Der vorhandene Incident-Log (s. Aktenstück 07) ist ein reaktives Instrument. Ein proaktives Post-Market-Monitoring-System — das kontinuierlich Leistungsdaten aus den 18 Kliniken sammelt, auswertet und Anomalien signalisiert — fehlt.

4. Meldepflichten schwerwiegende Vorfälle (Art. 73 KI-VO)

Art. 73 KI-VO verpflichtet Anbieter, schwerwiegende Vorfälle (Vorfälle oder Fehlfunktionen, die zu Tod, schwerer Körperverletzung oder anderen in Art. 3 Nr. 49 KI-VO definierten Schäden führen) unverzüglich der zuständigen Marktüberwachungsbehörde zu melden.

Befund: Die drei als schwerwiegend klassifizierten Incidents aus 2025 wurden der BNetzA nicht gemeldet. MedAssist AI GmbH begründete dies damit, dass es keinen bestätigten Patientenschaden gegeben habe. Dies verkennt den Meldezeitpunkt: Art. 73 KI-VO löst die Meldepflicht nicht erst bei eingetretenem Schaden aus, sondern bei schwerwiegenden Fehlfunktionen, die zu solchen Schäden führen können. Die zwei Unterklassifikations-Incidents (Schlaganfall, Freiburg-Süd; Herzinfarkt, Klinikum Mannheim-Süd) und der 47-minütige Systemausfall hätten gemeldet werden müssen.

Empfehlung: Nachträgliche Selbstmeldung bei BNetzA (proaktive Compliance-Geste) bis 30.04.2026; Kooperation mit BNetzA im laufenden Marktüberwachungsverfahren (Az. 1-101.05-2026/MA-008).

5. Besondere Pflichten nach Art. 25 KI-VO (Pflichten von Betreibern)

Die 18 Kliniken als Betreiber haben eigenständige Pflichten nach Art. 25 KI-VO. Dazu gehören u.a. die Sicherstellung der menschlichen Aufsicht, die Schulung des Personals und die Meldung von Vorfällen. Obwohl dies primär Klinik-Pflichten sind, hat MedAssist AI GmbH als Anbieter die vertragliche Pflicht sicherzustellen, dass die Betreiber ihre Pflichten erfüllen können (Art. 16 lit. f KI-VO i.V.m. Art. 25 KI-VO). Dies setzt voraus, dass die Betreiberverträge entsprechende Klauseln enthalten.

Befund: Die Betreiberverträge wurden noch nicht auf Art. 25 KI-VO-Konformität überprüft. Nachbesserungsbedarf ist wahrscheinlich.

6. Gesamtbewertung Art. 16

Art. 16 KI-VO: Erhebliche Defizite in nahezu allen Teilbereichen.

Insbesondere: kein QMS nach Art. 17, kein Post-Market-Monitoring, versäumte Meldepflichten. Konformitätsbewertung, EU-Erklärung, CE-Kennzeichnung und Registrierung stehen aus. Kritische Priorisierung im Handlungsplan.

Heidelberg, 12.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

12-art-43-konformitaetsbewertung.docx

Aktenstück 12 — Art. 43 KI-VO: Konformitätsbewertungsverfahren

Aktenzeichen: 2026-V-0427

Erstellt: 15.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 43 KI-VO (EU) 2024/1689; Anhang VI KI-VO; MDR (EU) 2017/745 Art. 52
–54

1. Systematik des Konformitätsbewertungsverfahrens

Art. 43 KI-VO sieht für Hochrisiko-KI-Systeme nach Anhang III grundsätzlich zwei Verfahrenswege vor:

Weg A — Interne Konformitätsbewertung (Art. 43 Abs. 1 i.V.m. Anhang VI):

Der Anbieter führt selbst das Konformitätsbewertungsverfahren durch (interne Kontrolle). Dies ist für die meisten Anhang-III-Systeme der Regelweg. Ausnahmen: Systeme nach Anhang III Nr. 1 (Biometrie) und bestimmte kritische Infrastruktursysteme sind zwingend durch eine Notifizierte Stelle zu prüfen.

Weg B — Konformitätsbewertung durch Notifizierte Stelle (Art. 43 Abs. 1 Unterabs. 2):

Sofern das KI-System zugleich ein Medizinprodukt nach MDR ist, das einer Konformitätsbewertung durch eine Notifizierte Stelle nach Art. 52 MDR bedarf (was für Klasse-IIb-Produkte der Fall ist), muss auch die KI-VO-Konformitätsbewertung durch dieselbe oder eine andere Notifizierte Stelle erfolgen. Dieser Weg ist für MedAssist v4 einschlägig.

2. Einschlägigkeit Weg B für MedAssist v4

Da MedAssist v4 als Medizinprodukt Klasse IIb die Konformitätsbewertung durch TÜV SÜD Product Service GmbH (NB 0123) bereits durchlaufen hat (MDR-CE 20.12.2025), ist für die KI-VO-Konformitätsbewertung Weg B einschlägig. Dies bedeutet:

- Die KI-VO-spezifische Prüfung muss durch eine für KI-VO notifizierte Stelle durchgeführt werden
- TÜV SÜD NB 0123 ist für KI-VO-Konformitätsbewertungen nach aktuellem Stand der NANDO-Datenbank (Stand: April 2026) notifiziert
- Ein separater KI-VO-Prüfauftrag an TÜV SÜD wäre erforderlich — alternativ kann eine andere notifizierte Stelle beauftragt werden

Feststellung: MedAssist AI GmbH hat bislang weder einen internen Konformitätsbewertungsprozess für KI-VO gestartet noch eine Notifizierte Stelle für die KI-VO-Prüfung beauftragt.

3. Ablauf der KI-VO-Konformitätsbewertung (Weg B, Anhang VI)

Schritt	Inhalt	Verantwortlich	Status
1	Vollständige technische Dokumentation (Anhang IV)	MedAssist AI GmbH	Fehlt (s. Aktenstück 06)
2	Vollständiges QMS nach Art. 17	MedAssist AI GmbH	Fehlt (s. Aktenstück 11)
3	Einreichung bei Notifizierter Stelle	MedAssist AI GmbH	Nicht begonnen
4	Prüfung durch NB (Audit, Dokumentenprüfung)	TÜV SÜD o.a.	Ausstehend
5	Ausstellung NB-Zertifikat	Notifizierte Stelle	Ausstehend
6	EU-Konformitätserklärung ausstellen (Art. 47)	MedAssist AI GmbH	Entwurf vorhanden
7	CE-Kennzeichnung anbringen (Art. 48)	MedAssist AI GmbH	Ausstehend
8	Registrierung EU-Datenbank (Art. 49)	MedAssist AI GmbH	Ausstehend

4. Zeitplanung und Fristproblematik

Kritische Einschätzung: Die Frist 02.08.2026 (Art. 113 Abs. 1 KI-VO) ist angesichts des aktuellen Stands der Vorbereitungen außerordentlich eng.

Realistische Zeitschätzung (Stand April 2026):

Meilenstein	Frühester Termin
Vervollständigung techn. Dokumentation	31.05.2026
QMS nach Art. 17 errichtet	31.05.2026
Einreichung bei TÜV SÜD	01.06.2026
NB-Prüfung abgeschlossen (Mindestdauer 6–8 Wochen)	Ende Juli 2026
EU-Konformitätserklärung + CE	August 2026
Registrierung EU-Datenbank	August 2026

Risiko: Das Verfahren ist unter Optimalbedingungen gerade noch fristtreu machbar. Jede Verzögerung — etwa durch Nachforderungen der Notifizierten Stelle — würde zur Fristüberschreitung führen. Empfohlen wird, TÜV SÜD unverzüglich zu kontaktieren und einen Prüftermin zu reservieren.

5. Verhältnis zur MDR-Konformitätsbewertung

Die KI-VO-Konformitätsbewertung tritt neben die MDR-Konformitätsbewertung. Das NB-Zertifikat nach MDR (TÜV SÜD) kann als Grundlagendokument herangezogen werden, ersetzt aber nicht die KI-VO-spezifische Prüfung. Empfohlen wird, mit TÜV SÜD eine koordinierte Prüfung zu vereinbaren (gemeinsame Audit-Termine, gemeinsame Dokumentation), um Aufwand zu minimieren.

6. Gesamtbewertung Art. 43

Art. 43 KI-VO: Nicht erfüllt.

Das Konformitätsbewertungsverfahren ist nicht eingeleitet. Angesichts der Frist 02.08.2026 besteht höchste Dringlichkeit. Beauftragung Notifizierte Stelle bis 15.05.2026 wird dringend empfohlen.

Heidelberg, 15.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

13-art-47-eu-konformitaetserklaerung.docx

Aktenstück 13 — Art. 47 KI-VO: EU-Konformitätserklärung — Analyse und Entwurf

Aktenzeichen: 2026-V-0427

Erstellt: 17.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 47 KI-VO (EU) 2024/1689

1. Rechtliche Anforderungen Art. 47 KI-VO

Art. 47 KI-VO verpflichtet Anbieter, vor dem Inverkehrbringen oder der Inbetriebnahme eines Hochrisiko-KI-Systems eine EU-Konformitätserklärung auszustellen. Die Erklärung muss mindestens enthalten (Art. 47 Abs. 2):

1. Name und Anschrift des Anbieters (und ggf. seines Bevollmächtigten)
2. Erklärung, dass die EU-Konformitätserklärung ausgestellt wird
3. Name und Typ des KI-Systems mit eindeutiger Kennung
4. Beschreibung des Verfahrens der Konformitätsbewertung
5. Name und Kennung der Notifizierten Stelle (falls eingeschaltet)
6. Verweis auf einschlägige harmonisierte Normen
7. Ggf. weitere angewandte Normen und technische Spezifikationen
8. Ort und Datum der Ausstellung, Unterschrift

Die EU-Konformitätserklärung muss für 10 Jahre nach dem letzten Inverkehrbringen aufbewahrt werden (Art. 47 Abs. 3 KI-VO).

2. Prüfung des übermittelten Entwurfs

CTO Krishnamurthy hat am 10.04.2026 einen Entwurf der EU-Konformitätserklärung übermittelt (Dokument MA-KONF-ERKL-ENTWURF-2026-01). Prüfungsergebnis:

Pflichtbestandteil Art. 47 Abs. 2	Im Entwurf	Bewertung
Nr. 1 — Name/Anschrift Anbieter	Vorhanden	Konform
Nr. 2 — Erklärungsformel	Vorhanden	Konform
Nr. 3 — Name/Typ/Kennung KI-System	Teilweise	Kennung fehlt (keine eindeutige MA-ID)
Nr. 4 — Verfahrensbeschreibung Konformitätsbewertung	Fehlt	Kritisch: NB noch nicht beauftragt
Nr. 5 — NB-Name und -Kennung	Fehlt	Konsequenz aus Nr. 4
Nr. 6 — Verweis harmonisierte Normen	Lückenhaft	Nur ISO 9001; ISO 62304, ISO 14971 fehlen
Nr. 7 — Weitere Normen/Spezifikationen	Lückenhaft	ENISA-Leitlinien nicht erwähnt
Nr. 8 — Ort, Datum, Unterschrift	Noch leer	Noch nicht unterzeichnet

Bewertung: Der Entwurf ist nicht fertigstellungsreif. Er kann erst nach Abschluss des Konformitätsbewertungsverfahrens (Art. 43) und NB-Zertifizierung finalisiert werden.

3. Unterzeichnungsberechtigte

Die EU-Konformitätserklärung muss von der verantwortlichen natürlichen Person beim Anbieter unterzeichnet werden. Bei der MedAssist AI GmbH ist dies CEO Dr. Theresia Vogelkamp (einzelnvertretungsberechtigt). Eine Delegation an CTO Krishnamurthy wäre nur mit gesonderter Vollmacht möglich.

Empfehlung: Da die EU-Konformitätserklärung ein Dokument mit erheblicher Rechtswirkung ist (Grundlage für CE-Kennzeichnung und EU-Datenbankregistrierung), sollte nur CEO Dr. Vogelkamp unterzeichnen.

4. Koordination mit MDR-Konformitätserklärung

MedAssist AI GmbH hat am 18.12.2025 auch eine EU-Konformitätserklärung nach Art. 19 MDR ausgestellt (Bezugnahme auf TÜV-SÜD-Zertifikat NB 0123, Az. MDR-2025-08812). Diese MDR-Erklärung ist separat von der KI-VO-Konformitätserklärung und kann nicht kombiniert werden (unterschiedliche Rechtsnormen, unterschiedliche NB-Kennungen möglich). Empfohlen wird, beide Erklärungen in der Technischen Dokumentation nebeneinander zu führen und aufeinander zu verweisen.

5. Handlungsplan EU-Konformitätserklärung

Schritt	Frist
NB (TÜV SÜD) beauftragen	15.05.2026
Eindeutige Systemkennung (MA-ID) festlegen und dokumentieren	30.04.2026
Normverzeichnis vervollständigen	31.05.2026
Entwurf nach NB-Zertifizierung finalisieren	August 2026
Unterzeichnung durch CEO Dr. Vogelkamp	August 2026
Aufbewahrung 10 Jahre (elektronisch signiert)	Ab Unterzeichnung

6. Gesamtbewertung Art. 47

Art. 47 KI-VO: Entwurf vorhanden, aber nicht finalisierbar vor NB-Zertifizierung.

Keine Verletzung des Finalitätserfordernisses zum gegenwärtigen Zeitpunkt (Zertifizierung noch offen). Kritische Lücken im Entwurf müssen bis Abschluss NB-Verfahren behoben werden.

Heidelberg, 17.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

14-art-48-ce-kennzeichnung.docx

Aktenstück 14 — Art. 48 KI-VO: CE-Kennzeichnung — Koordination mit MDR

Aktenzeichen: 2026-V-0427

Erstellt: 18.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 48 KI-VO (EU) 2024/1689; Art. 20 MDR (EU) 2017/745

1. CE-Kennzeichnung nach KI-VO

Art. 48 Abs. 1 KI-VO: Vor dem Inverkehrbringen oder der Inbetriebnahme eines Hochrisiko-KI-Systems bringt der Anbieter die CE-Kennzeichnung an. Voraussetzung: Das Konformitätsbewertungsverfahren nach Art. 43 KI-VO ist abgeschlossen und die EU-Konformitätserklärung nach Art. 47 wurde ausgestellt.

Art. 48 Abs. 2 KI-VO: Die CE-Kennzeichnung muss sichtbar, lesbar und dauerhaft auf dem KI-System oder dessen Begleitunterlagen angebracht sein. Bei Software gilt: Anbringung in der digitalen Oberfläche und in der Dokumentation.

Art. 48 Abs. 4 KI-VO: Bei Medizinprodukten nach MDR, die einer Konformitätsbewertung durch eine Notifizierte Stelle bedurften, folgt auf die KI-VO-CE-Kennzeichnung das Notifizierte-Stelle-Kennzeichen.

2. Aktueller Status CE-Kennzeichnung

CE-Kennzeichnung	Status	Grundlage
CE nach MDR (EU) 2017/745	Angebracht (20.12.2025)	TÜV SÜD NB 0123; MDR-Zertifikat
CE nach KI-VO (EU) 2024/1689	Nicht angebracht	KI-VO-Konformitätsbewertung ausstehend

Das MDR-CE-Kennzeichen ist bereits ordnungsgemäß angebracht (in der Softwareoberfläche, in den Produktunterlagen und auf der Website). Das KI-VO-CE-Kennzeichen kann erst nach Abschluss des KI-VO-Konformitätsbewertungsverfahrens angebracht werden.

3. Koordinationsfragen MDR-CE / KI-VO-CE

3.1 Gleichzeitige Anbringung

Art. 8 Abs. 1 KI-VO bestimmt, dass sektorspezifische Unionsrechtsakte (u.a. MDR) unberührt bleiben. Art. 48 Abs. 3 KI-VO erlaubt ausdrücklich, dass KI-VO-CE und sektorspezifisches CE-Zeichen nebeneinander bestehen. Für MedAssist v4 bedeutet dies:

- Beide CE-Kennzeichen müssen angebracht werden
- Reihenfolge: MDR-CE (bereits vorhanden) → KI-VO-CE (nach Abschluss KI-VO-Bewertung)

- Anbringungsort: gemeinsame Darstellung in Produktoberfläche und Dokumentation, klar differenziert

3.2 NB-Kennzeichen

Nach Art. 48 Abs. 4 KI-VO ist die CE-Kennzeichnung für KI-VO bei mandatorischer NB-Beteiligung (hier gegeben, da MDR-Kombination) durch das NB-Kennzeichen zu ergänzen. TÜV SÜD NB 0123 ist also auch im KI-VO-CE anzugeben.

3.3 Keine Vorwegnahme

Wichtig: Die CE-Kennzeichnung nach KI-VO darf ausschließlich nach Abschluss des vollständigen Konformitätsbewertungsverfahrens angebracht werden. Eine vorzeitige Anbringung würde Art. 48 KI-VO verletzen und ist als Verstoß gegen Art. 99 Abs. 2 lit. c KI-VO bußgeldbewehrt (bis zu 15 Mio. EUR oder 3 % des weltweiten Jahresumsatzes, je nachdem welcher Betrag höher ist).

4. Praktische Umsetzung (Software-CE)

Für Software-Produkte wird die CE-Kennzeichnung typischerweise wie folgt umgesetzt:

- **Produktoberfläche:** „About“-Bildschirm oder Impressum der Softwareapplikation; Aufnahme beider CE-Zeichen nach Abschluss beider Verfahren
- **Benutzerhandbuch:** Deckblatt und Abschnitt Konformitätsangaben
- **Website des Anbieters:** Produktseite MedAssist v4
- **Technische Dokumentation:** Titelblatt

5. Zeitplanung CE-Kennzeichnung KI-VO

Meilenstein	Voraussetzung	Frühester Termin
KI-VO-Konformitätsbewertung abgeschlossen	NB-Zertifizierung	Ende Juli 2026
EU-Konformitätserklärung unterzeichnet	NB-Zertifizierung	August 2026
CE-Kennzeichen KI-VO angebracht	EU-Konformitätserklärung	August 2026

6. Gesamtbewertung Art. 48

Art. 48 KI-VO: Noch nicht erfüllbar — abhängig von NB-Zertifizierung.

MDR-CE korrekt angebracht. KI-VO-CE kann erst nach Abschluss des NB-Verfahrens angebracht werden. Keine eigenständige Verletzung zum gegenwärtigen Zeitpunkt, sofern KI-VO-CE nicht vorzeitig angebracht wird.

Heidelberg, 18.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

15-art-49-registrierung-eu-datenbank.docx

Aktenstück 15 — Art. 49 KI-VO: Registrierung EU-Datenbank (EUID)

Aktenzeichen: 2026-V-0427

Erstellt: 20.04.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 49 KI-VO (EU) 2024/1689; Art. 71 KI-VO (EU-Datenbank)

1. Registrierungspflicht Art. 49 KI-VO

Art. 49 Abs. 1 KI-VO verpflichtet Anbieter von Hochrisiko-KI-Systemen nach Anhang III, ihr System vor dem Inverkehrbringen oder der Inbetriebnahme in der EU-KI-Datenbank nach Art. 71 KI-VO zu registrieren. Die Datenbank wird von der EU-KI-Behörde (AI Office der Europäischen Kommission) verwaltet. Die Registrierung mündet in einer eindeutigen EU-KI-Kennung (EUID — EU AI Identification).

2. Pflichtangaben für die Registrierung (Art. 49 Abs. 2)

Pflichtfeld	Inhalt (MedAssist v4)	Status
Name und Anschrift Anbieter	MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg	Bereit
Handelsname und Typ des KI-Systems	MedAssist v4 — Notrufdispositionssystem	Bereit
Beschreibung des Verwendungszwecks	Automatisierte Notrufdisposition in Krankenhäusern	Bereit
Version und Änderungsstand	v4.2.3	Bereit
Status des KI-Systems (in Betrieb / eingestellt)	In Betrieb	Bereit
Einstufung nach Anhang III	Anhang III Nr. 7	Bereit
Verweis auf EU-Konformitätserklärung	Art. 47-Erklärung	Ausstehend (noch nicht ausgestellt)
Verweis auf NB-Zertifikat	TÜV SÜD NB 0123 (KI-VO)	Ausstehend
Erklärung zur Nutzung durch Betreiber	18 Krankenhäuser BW/Bayern	Bereit

3. Aktueller Registrierungsstand

MedAssist AI GmbH hat **keine Registrierung** in der EU-KI-Datenbank vorgenommen. Der Mandant hat bei Erstkontakt am 03.03.2026 angegeben, nicht gewusst zu haben, dass eine Registrierungspflicht bereits vor Vollständigkeit der Konformitätsbewertung für in Betrieb befindliche Systeme gilt.

Rechtliche Klarstellung: Art. 49 Abs. 1 KI-VO normiert die Registrierungspflicht „vor dem Inverkehrbringen oder der Inbetriebnahme“. MedAssist v4 ist seit 2023 in Betrieb; die KI-VO galt ab 02.08.2024 (Art. 113 Abs. 1). Für Systeme, die bereits vor Inkrafttreten der KI-VO in Betrieb waren, gilt die Übergangsfrist des Art. 113 Abs. 1 KI-VO (02.08.2026). Die Registrierung muss bis spätestens 02.08.2026 erfolgen.

4. Praktischer Registrierungsprozess

Die Registrierung erfolgt über das EU-AI-Office-Portal (<https://ai-act-portal.ec.europa.eu>, Login mit EU-Login-Konto). Der Prozess umfasst:

1. Anlegen eines Organisationskontos für MedAssist AI GmbH beim EU-AI-Office
2. Ausfüllen der Pflichtfelder (s. Tabelle oben) und Upload der EU-Konformitätserklärung
3. Eingabe NB-Zertifikats-Referenz
4. Übermittlung → System generiert EUID automatisch
5. EUID muss anschließend in der technischen Dokumentation und (nach CE-Anbringung) in der Produktoberfläche vermerkt werden

Problem: Die Registrierung setzt die fertige EU-Konformitätserklärung voraus, die wiederum das NB-Zertifikat voraussetzt. Da beide noch ausstehen, kann die Registrierung frühestens nach Abschluss des NB-Verfahrens (Ende Juli 2026) erfolgen.

5. Vorbereitungsmaßnahmen

Maßnahme	Frist	Verantwortlich
EU-Login-Konto für MedAssist AI GmbH anlegen	30.04.2026	CTO Krishnamurthy
Pflichtangaben vorbereiten und intern genehmigen	31.05.2026	Dr. Roosendaal (Koordination)
EU-Konformitätserklärung finalisieren	August 2026	Dr. Vellbruck-Steinheim
Registrierung durchführen (nach NB-Zertifikat)	August 2026	CTO Krishnamurthy
EUID in Dokumentation und Oberfläche eintragen	August 2026	CTO Krishnamurthy

6. Gesamtbewertung Art. 49

Art. 49 KI-VO: Nicht erfüllt.

Keine Registrierung vorhanden. Fristgerechte Registrierung bis 02.08.2026 noch möglich, aber abhängig von NB-Zertifizierung und EU-Konformitätserklärung. Vorbereitungen unverzüglich aufnehmen.

Heidelberg, 20.04.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

16-grenzwerte-mdr-2017-745-schnittstelle.docx

Aktenstück 16 — MDR (EU) 2017/745: Klasse IIb, Notified Body, Doppelkonformität

Aktenzeichen: 2026-V-0427

Erstellt: 22.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: MDR (EU) 2017/745; Art. 8 KI-VO (EU) 2024/1689

1. MDR-Einordnung MedAssist v4

1.1 Klasse-IIb-Klassifizierung

Nach Regel 11 Anhang VIII MDR gilt für medizinische Software: Software, die zur Kontrolle physiologischer Prozesse eingesetzt wird oder Informationen zur Diagnose, Therapie oder Prävention von Erkrankungen liefert, ist als Medizinprodukt einzustufen. MedAssist v4 klassifiziert medizinische Notfälle, schlägt Therapieressourcen (Spezialisten, Reanimationsteams) vor und priorisiert Ressourcen in lebensbedrohlichen Situationen. Dies führt nach Regel 11 Abs. 3 Anhang VIII MDR zur Klassifizierung als Klasse IIb (erhöhtes Risiko bei Fehlfunktionen; Schäden schwerwiegend, aber nicht zwangsläufig irreversibel; Verwendung in lebensbedrohlichem Umfeld).

1.2 Abgrenzung zu Klasse III

Klasse III (höchste Risikokategorie) wäre einschlägig, wenn das System unmittelbar lebenserhaltende Funktionen steuert (z.B. autonome Medikamentendosierung). Da MedAssist v4 dispositionsunterstützend ist und keine unmittelbare Therapiesteuerung vornimmt, verbleibt es bei Klasse IIb — sofern die menschliche Aufsicht tatsächlich wirksam ist (was aktuell bezweifelt werden muss; s. Aktenstück 09).

2. BfArM-Bescheid (Az. MED-AI-2026-0319)

Das BfArM hat mit Bescheid vom 12.01.2026 die MDR-Konformität von MedAssist v4 Klasse IIb bestätigt. Der Bescheid basiert auf:

- NB-Zertifikat TÜV SÜD NB 0123, ausgestellt 20.11.2025, gültig bis 20.11.2028
- Technischem Dossier MedAssist v4 Version 4.2.0 (Stand August 2024)
- Klinische Evaluierung nach Art. 61 MDR i.V.m. Anhang XIV MDR (klinische Daten aus Partnerkliniken 2021–2023)

Wichtiger Hinweis im BfArM-Bescheid:

„Die vorliegende Feststellung beschränkt sich auf die Anforderungen der Verordnung (EU) 2017/745. Anforderungen der KI-VO (EU) 2024/1689 werden von diesem Bescheid nicht erfasst. Für eine vollständige Konformität des Produkts mit dem gesamten EU-Recht ist die Einhaltung der KI-VO durch das Unternehmen eigenverantwortlich sicherzustellen.“

3. Schnittstellenanalyse MDR / KI-VO

3.1 Klinische Evaluierung MDR vs. Art. 9 Abs. 7 KI-VO

Die MDR-Klinische Evaluierung (Anhang XIV MDR) und das KI-VO-Testing unter realen Bedingungen (Art. 9 Abs. 7 KI-VO) überschneiden sich in der Zielsetzung, sind aber unterschiedliche rechtliche Instrumente. Empfohlen wird ein koordinierter Ansatz: Erweiterung der MDR-Klinischen Evaluierung um KI-VO-spezifische Test-Dimensionen (Bias, Robustheit, Adversarial Testing).

3.2 Grundlegende Sicherheits- und Leistungsanforderungen (MDR Anhang I) vs. Art. 15 KI-VO

MDR Anhang I, insbesondere Nr. 14 (allgemeine Anforderungen für Software als Medizinprodukt), verlangt ähnliche Genauigkeits- und Sicherheitsanforderungen wie Art. 15 KI-VO. Die Abweichung: Die False-Negative-Rate von 8,8 % bei Dringlichkeit 1 wirft die Frage auf, ob das MDR-Anforderungsniveau tatsächlich erfüllt ist — oder ob das NB die Klinische Evaluierung nur auf Basis der Partnerklinik-Daten (mit begrenztem Aussagegewicht) positiv beschieden hat.

Empfehlung: Überprüfung, ob das BfArM-Verfahren Anlass gibt, das NB-Zertifikat nach § 87 MDR zu überprüfen. Dies ist eine intern heikle Thematik, da eine Infragestellung des MDR-CE die Marktstellung von MedAssist v4 weiter destabilisieren würde.

3.3 Post-Market Surveillance MDR (Art. 83–84) vs. Art. 72 KI-VO

Beide Regime verlangen Post-Market-Überwachung. Das MDR-PMS-System (vorhanden, als Teil des NB-Verfahrens) kann als Grundlage für das KI-VO-Post-Market-Monitoring nach Art. 72 KI-VO genutzt werden, muss aber um KI-spezifische Dimensionen (Konzeptdrift, Bias-Monitoring, Accuracy-Tracking) ergänzt werden.

4. Empfehlungen zur Doppelkonformitätsstrategie

Bereich	MDR-Anforderung	KI-VO-Anforderung	Koordinationsmaßnahme
Technische Dokumentation	Anhang II MDR	Anhang IV KI-VO	Zusammenführung in Gesamt-Technisches Dossier
Klinische Validierung	Anhang XIV MDR	Art. 9 Abs. 7 KI-VO	Erweiterung MDR-Klinische Evaluierung
Post-Market	Art. 83–84 MDR	Art. 72 KI-VO	MDR-PMS um KI-VO-Dimensionen erweitern
Vorfallmeldung	Art. 87 MDR (BfArM)	Art. 73 KI-VO (BNetzA)	Koordiniertes Meldemanagement einrichten
NB-Zertifizierung	TÜV SÜD NB 0123 (MDR)	TÜV SÜD NB 0123 (KI-VO)	Gemeinsame Prüftermine vereinbaren

5. Gesamtbewertung MDR-Schnittstelle

Die MDR-Konformität ist formal bestätigt, inhaltlich aber in Teilen fragwürdig (angesichts der False-Negative-Rate und der Aufsichtslücke). Die Doppelkonformität ist technisch machbar, erfordert aber eine koordinierte Dokumentationsstrategie und gemeinsame Prüftermine mit TÜV SÜD. Priorität: Erweiterung MDR-Klinische Evaluierung für KI-VO-Zwecke.

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

17-marktueberwachung-bnetza-zustaendigkeit.docx

Aktenstück 17 — BNetzA: Marktüberwachung KI-VO, Verfahrensstand, Auskunftspflicht

Aktenzeichen: 2026-V-0427

BNetzA-Verfahren: 1-101.05-2026/MA-008

Erstellt: 25.04.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim

Rechtsgrundlage: Art. 74 ff. KI-VO (EU) 2024/1689; KI-VO-Durchführungsgesetz (KI-VoDG, in Kraft ab 01.01.2026)

1. Zuständigkeit der BNetzA

Durch das deutsche KI-VO-Durchführungsgesetz (KI-VoDG) vom 15.12.2025 (BGBl. I 2025, S. 4812) wurde die Bundesnetzagentur (BNetzA) als nationale Marktüberwachungsbehörde für den Großteil der KI-VO-Sachverhalte bestimmt, mit Ausnahmen zugunsten der BaFin (Finanzsektor) und des BfArM (Medizinprodukte-Spezialfragen). Die BNetzA hat innerhalb der EU als Marktüberwachungsbehörde die Befugnisse nach Art. 74–80 KI-VO, insbesondere:

- Dokumentenanforderung (Art. 74 Abs. 4)
- Vor-Ort-Besichtigung (Art. 74 Abs. 5)
- Vorläufige Maßnahmen (Art. 79)
- Rückruf, Marktrücknahme (Art. 80)
- Bußgeldempfehlung an die EU-KI-Behörde (Bußgelder nach Art. 99 KI-VO)

2. Verfahrensstand BNetzA Az. 1-101.05-2026/MA-008

Chronologie

Datum	Ereignis
22.02.2026	BNetzA eröffnet Marktüberwachungsverfahren nach Art. 74 KI-VO auf Basis der DiagnoFlow-Beschwerde (DG CONNECT, weitergeleitet an BNetzA)
25.02.2026	BNetzA-Eröffnungsschreiben an MedAssist AI GmbH; Aufforderung zur Stellungnahme binnen 4 Wochen
03.03.2026	Mandatserteilung Vellbruck & Partner; Vollmacht an BNetzA übermittelt
01.03.2026	Erstes Auskunftersuchen BNetzA: Anforderung techn. Dokumentation, Risikoanalyse, Logging-Daten, Liste Betreiber
15.03.2026	Teilantwort MedAssist AI GmbH: techn. Dokumentation (unvollständig), Risikoanalyse MA-RISK-2024-01, Logging-Export 18 Kliniken (ohne Disponenten-ID)
22.03.2026	BNetzA: Nachforderung — Disponenten-ID-Daten, Nachweise menschliche Aufsicht,

	Trainingsdatendokumentation
05.04.2026	Dr. Vellbruck-Steinheim antwortet für Mandanten: Disponenten-ID-Logs in 14 Kliniken noch nicht vorhanden (technischer Fehler); Fristbitte bis 30.04.2026 für Nachlieferung
10.04.2026	BNetzA gewährt Fristverlängerung bis 07.05.2026, kündigt aber Vor-Ort-Besichtigung an
22.04.2026	BNetzA kündigt Vor-Ort-Besichtigung Klinikum Mannheim-Süd für 12.05.2026 an

3. Vorbereitung Vor-Ort-Besichtigung (12.05.2026)

3.1 Gegenstand der Besichtigung

Die BNetzA hat den Besichtigungsgegenstand definiert als:

- Überprüfung des Leitstellen-Dashboards (Art. 14-Aufsichtsmechanismus)
- Einsicht in Logging-Daten vor Ort (Art. 12)
- Gespräch mit dem lokalen Disponenten-Team (Schulungsstand)

3.2 Empfehlungen zur Besichtigungsvorbereitung

Maßnahme	Verantwortlich	Frist
Sicherstellen, dass Quittierungsschritt (Beta) in Klinikum Mannheim-Süd aktiv ist	CTO Krishnamurthy	07.05.2026
Kurzbriefing Disponenten-Team Mannheim-Süd	Klinikum + Dr. Vellbruck-Steinheim	11.05.2026
Rechtsanwalt vor Ort (Dr. Vellbruck-Steinheim)	—	12.05.2026
Logging-Daten bereinigen und aufbereiten für BNetzA-Einsicht	CTO Krishnamurthy	07.05.2026
Keine spontanen Aussagen zu Art. 14-Defiziten durch Klinikpersonal	Briefing	11.05.2026

Hinweis: Die BNetzA kann gemäß Art. 74 Abs. 5 KI-VO Systemzugang verlangen und Testläufe durchführen. MedAssist AI GmbH ist zur Kooperation verpflichtet; eine Verweigerung der Kooperation kann als erschwerender Umstand im Bußgeldverfahren gewertet werden.

4. Bußgeldrahmen (Art. 99 KI-VO)

Verstoß	Bußgeldrahmen
Nicht-Konformität des KI-Systems (Art. 5, 10, 13, 14, 15)	Bis 15 Mio. EUR oder 3 % des weltweiten Jahresumsatzes
Fehler im Konformitätsbewertungsverfahren	Bis 15 Mio. EUR oder 3 %
Fehlinformationen gegenüber Behörden	Bis 7,5 Mio. EUR oder 1,5 %
Verstöße gegen Transparenzpflichten	Bis 7,5 Mio. EUR oder 1,5 %

MedAssist AI GmbH hat laut Jahresbericht 2024 einen weltweiten Jahresumsatz von ca. 48 Mio. EUR. Relevante Bußgeldobergrenzen damit: 15 Mio. EUR (für Art. 10, 13, 14, 15-Verstöße) bzw. ca. 1,44 Mio. EUR (3 % von 48 Mio.) — Bußgeld wird auf den höheren Wert festgesetzt, hier 15 Mio. EUR.

5. Kooperationsstrategie

Dr. Vellbruck-Steinheim empfiehlt gegenüber der BNetzA eine transparente Kooperationsstrategie:

- Vollständige Offenlegung der identifizierten Mängel
- Vorlage des Handlungsplans (Aktenstück 20)
- Proaktive Demonstration eingeleiteter Maßnahmen (Quittierungsschritt-Rollout bis 30.04.2026)

Diese Strategie kann bußgeldmindernd wirken (vgl. Art. 99 Abs. 6 KI-VO: Berücksichtigung kooperativen Verhaltens).

Heidelberg, 25.04.2026

RAin Dr. Henrietta Vellbruck-Steinheim — Az. 2026-V-0427

18-bafin-finanzaufsicht-schnittstelle.docx

Aktenstück 18 — BaFin-Schnittstelle: Finanzaufsicht und Datenschutz-Berührungspunkte

Aktenzeichen: 2026-V-0427

Erstellt: 26.04.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: KI-VoDG § 5 (BaFin-Zuständigkeit Finanzsektor); DSGVO Art. 9, 35; BfDI Az. 13-3120/004#0117

1. BaFin-Zuständigkeit im KI-VO-Kontext

Gemäß § 5 Abs. 2 KI-VoDG ist die Bundesanstalt für Finanzdienstleistungsaufsicht (BaFin) die zuständige Marktüberwachungsbehörde für KI-Systeme im Anwendungsbereich des Kreditwesengesetzes (KWG), der Versicherungsaufsicht (VAG) und verwandter Finanzmarktregulierung. MedAssist AI GmbH ist kein Finanzdienstleister; MedAssist v4 hat keine originäre Finanzsektoranwendung.

Direkter BaFin-Bezug besteht nicht. Das vorliegende Aktenstück dokumentiert jedoch zwei Berührungspunkte, die BaFin-relevante Aspekte tangieren:

2. D&O-Versicherung: BaFin-Aufsicht über Allianz SE

Die Kündigung der D&O-Police der Allianz SE (Schreiben 01.03.2026) ist versicherungsvertragsrechtlich relevant. Die Allianz SE unterliegt der Aufsicht durch die BaFin (§ 1 Abs. 1 Nr. 1 VAG). Sofern die Kündigung als Reaktion auf ein regulatorisches Verfahren (BNetzA-Marktüberwachung) erfolgt, stellt sich die Frage, ob ein Wettbewerbs- oder Aufsichtsrecht-Problem besteht.

Einschätzung: Die Kündigung der D&O-Versicherung ist privatrechtlich zulässig (§ 314 BGB, außerordentliche Kündigung bei schwerwiegender Pflichtverletzung). Eine BaFin-Intervention ist nicht zu erwarten. Die Kündigung entfaltet jedoch erheblichen Druck auf den Vorstand der MedAssist AI GmbH: Ohne D&O-Schutz haften CEO Dr. Vogelkamp und CTO Krishnamurthy persönlich für Schäden aus KI-VO-Verstößen (§ 43 GmbHG i.V.m. § 823 BGB). Dies verstärkt die Motivation zur schnellen Konformitätsherstellung.

Empfehlung: Erneute Verhandlung mit Allianz SE nach Vorlage des Handlungsplans und Nachweis der eingeleiteten Maßnahmen (insbesondere Quittierungsschritt-Rollout). Parallel: Marktabfrage alternativer D&O-Versicherer im KI-Bereich (z.B. AXA XL, Zurich).

3. BfDI: DPIA und Datenschutz-Berührungspunkte

3.1 BfDI-Anforderung (Az. 13-3120/004#0117)

Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI) hat mit Schreiben vom 15.02.2026 eine Datenschutz-Folgenabschätzung (DPIA) nach Art. 35 DSGVO angefordert. Die BfDI begründet die Anforderung mit:

- Systematische Verarbeitung von Gesundheitsdaten (Art. 9 Abs. 1 DSGVO) in großem Maßstab (18 Krankenhäuser, täglich ca. 3.200 Notrufe)
- Automatisierte Entscheidungsunterstützung mit potenzieller Wirkung auf Betroffene (Patienten), Art. 22 DSGVO
- Verarbeitung von Daten besonderer Kategorien ohne ausreichend dokumentierte Rechtsgrundlage

3.2 Art. 35 DSGVO — Pflicht zur DPIA

Art. 35 Abs. 3 lit. a DSGVO: Eine DPIA ist obligatorisch bei „systematischer und umfangreicher Verarbeitung besonderer Kategorien von Daten gemäß Art. 9“. Dies ist hier eindeutig gegeben.

Die DPIA hätte vor Inbetriebnahme von MedAssist v4 durchgeführt werden müssen. Das Versäumnis begründet einen Verstoß gegen Art. 35 DSGVO, für den die BfDI Bußgelder nach Art. 83 Abs. 4 DSGVO (bis 10 Mio. EUR oder 2 % des weltweiten Jahresumsatzes) verhängen kann.

3.3 DPIA-Inhalte (Art. 35 Abs. 7 DSGVO)

Die DPIA muss enthalten:

- Systematische Beschreibung der Verarbeitungsvorgänge und Verarbeitungszwecke
- Bewertung der Notwendigkeit und Verhältnismäßigkeit
- Bewertung der Risiken für die Rechte und Freiheiten der betroffenen Personen
- Vorgesehene Abhilfemaßnahmen, Sicherheitsmaßnahmen und Garantien

Besonderheit KI: Für KI-Systeme empfiehlt das European Data Protection Board (EDPB), in der DPIA auch das Risiko algorithmischer Diskriminierung (Bias) zu adressieren. Dies schlägt die Brücke zu Art. 10 KI-VO (s. Aktenstück 05).

4. Art. 22 DSGVO — Automatisierte Einzelentscheidungen

Art. 22 Abs. 1 DSGVO: Personen haben das Recht, nicht einer ausschließlich automatisierten Entscheidung unterworfen zu werden, die ihnen gegenüber rechtliche Wirkung entfaltet oder sie in ähnlicher Weise erheblich beeinträchtigt. Im Notfalldispositionskontext: Wird die Ressourcenzuweisung durch MedAssist v4 faktisch ohne menschliche Prüfung übernommen (was in 14 Kliniken der Fall ist), kann dies als „ausschließlich automatisierte“ Entscheidung qualifiziert werden.

Handlungsempfehlung: Der Roll-out des Pflicht-Quittierungsschritts (Art. 14 KI-VO) löst zugleich die Art. 22 DSGVO-Problematik. Die DPIA muss diesen Zusammenhang explizit dokumentieren.

5. Handlungsempfehlungen

Maßnahme	Frist	Verantwortlich
DPIA erstellen und BfDI vorlegen	01.05.2026	Dr. Roosendaal (federführend)

Aktenstück 18

Behörde · Aktenzeichen: 2026-V-0427

Allianz SE: Verhandlung D&O-Verlängerung nach Handlungsplan-Vorlage	15.05.2026	CEO Dr. Vogelkamp
Art. 22 DSGVO-Analyse in DPIA integrieren	01.05.2026	Dr. Roosendaal
Rechtsgrundlagen-Prüfung AVV 18 Kliniken (Art. 9 DSGVO)	31.05.2026	Dr. Roosendaal

Heidelberg, 26.04.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

19-gpai-baseline-llm-komponente.docx

Aktenstück 19 — GPAI-Basiskomponente: Llama-Adaptation, Art. 53 KI-VO, Systemcard

Aktenzeichen: 2026-V-0427

Erstellt: 28.04.2026

Bearbeitung: RA Dr. Mark Roosendaal

Rechtsgrundlage: Art. 3 Nr. 63, Art. 51–55 KI-VO (EU) 2024/1689 (GPAI-Modelle)

1. Rechtlicher Rahmen: GPAI-Modelle nach KI-VO

Die KI-VO reguliert in Kapitel V (Art. 51–55) erstmals explizit sogenannte Allzweck-KI-Modelle (GPAI — General Purpose AI). Ein GPAI-Modell i.S.d. Art. 3 Nr. 63 KI-VO ist ein KI-Modell, das mit einer großen Datenmenge trainiert wurde, auf breiter Basis verfügbar ist und eine Vielzahl von Aufgaben erfüllen kann.

Relevanz für MedAssist v4: Die NLU-Kernkomponente „MedAssist-LLM-Core v4“ basiert auf Llama-3.1-70B-Instruct von Meta AI, das durch Fine-Tuning auf medizinische Notfalldaten angepasst wurde. Llama-3.1 ist ein anerkanntes GPAI-Modell; das Fine-Tuning ändert nichts an dieser Grundnatur.

2. GPAI-Anbieterpflichten (Art. 53 KI-VO)

Art. 53 KI-VO verpflichtet GPAI-Modellanbieter zu:

Pflicht	Art. 53 Abs.	Erfüllungsort bei MedAssist v4
Technische Dokumentation des Modells (Systemcard)	Art. 53 Abs. 1 lit. a	Meta AI (Llama-Anbieter) — nicht MedAssist
Informationen für nachgelagerte Anbieter	Art. 53 Abs. 1 lit. b	Meta AI; zu prüfen ob MedAssist weiterverpflichtet
Urheberrechtsrichtlinien-konformes Training	Art. 53 Abs. 1 lit. c	Meta AI (Training Llama-3.1)
Zusammenfassung Trainingsinhalte (öffentlich)	Art. 53 Abs. 1 lit. d	Meta AI

2.1 Differenzierung: Meta AI vs. MedAssist AI GmbH als GPAI-Anbieter

Grundsatz: Der GPAI-Anbieter ist die Partei, die das Modell trainiert und in Verkehr bringt. Bei reinem Downstream-Fine-Tuning (Anpassung des vortrainierten Modells) stellt sich die Frage, ob der Fine-Tuner selbst zum GPAI-Anbieter wird.

Rechtseinschätzung: Nach Art. 3 Nr. 63 i.V.m. Art. 51 Abs. 2 KI-VO: Wer ein GPAI-Modell durch Fine-Tuning wesentlich modifiziert, übernimmt die Anbieterstellung für das modifizierte Modell, sofern das Resultat weiterhin als GPAI-Modell einzustufen ist (d.h. generalistische Verwendbarkeit wäre erhalten).

MedAssist AI GmbHs Position: Das Fine-Tuning wurde ausschließlich auf medizinische Notfallkommunikation ausgerichtet. MedAssist-LLM-Core v4 hat damit keine generalistische

Verwendbarkeit mehr — es ist ein spezialisiertes Anwendungsmodell, kein GPAI-Modell. Damit entfallen die GPAI-Anbieterpflichten nach Art. 53 KI-VO für MedAssist AI GmbH.

Jedoch (kritischer Befund): Die Nutzung des GPAI-Modells Llama-3.1 als Basis verpflichtet MedAssist AI GmbH als nachgelagerter Anbieter nach Art. 11 Abs. 3 KI-VO, die vom Llama-Anbieter (Meta AI) bereitgestellten Informationen in die eigene technische Dokumentation zu integrieren. Dies ist bislang nicht erfolgt.

3. Verfügbare Llama-3.1-GPAI-Dokumentation von Meta AI

Meta AI hat für Llama-3.1 folgende Dokumentation veröffentlicht (Stand April 2026):

- **System Card Llama 3.1:** <https://ai.meta.com/llama> — enthält Trainingsarchitektur, Datenanmerkungen, Evaluierungsergebnisse, Sicherheitsbewertungen
- **Acceptable Use Policy:** Einschränkungen für Hochrisiko-Anwendungen (u.a. medizinische Diagnose ohne menschliche Aufsicht explizit eingeschränkt)
- **RAIL-Lizenzbedingungen:** Nutzungseinschränkungen für bestimmte Anwendungsfälle

Kritischer Befund: Die Acceptable Use Policy von Llama-3.1 schließt die eigenständige medizinische Diagnose ohne menschliche Aufsicht aus. MedAssist v4 bewegt sich in einem Grenzbereich: Die Notrufdisposition ist keine „Diagnose“ im klinischen Sinne, enthält aber klassifikatorische Urteile mit medizinischem Charakter. Die fehlende menschliche Aufsicht (Art. 14-Defizit) könnte auch eine Verletzung der Meta-Lizenzbedingungen darstellen — was rechtlich komplizierte Konsequenzen hätte.

4. Systemcard-Anforderungen nach Art. 52 KI-VO

Art. 52 Abs. 1 KI-VO: GPAI-Modellanbieter mit systemischem Risiko (Trainingsrechenaufwand $> 10^{25}$ FLOP) haben erweiterte Pflichten, einschließlich Model Evaluation (Red Teaming) und Systemcard mit erweitertem Inhalt. Llama-3.1-70B: Der Trainingsaufwand liegt bei ca. $6,4 \times 10^{23}$ FLOP — damit unterhalb der Systemrisiko-Schwelle. Die erweiterten Art. 52-Pflichten gelten nicht für Llama-3.1-70B.

5. Handlungsempfehlungen

Maßnahme	Priorität	Frist
Integration Llama-3.1 System Card in technische Dokumentation MedAssist v4	Hoch	30.05.2026
Rechtliche Prüfung Meta RAIL-Lizenz auf Vereinbarkeit mit Notrufdisposition ohne vollständige Aufsicht	Hoch	15.05.2026
Fine-Tuning-Dokumentation (Trainingsparameter, Datensatz, Evaluierungsergebnisse) erstellen	Hoch	31.05.2026
Klärung mit Meta AI, ob Deployment in kritischer Infrastruktur zulässig	Mittel	31.05.2026

6. Gesamtbewertung GPAI-Komponente

GPAI-Anbieterstellung von MedAssist AI GmbH: Nicht gegeben (da Fine-Tuning zur Spezialisierung führt). **Pflicht zur Integration der Llama-Upstream-Dokumentation: Nicht erfüllt.** Lizenzrechtliche Risiken durch fehlende Aufsicht: Erheblich. Sofortige Integration in technische Dokumentation und rechtliche Lizenzprüfung erforderlich.

Heidelberg, 28.04.2026

RA Dr. Mark Roosendaal — Az. 2026-V-0427

20-handlungsplan-feststellungen.docx

Aktenstück 20 — Handlungsplan: Feststellungen und Maßnahmen zur KI-VO-Konformität

Aktenzeichen: 2026-V-0427

Erstellt: 05.05.2026

Bearbeitung: RAin Dr. Henrietta Vellbruck-Steinheim, RA Dr. Mark Roosendaal

Adressaten: CEO Dr. Theresia Vogelkamp, CTO Aravind Krishnamurthy (MedAssist AI GmbH)

Vertraulich — Anwalt-Mandant-Privileg

1. Gesamtbefund

Die Konformitätsprüfung MedAssist v4 (KI-VO Art. 6–49) ergibt folgenden Befund:

Artikel	Befund	Schwere
Art. 6 + Anhang III Nr. 7 — Einstufung Hochrisiko	Eindeutig zutreffend	—
Art. 9 — Risikomanagementsystem	Nicht konform	Kritisch
Art. 10 — Daten-Governance	Nicht konform	Kritisch
Art. 11 — Technische Dokumentation	Nicht konform	Kritisch
Art. 12 — Aufzeichnungspflichten	Teilweise konform (mit krit. Lücken)	Hoch
Art. 13 — Transparenz	Teilweise konform	Hoch
Art. 14 — Menschliche Aufsicht	Nicht konform (gravierendstes Defizit)	Kritisch
Art. 15 — Genauigkeit/Robustheit/Cyber	Nicht konform	Hoch
Art. 16 + Art. 17 — Anbieterpflichten + QMS	Nicht konform	Hoch
Art. 43 — Konformitätsbewertung	Nicht begonnen	Kritisch
Art. 47 — EU-Konformitätserklärung	Entwurf; nicht finalisierbar	Hoch
Art. 48 — CE-Kennzeichnung KI-VO	Noch nicht anbringbar	Hoch
Art. 49 — EU-Datenbank-Registrierung	Nicht erfolgt	Hoch
MDR-Schnittstelle	Koordination erforderlich	Mittel
GPAI (Llama)	Teildokumentation fehlt	Mittel

Frist: 02.08.2026 (Art. 113 Abs. 1 KI-VO). Verbleibende Zeit: 89 Tage.

2. Kritischer Pfad bis 02.08.2026

...

Mai 2026

|— 07.05.2026 — Antwort BNetzA Nachforderung (Disponenten-ID-Logs)

- |— 12.05.2026 — BNetzA Vor-Ort-Besichtigung Klinikum Mannheim-Süd
- |— 15.05.2026 — Beauftragung TÜV SÜD für KI-VO-Konformitätsbewertung
- |— 01.05.2026 — DPIA an BfDI
- |— 30.04.2026 — Quittierungsschritt Roll-out abgeschlossen (18 Kliniken)
- |— 31.05.2026 — Disponenten-Schulung gestartet

Juni 2026

- |— 01.06.2026 — Vollständige technische Dokumentation (Anhang IV) an TÜV SÜD
- |— 01.06.2026 — QMS nach Art. 17 errichtet und dokumentiert
- |— 15.06.2026 — Bias-Analyse abgeschlossen
- |— 30.06.2026 — Erklärbarkeits-Modul Dashboard live
- |— 30.06.2026 — Adversarial Testing + ISO 27001-Rezertifizierung

Juli 2026

- |— Mitte Juli — TÜV SÜD NB-Zertifikat KI-VO erwartet
- |— 20.07.2026 — EU-Konformitätserklärung ausgestellt
- |— 25.07.2026 — CE-Kennzeichnung KI-VO angebracht
- |— 30.07.2026 — Registrierung EU-Datenbank (EUID generiert)

02.08.2026 — FRIST

...

3. Detaillierter Maßnahmenkatalog

3.1 Sofortmaßnahmen (bis 15.05.2026)

#	Maßnahme	Verantwortlich	Frist	Status
S-1	Quittierungsschritt-Roll-out alle 18 Kliniken	CTO Krishnamurthy	30.04.2026	Eingeleitet
S-2	Antwort an BNetzA re Nachforderung (Disponenten-ID)	Dr. Vellbruck-Steinheim	07.05.2026	Offen
S-3	DPIA erstellen und an BfDI übermitteln	Dr. Roosendaal	01.05.2026	In Bearbeitung
S-4	Beauftragung TÜV SÜD KI-VO-Prüfung	Dr. Vellbruck-Steinheim	15.05.2026	Offen
S-5	Selbstmeldung schwerwiegende	Dr. Vellbruck-Steinheim	07.05.2026	Offen

	Vorfälle 2025 an BNetzA			
S-6	Eindeutige Systemkennung (MA-ID) festlegen	CTO Krishnamurthy	30.04.2026	Offen

3.2 Kurzfristmaßnahmen (bis 30.06.2026)

#	Maßnahme	Verantwortlich	Frist
K-1	Vollständige technische Dokumentation (Anhang IV) erstellen	CTO Krishnamurthy / Dr. Roosendaal	01.06.2026
K-2	QMS nach Art. 17 KI-VO errichten und dokumentieren	CEO Dr. Vogelkamp / CTO Krishnamurthy	01.06.2026
K-3	RMS aktualisieren (alle Vorfälle 2025, FMEA alle Module)	CTO Krishnamurthy	30.04.2026
K-4	Bias-Analyse Trainingsdaten (Geschlecht, Alter)	CTO Krishnamurthy	15.06.2026
K-5	Disponenten-Schulungsprogramm (Curriculum 4h) + Start	Dr. Vellbruck-Steinheim (Koordination)	31.05.2026
K-6	ISO 27001:2022 Rezertifizierung	CTO Krishnamurthy	30.06.2026
K-7	Adversarial Testing NLU-Modul	CTO Krishnamurthy	30.06.2026
K-8	Benutzerhandbuch v4.2 (alle Art. 13-Anforderungen)	CTO Krishnamurthy	31.05.2026
K-9	Erklärbarkeits-Modul Dashboard implementieren	CTO Krishnamurthy	30.06.2026
K-10	Llama-3.1 System Card in technische Dokumentation	CTO Krishnamurthy	31.05.2026

3.3 Finalmaßnahmen (Juli 2026)

#	Maßnahme	Verantwortlich	Frist
F-1	NB-Zertifikat TÜV SÜD entgegennehmen	TÜV SÜD / MedAssist	Mitte Juli
F-2	EU-Konformitätserklärung finalisieren und unterzeichnen	CEO Dr. Vogelkamp	20.07.2026
F-3	CE-Kennzeichnung KI-VO anbringen	CTO Krishnamurthy	25.07.2026
F-4	EU-Datenbank registrieren (EUID)	CTO Krishnamurthy	30.07.2026

4. Risikobewertung Fristwahrung

Risiko	Eintrittswahrscheinlichkeit	Auswirkung	Gegenmaßnahme
TÜV SÜD benötigt > 8 Wochen (Kapazitäten)	Mittel (30 %)	Fristüberschreitung	Frühzeitige Beauftragung; Alternativ-NB identifizieren

Bias-Analyse zeigt kritische Befunde (Nachbesserung)	Hoch (50 %)	Verzögerung techn. Doku	Puffer einplanen; partielle Dokumentation vorab
BNetzA eskaliert nach Vor-Ort-Besichtigung	Niedrig (15 %)	Vorläufige Maßnahme	Kooperationsstrategie, Handlungsplan vorlegen
Allianz SE kündigt D&O vor Frist	Mittel (40 %)	Persönliches Haftungsrisiko Vorstand	Verhandlung Allianz, Alternativversicherer

Heidelberg, 05.05.2026

RAin Dr. Henrietta Vellbruck-Steinheim / RA Dr. Mark Roosendaal — Az. 2026-V-0427

21-interne-mandantenpraesentation.docx

Aktenstück 21 — Interne Mandantenpräsentation: KI-VO-Konformitätsbefunde MedAssist v4

Aktenzeichen: 2026-V-0427

Erstellt: 12.05.2026

Format: Präsentationsnotizen für Vorstandssitzung MedAssist AI GmbH, 14.05.2026

Adressaten: CEO Dr. Theresia Vogelkamp, CTO Aravind Krishnamurthy, CMO Dr. Lutz Federkamp

Präsentierende: RAin Dr. Henrietta Vellbruck-Steinheim, RA Dr. Mark Roosendaal

Vertraulich

Folie 1 — Ausgangslage

Titel: MedAssist v4: KI-VO-Konformitätsprüfung — Zwischenbilanz

- Prüfungszeitraum: 03.03.2026 – 12.05.2026
- Prüfungsumfang: Art. 6–49 KI-VO, MDR-Schnittstelle, GPAI-Komponente, behördliche Verfahren
- Frist: **02.08.2026** (Art. 113 Abs. 1 KI-VO) — 82 Tage verbleibend
- Behördliche Verfahren: BNetzA (1-101.05-2026/MA-008), BfDI (13-3120/004#0117), BfArM (MED-AI-2026-0319)

Folie 2 — Auf einen Blick: Ampelstatus

Bereich	Status	Sofortbedarf
Menschliche Aufsicht (Art. 14)	Rot — nicht konform	Ja (Roll-out läuft)
Risikomanagementsystem (Art. 9)	Rot — nicht konform	Ja
Daten-Governance (Art. 10)	Rot — nicht konform	Ja
Technische Dokumentation (Art. 11)	Rot — nicht konform	Ja
Konformitätsbewertung (Art. 43)	Rot — nicht begonnen	Ja
Registrierung EU-DB (Art. 49)	Rot — nicht erfolgt	Abhängig
Aufzeichnungspflichten (Art. 12)	Gelb — Lücken	Teilweise
Transparenz (Art. 13)	Gelb — Lücken	Teilweise
Cybersicherheit (Art. 15)	Gelb — ISO abgelaufen	Ja
MDR-Koordination	Gelb — Abstimmung nötig	Mittel
GPAI-Dokumentation	Gelb — Lücke	Mittel

Folie 3 — Das gravierendste Defizit: Art. 14 (Menschliche Aufsicht)

Status: In 14 von 18 Kliniken kein technisch erzwungener Quittierungsschritt.

Was das bedeutet:

- MedAssist v4 steuert de facto die Notrufdisposition ohne dokumentierte menschliche Prüfung
- False-Negative-Rate 8,8 % bei lebensbedrohlichen Notrufen (Dringlichkeit 1) wird nicht korrigiert
- Jede 11. lebensbedrohliche Lage wird unterklassifiziert → Dispositionsverzögerung

- Haftungsrisiko Anbieter: Produkthaftungsgesetz, § 823 BGB; Haftungsrisiko Vorstand: § 43 GmbHG

Was bereits eingeleitet ist:

- Roll-out Quittierungsschritt auf alle 18 Kliniken: **30.04.2026** ✓ (laut CTO: abgeschlossen)
- Protokollierung Disponenten-ID läuft an

Nächster Schritt: Schulungsprogramm Disponenten bis 31.05.2026.

Folie 4 — Behördliche Verfahren: Aktueller Stand

BNetzA (Az. 1-101.05-2026/MA-008)

- Vor-Ort-Besichtigung Klinikum Mannheim-Süd: 12.05.2026 (heute!)
- Ergebnis: BNetzA-Inspektor hat Quittierungsschritt (Beta) positiv vermerkt; weitere Unterlagen angefordert (Bias-Analyse, Schulungskonzept)
- Bewertung: Kooperationsstrategie zeigt Wirkung; kein Sofortbescheid

BfDI (Az. 13-3120/004#0117)

- DPIA an BfDI übermittelt: 01.05.2026 (fristgerecht)
- BfDI hat 30-Tage-Prüffrist → Rückmeldung erwartet bis 01.06.2026
- Inhalt DPIA: Systematische Verarbeitung Gesundheitsdaten, Bias-Risiken, Art. 22 DSGVO-Analyse, Abhilfemaßnahmen

BfArM (Az. MED-AI-2026-0319)

- MDR-Konformität bestätigt; KI-VO ausdrücklich ausgeklammert
- Koordination für gemeinsame Prüfung mit TÜV SÜD läuft

Wettbewerberbeschwerde DiagnoFlow / DG CONNECT

- DG CONNECT hat Beschwerde an BNetzA weitergeleitet (Standardverfahren)
- Kein direktes DG-CONNECT-Verfahren zu erwarten
- BNetzA-Verfahren deckt Beschwerde ab

Folie 5 — Kritischer Pfad bis 02.08.2026

Muss bis Frist zwingend fertig sein:

1. Vollständige technische Dokumentation → **01.06.2026**
2. QMS nach Art. 17 KI-VO → **01.06.2026**
3. TÜV SÜD beauftragen → **15.05.2026** (noch ausstehend!)
4. NB-Zertifikat TÜV SÜD → **Mitte Juli 2026**
5. EU-Konformitätserklärung → **20.07.2026**
6. CE-Kennzeichnung KI-VO → **25.07.2026**
7. EU-Datenbank-Registrierung (EUID) → **30.07.2026**

Engpass: TÜV SÜD muss sofort beauftragt werden. Jede Woche Verzögerung gefährdet die Frist.

Folie 6 — Empfehlung an den Vorstand

8. **Sofort (diese Woche):** CTO Krishnamurthy beauftragt TÜV SÜD schriftlich mit KI-VO-Konformitätsbewertung.
9. **Bis 31.05.2026:** Disponenten-Schulung in allen 18 Kliniken abgeschlossen.
10. **Bis 01.06.2026:** Vollständige technische Dokumentation an TÜV SÜD.
11. **D&O-Versicherung:** CEO Dr. Vogelkamp nimmt Verhandlungen mit Allianz SE auf, gestützt auf Handlungsplan und Fortschrittsnachweis.
12. **CMO Dr. Federkamp:** Einbindung der Kliniken als Betreiber in den Konformitätsprozess — Betreiberverträge anpassen (Art. 25 KI-VO).

Folie 7 — Risikoszenario: Was passiert bei Fristüberschreitung?

- Bußgeld BNetzA: Bis **15 Mio. EUR** (Art. 99 Abs. 3 KI-VO) für nicht-konforme Hochrisiko-KI
- Vorläufige Maßnahme BNetzA: **Betriebsuntersagung** MedAssist v4 in allen 18 Kliniken möglich (Art. 79 KI-VO)
- Persönliche Haftung Vorstand: § 43 GmbHG — ohne D&O-Schutz erhebliches persönliches Risiko
- Reputationsschaden: DiagnoFlow-Beschwerde + Medienberichterstattung (Ärzte Zeitung 22.02.2026 bereits berichtet)
- Vertragsrisiko Kliniken: 18 Betreiberverträge könnten bei BNetzA-Betriebsuntersagung unter Rücktrittsrecht stehen

Heidelberg, 12.05.2026 — Vellbruck & Partner mbB — Az. 2026-V-0427

Vertraulich — nur für die Empfänger bestimmt

22-abschlussvermerk-rechtsanwalt.docx

Aktenstück 22 — Abschlussvermerk Rechtsanwältin

Aktenzeichen: 2026-V-0427

Erstellt: 30.06.2026

Verfasserin: RAin Dr. Henrietta Vellbruck-Steinheim

Kanzlei: Vellbruck & Partner mbB, Erbprinzenstraße 14, 69117 Heidelberg

Gegenstand: Abschlussvermerk KI-VO-Konformitätsprüfung MedAssist v4

1. Mandat und Auftrag

Die Kanzlei Vellbruck & Partner mbB wurde am 03.03.2026 durch die MedAssist AI GmbH mandatiert, eine vollständige Konformitätsprüfung des KI-Systems MedAssist v4 nach der Verordnung (EU) 2024/1689 (KI-VO) durchzuführen und bei der Herstellung der Konformität bis zur Frist 02.08.2026 (Art. 113 Abs. 1 KI-VO) zu beraten.

2. Zusammenfassung der Prüfungsergebnisse

2.1 Einstufung

MedAssist v4 ist eindeutig als Hochrisiko-KI-System nach Art. 6 Abs. 2 KI-VO i.V.m. Anhang III Nr. 7 KI-VO einzustufen. Diese Einstufung ist rechtlich nicht anfechtenswert. Zugleich ist MedAssist v4 Medizinprodukt Klasse IIb nach MDR (EU) 2017/745 (bestätigt durch BfArM, Az. MED-AI-2026-0319). Die MDR-Konformität ist formal bestätigt, materiell jedoch in einzelnen Punkten zu hinterfragen (Accuracy-Niveau, menschliche Aufsicht).

2.2 Identifizierte Defizite (Prüfungsbeginn März 2026)

Bei Aufnahme des Mandats bestanden kritische Verstöße gegen:

- Art. 9 KI-VO (kein funktionsfähiges, kontinuierliches RMS)
- Art. 10 KI-VO (US-Trainingsdaten ohne Repräsentativitätsnachweis; keine Bias-Analyse)
- Art. 11 KI-VO (unvollständige technische Dokumentation)
- Art. 12 KI-VO (keine Disponenten-ID-Protokollierung in 14 Kliniken)
- Art. 14 KI-VO (fehlender Quittierungsschritt; schwerster Befund)
- Art. 15 KI-VO (unzureichende Accuracy; abgelaufene ISO 27001-Zertifizierung)
- Art. 16, 17 KI-VO (kein QMS; keine Vorfallmeldungen)
- Art. 43, 47, 48, 49 KI-VO (Konformitätsbewertung, Erklärung, CE, Registrierung nicht eingeleitet)

2.3 Stand der Maßnahmen (30.06.2026)

Maßnahme	Status
Quittierungsschritt Roll-out 18 Kliniken	Abgeschlossen (30.04.2026)
Disponenten-ID-Protokollierung 18 Kliniken	Abgeschlossen (07.05.2026)
DPIA an BfDI	Übermittelt (01.05.2026); BfDI-Rückmeldung ausstehend
Disponenten-Schulung	Durchgeführt (31.05.2026, 18 Kliniken)

TÜV SÜD beauftragt	16.05.2026; Prüfung läuft
Technische Dokumentation (Anhang IV)	Fertiggestellt (28.05.2026); bei TÜV SÜD
QMS nach Art. 17 KI-VO	Errichtet und dokumentiert (01.06.2026)
RMS aktualisiert	Abgeschlossen (30.04.2026)
Bias-Analyse	Abgeschlossen (15.06.2026); Befunde positiv (keine kritischen Biases, aber leichte Unterrepräsentation älterer Patienten dokumentiert)
ISO 27001:2022 Rezertifizierung	In Bearbeitung; Zertifikat erwartet 15.07.2026
Adversarial Testing NLU	Abgeschlossen (29.06.2026); kein kritischer Befund
Benutzerhandbuch v4.2	Fertiggestellt (31.05.2026)
Erklärbarkeits-Modul Dashboard	Live (28.06.2026)
Llama-3.1 System Card integriert	Abgeschlossen (27.05.2026)
Selbstmeldung Vorfälle 2025 an BNetzA	Erfolgt (07.05.2026)
NB-Zertifikat TÜV SÜD (KI-VO)	Erwartet Mitte Juli 2026
EU-Konformitätserklärung	Ausstehend (nach NB-Zertifikat)
CE-Kennzeichnung KI-VO	Ausstehend
EU-Datenbank-Registrierung	Ausstehend

3. Rechtliche Prognose

Auf der Grundlage des Fortschrittstands vom 30.06.2026 und der zu erwartenden TÜV-SÜD-Prüfungsdauer (4–5 Wochen) ist die Wahrscheinlichkeit einer fristgerechten Konformität bis 02.08.2026 als hoch einzustufen, sofern:

1. Das TÜV-SÜD-NB-Zertifikat bis spätestens 21.07.2026 ausgestellt wird
2. Keine gravierenden Nachforderungen durch TÜV SÜD entstehen
3. Die ISO 27001-Rezertifizierung bis 15.07.2026 abgeschlossen ist

Restrisiken:

- BfDI-Rückmeldung zur DPIA könnte ergänzende Maßnahmen verlangen
- Bias-Befund (leichte Unterrepräsentation älterer Patienten) wird in DPIA und technischer Dokumentation adressiert; formelle Beanstandung durch BfDI nicht auszuschließen
- D&O-Versicherung: Allianz SE hat nach Vorlage des Handlungsplans Verlängerung bis 30.09.2026 gewährt; endgültige Entscheidung nach NB-Zertifikat

4. Haftungsrechtlicher Hinweis

Dieser Abschlussvermerk dokumentiert den Stand der rechtlichen Beratung zum 30.06.2026. Er ersetzt nicht die eigenverantwortliche unternehmerische Entscheidung des Mandanten. Die vollständige Konformität mit der KI-VO ist erst nach Vorlage des NB-Zertifikats, Ausstellen der EU-Konformitätserklärung, Anbringen der CE-Kennzeichnung und Registrierung in der EU-Datenbank gegeben. Bis dahin befindet sich MedAssist AI GmbH in einem Übergangsstatus, der durch die dokumentierten Fortschritte und die eingereichten Behördenberichte abgesichert ist.

Die Kanzlei Vellbruck & Partner mbB haftet nach Maßgabe des Anwaltsvertrags und der BRAO; eine Garantie für den Ausgang behördlicher oder gerichtlicher Verfahren kann nicht gegeben werden.

5. Fortführung des Mandats

Die Kanzlei empfiehlt, das Mandat über den 02.08.2026 hinaus fortzuführen für:

- Begleitung des TÜV-SÜD-Abschlussverfahrens
- Überwachung des BfDI-Verfahrens
- Laufende KI-VO-Compliance-Beratung (Post-Market-Monitoring, Art. 72)
- Verteidigung im BNetzA-Verfahren bis zur Verfahrenseinstellung

Heidelberg, 30.06.2026

RAin Dr. Henrietta Vellbruck-Steinheim

Vellbruck & Partner mbB

Erbprinzenstraße 14

69117 Heidelberg

Telefon: 06221 / 84 90-0

E-Mail: h.vellbruck-steinheim@vellbruck-partner.de

Aktenzeichen: 2026-V-0427

GUTACHTEN

Konformitätsprüfung MedAssist v4

nach Verordnung (EU) 2024/1689 (KI-VO)

Auftraggeber: MedAssist AI GmbH, Heidelberg

Kanzlei Vellbruck & Partner mbB, Heidelberg

Az. 2026-V-0427 | Stand: 30.06.2026 | Vertraulich

RAin Dr. Henrietta Vellbruck-Steinheim (federführend)
RA Dr. Mark Roosendaal

1. Gegenstand und Auftrag

Die Kanzlei Vellbruck & Partner mbB wurde am 03.03.2026 durch die MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg (nachfolgend: Mandantin), mandatiert, eine vollständige rechtliche Konformitätsprüfung des KI-Systems MedAssist v4 nach der Verordnung (EU) 2024/1689 (KI-VO) durchzuführen. Das Mandat umfasst die Prüfung der Artikel 6, 9–15, 16, 43, 47–49 und 113 KI-VO sowie der Schnittstellen zur MDR (EU) 2017/745, zur DSGVO und zu laufenden Behördenverfahren bei BNetzA (Az. 1-101.05-2026/MA-008), BfDI (Az. 13-3120/004#0117) und BfArM (Az. MED-AI-2026-0319).

Dieses Gutachten fasst die Ergebnisse der Prüfung zusammen und richtet sich an den Vorstand der Mandantin sowie die beteiligten Behörden.

1.1 Das geprüfte KI-System

MedAssist v4 (Version 4.2.3) ist ein KI-System zur automatisierten Notrufdisposition in Krankenhäusern. Es verarbeitet eingehende Notrufe in Echtzeit (Sprachtranskription durch eine Llama-3.1-70B-Adaptation), klassifiziert Dringlichkeitsstufen (1–5) und schlägt Ressourcenzuweisungen vor. Das System ist in 18 Krankenhäusern in Baden-Württemberg (12) und Bayern (6) im Produktivbetrieb.

MedAssist v4 ist zugleich als Medizinprodukt Klasse IIb nach MDR (EU) 2017/745 zertifiziert (NB TÜV SÜD Product Service GmbH, NB 0123; BfArM-Bescheid MED-AI-2026-0319 vom 12.01.2026).

2. Rechtlicher Rahmen

2.1 KI-VO (EU) 2024/1689

Die Verordnung (EU) 2024/1689 des Europäischen Parlaments und des Rates vom 13. Juni 2024 zur Festlegung harmonisierter Vorschriften für künstliche Intelligenz (KI-Verordnung) ist am 01.08.2024 in Kraft getreten. Für Hochrisiko-KI-Systeme nach Anhang III gilt die Übergangsfrist des Art. 113 Abs. 1 KI-VO: Diese Systeme müssen bis 02.08.2026 vollständig konform sein.

Hochrisiko-KI-Systeme nach Art. 6 Abs. 2 KI-VO i.V.m. Anhang III unterliegen den Pflichten der Art. 9–15 (technische Anforderungen), Art. 16–17 (Anbieterpflichten), Art. 43 (Konformitätsbewertung), Art. 47–49 (Erklärung, CE, Registrierung).

2.2 MDR (EU) 2017/745

Die MDR gilt parallel zur KI-VO. Art. 8 KI-VO stellt klar, dass sektorspezifische Rechtsvorschriften — einschließlich MDR — durch die KI-VO unberührt bleiben, soweit sie höhere Schutzstandards normieren. Beide Regimes bestehen kumulativ; die MDR-Konformität ersetzt nicht die KI-VO-Konformität.

2.3 DSGVO

Bei der Verarbeitung von Gesundheitsdaten (besondere Kategorien nach Art. 9 Abs. 1 DSGVO) sind die Anforderungen der DSGVO zu wahren, insbesondere Art. 9 (Rechtsgrundlage), Art. 22 (automatisierte Entscheidungen) und Art. 35 (Datenschutz-Folgenabschätzung).

3. Einstufung MedAssist v4

MedAssist v4 ist eindeutig als Hochrisiko-KI-System nach Art. 6 Abs. 2 KI-VO i.V.m. Anhang III Nr. 7 KI-VO einzustufen. Anhang III Nr. 7 erfasst KI-Systeme für den Einsatz in Notfalldiensten und für erste Reaktion auf Notfälle. Die Notrufdisposition in Krankenhäusern ist ein Kernbereich dieser Kategorie. Ausnahmetatbestände nach Art. 6 Abs. 3 KI-VO greifen nicht.

Die Einstufung als Medizinprodukt Klasse IIb (MDR) ist durch BfArM-Bescheid bestätigt. MedAssist v4 unterliegt damit doppelter Regulierung.

4. Prüfungsergebnisse im Überblick

Artikel	Anforderung	Befund	Risiko
Art. 9	Risikomanagementsystem	Nicht konform	Kritisch
Art. 10	Daten-Governance / Trainingsdaten	Nicht konform	Kritisch
Art. 11	Technische Dokumentation (Anhang IV)	Nicht konform	Kritisch
Art. 12	Aufzeichnungspflichten / Logging	Teilweise konform	Hoch
Art. 13	Transparenz / Benutzerhandbuch	Teilweise konform	Hoch
Art. 14	Menschliche Aufsicht	Nicht konform (GRAVIEREND)	Kritisch
Art. 15	Genauigkeit / Robustheit / Cybersicherheit	Nicht konform	Hoch
Art. 16/17	Anbieterpflichten / QMS	Nicht konform	Hoch
Art. 43	Konformitätsbewertung (NB)	Nicht begonnen	Kritisch
Art. 47	EU-Konformitätserklärung	Entwurf (nicht finalisierbar)	Hoch
Art. 48	CE-Kennzeichnung KI-VO	Ausstehend	Hoch
Art. 49	EU-Datenbank-Registrierung	Nicht erfolgt	Hoch

5. Kernergebnis: Art. 14 — Menschliche Aufsicht

Der gravierendste Befund dieser Prüfung betrifft Art. 14 KI-VO. In 14 der 18 Krankenhäuser, in denen MedAssist v4 produktiv betrieben wird, existiert kein technisch erzwungener Quittierungsschritt, bevor die Systemempfehlung zur Ressourcenzuweisung umgesetzt wird. Disponenten übernehmen die Empfehlung faktisch ohne protokollierte Prüfung. Dies begründet eine strukturelle Aufsichtslücke.

Rechtliche Einordnung: Art. 14 Abs. 4 lit. e KI-VO verpflichtet Anbieter, Mechanismen bereitzustellen, die Betreibern erlauben, das System zu übersteuern oder zu stoppen. Eine bloß konzeptionell vorgesehene Übersteuerungsmöglichkeit ohne technische Erzwingung und Protokollierung erfüllt diese Anforderung nicht.

Haftungsrechtliche Folge: Die Verbindung von 8,8 % False-Negative-Rate bei lebensbedrohlichen Notrufen (Dringlichkeit 1) mit fehlender menschlicher Prüfung begründet erhebliche Produkthaftungsrisiken. Das Produkthaftungsgesetz (ProdHaftG) i.d.F. der Umsetzung der RL (EU) 2024/2853 findet Anwendung.

Sofortmaßnahme: Der Roll-out des Pflicht-Quittierungsschritts auf alle 18 Kliniken wurde am 30.04.2026 abgeschlossen (Bestätigung CTO Krishnamurthy vom 30.04.2026).

6. GPAI-Komponente: Llama-Adaptation

MedAssist-LLM-Core v4 basiert auf Llama-3.1-70B-Instruct (Meta AI, RAIL-Lizenz v3). Das Fine-Tuning erfolgte auf einem medizinischen Notfalldatensatz (280.000 Trainingsschritte). Die Llama-3.1-Basiskomponente stellt ein GPAI-Modell i.S.d. Art. 3 Nr. 63 KI-VO dar.

Da das Fine-Tuning zu einer Spezialisierung (keine generalistische Verwendbarkeit mehr) geführt hat, ist MedAssist AI GmbH nicht als GPAI-Anbieter nach Art. 51–55 KI-VO einzustufen. Allerdings verpflichtet Art. 11 Abs. 3 KI-VO zur Integration der vom GPAI-Anbieter (Meta AI) bereitgestellten Informationen in die technische Dokumentation. Dies ist bislang nicht erfolgt.

Lizenzrechtliches Risiko: Die Acceptable Use Policy von Llama-3.1 schränkt den Einsatz für medizinische Entscheidungen ohne menschliche Aufsicht ein. Angesichts des Art. 14-Defizits (nun behoben) und der de-facto-Automatisierung in 14 Kliniken war das Lizenzrisiko erheblich.

7. Behördliche Verfahren

7.1 BNetzA (Az. 1-101.05-2026/MA-008)

Die Bundesnetzagentur hat am 22.02.2026 das Marktüberwachungsverfahren eröffnet. Auslöser: Beschwerde DiagnoFlow GmbH (München) beim DG CONNECT, weitergeleitet an BNetzA. Die Kanzlei Vellbruck & Partner mbB vertritt MedAssist AI GmbH in diesem Verfahren.

Vor-Ort-Besichtigung Klinikum Mannheim-Süd: 12.05.2026. Der BNetzA-Inspektor hat den Quittierungsschritt (Beta) positiv vermerkt; weitere Unterlagen wurden angefordert.

7.2 BfDI (Az. 13-3120/004#0117)

Die DPIA wurde am 01.05.2026 an die BfDI übermittelt. Rückmeldung der BfDI steht aus (30-Tage-Frist bis 01.06.2026).

7.3 BfArM (Az. MED-AI-2026-0319)

MDR-Konformität bestätigt. BfArM hat auf ausstehende KI-VO-Konformität hingewiesen. Koordination für gemeinsame NB-Prüfung TÜV SÜD läuft.

8. Handlungsempfehlungen und kritischer Pfad

Die wesentlichen Sofortmaßnahmen wurden eingeleitet (Quittierungsschritt-Roll-out, DPIA). Für die vollständige Konformität bis 02.08.2026 sind folgende Schritte auf dem kritischen Pfad:

- Beauftragung TÜV SÜD für KI-VO-Konformitätsbewertung bis 15.05.2026
- Fertigstellung technische Dokumentation (Anhang IV) bis 01.06.2026
- Errichtung QMS nach Art. 17 KI-VO bis 01.06.2026
- ISO 27001:2022 Rezertifizierung bis 30.06.2026
- NB-Zertifikat TÜV SÜD: erwartet Mitte Juli 2026
- EU-Konformitätserklärung, CE-Kennzeichnung, EUID-Registrierung: August 2026

Die Frist 02.08.2026 ist unter Optimalbedingungen erreichbar. Jede Verzögerung bei TÜV SÜD gefährdet die Fristwahrung.

9. Haftungsrechtlicher Hinweis

Dieses Gutachten wurde auf Grundlage der bis 30.06.2026 vorliegenden Informationen erstellt. Es unterliegt dem Anwalt-Mandant-Privileg und ist vertraulich zu behandeln. Die vollständige Konformität tritt erst mit Abschluss aller unter Kapitel 8 genannten Maßnahmen ein. Bis dahin besteht ein Restrisiko behördlicher Maßnahmen, das durch die dokumentierten Fortschritte und die eingereichten Behördenberichte abgemildert wird.

Für Rückfragen:

RAin Dr. Henrietta Vellbruck-Steinheim — h.vellbruck-steinheim@vellbruck-partner.de — 06221 / 84 90-100

RA Dr. Mark Roosendaal — m.roosendaal@vellbruck-partner.de — 06221 / 84 90-110

Heidelberg, 30. Juni 2026

RAin Dr. Henrietta Vellbruck-Steinheim

Vellbruck & Partner mbB, Heidelberg

WORD-DOKUMENT (ORIGINAL-LAYOUT)

protokoll-ki-vo-workshop.docx

PROTOKOLL — KI-VO-COMPLIANCE-WORKSHOP

MedAssist AI GmbH | 22. April 2026 | Konferenzraum Innovation Hub, Heidelberg

Teilnehmende

Name	Funktion	Organisation
RAin Dr. Henrietta Vellbruck-Steinheim	Mandatierte Kanzlei (federführend)	Vellbruck & Partner mbB
RA Dr. Mark Roosendaal	Mandatierte Kanzlei	Vellbruck & Partner mbB
Dr. Theresia Vogelkamp	CEO	MedAssist AI GmbH
Aravind Krishnamurthy	CTO	MedAssist AI GmbH
Dr. Lutz Federkamp	CMO (Medizin)	MedAssist AI GmbH
Michael Albrecht-Haag	Chefjustiziar	MedAssist AI GmbH
Elena Schöpfer	Product Owner MedAssist v4	MedAssist AI GmbH
Dr. Fabian Grüneberg	Machine Learning Lead	MedAssist AI GmbH

1. Begrüßung und Agenda

RAin Dr. Vellbruck-Steinheim eröffnet den Workshop um 09:15 Uhr. Zweck des Workshops: gemeinsame Durcharbeitung der KI-VO-Anforderungen Art. 9–15 und Klärung offener Fragen vor Beginn der Maßnahmenphase. Ergebnisse werden in einem Aktionsplan festgehalten.

2. Block A: Art. 14 — Menschliche Aufsicht (09:30–11:00)

RA Dr. Roosendaal präsentiert die Befunde aus dem Prüfbericht zu Art. 14. CTO Krishnamurthy bestätigt, dass der Quittierungsschritt technisch fertig entwickelt ist (in Beta bei 4 Kliniken) und bis 30.04.2026 auf alle 18 Kliniken ausgerollt wird. Diskussion zu Schulungskonzept:

- Product Owner Schöpfer: Schulungsdauer 4h ist machbar; Vorschlag Video-Tutorial als Ergänzung
- CMO Dr. Federkamp: Kliniken brauchen klare Kommunikation, warum der neue Bestätigen-Schritt eingeführt wird — positive Framing als Qualitätsmaßnahme
- RAin Dr. Vellbruck-Steinheim: Schulung muss dokumentiert werden; Teilnahme-Nachweis pro Disponent erforderlich für Art. 14 Abs. 3 KI-VO

Beschluss: Schulungscurriculum wird bis 15.05.2026 entwickelt (Dr. Grüneberg + Dr. Vellbruck-Steinheim). Roll-out Schulung 18 Kliniken bis 31.05.2026.

3. Block B: Art. 10 — Daten-Governance und Bias (11:15–12:30)

Dr. Grüneberg erläutert die Trainingsdatensituation. Diskussion zu Bias-Analyse:

- Dr. Grüneberg: Bias-Analyse technisch machbar; braucht ca. 3 Wochen für vollständige Auswertung
- RAin Dr. Vellbruck-Steinheim: BfDI erwartet Ergebnisse; kritischer Pfad ist DPIA-Vorlage 01.05.2026
- CTO Krishnamurthy: Zusage, vorläufige Bias-Ergebnisse für DPIA bis 29.04.2026 bereitzustellen

- Dr. Federkamp: Kliniken müssen von der Bias-Analyse in Kenntnis gesetzt werden — welche Patientengruppen besonders geprüft werden

Beschluss: Bias-Analyse bis 15.06.2026; vorläufige Ergebnisse bis 29.04.2026 für DPIA.

4. Block C: Art. 43/47 — Konformitätsbewertung und TÜV SÜD (13:30–14:30)

RAin Dr. Vellbruck-Steinheim erklärt den Verfahrensablauf. TÜV SÜD NB 0123 ist für KI-VO notifiziert. Beauftragungsschreiben muss bis spätestens 15.05.2026 versandt werden.

- Chefjustiziar Albrecht-Haag: Vertragsentwurf TÜV SÜD wird bis 08.05.2026 vorbereitet
- CTO Krishnamurthy: Technische Dokumentation (Anhang IV) muss bis 01.06.2026 fertig sein — engster Zeitplan
- CEO Dr. Vogelkamp: Genehmigt Budget für TÜV-SÜD-Beauftragung (geschätzt 85.000–120.000 EUR)

5. Ergebnisse und Aktionsplan

Maßnahme	Verantwortlich	Frist
Roll-out Quittierungsschritt 18 Kliniken	CTO Krishnamurthy	30.04.2026
Schulungscurriculum Art. 14	Dr. Grüneberg / Dr. Vellbruck-Steinheim	15.05.2026
Vorläufige Bias-Ergebnisse für DPIA	Dr. Grüneberg	29.04.2026
DPIA an BfDI	Dr. Roosendaal	01.05.2026
Vertragsentwurf TÜV SÜD	Albrecht-Haag	08.05.2026
Beauftragung TÜV SÜD	CEO Dr. Vogelkamp	15.05.2026
Technische Dokumentation (Anhang IV)	CTO Krishnamurthy	01.06.2026
Vollständige Bias-Analyse	Dr. Grüneberg	15.06.2026

Heidelberg, 22. April 2026 — Protokoll: RA Dr. Mark Roosendaal

vertraulichkeitserklaerung-pruefauftrag.docx

VERTRAULICHKEITSERKLÄRUNG

im Rahmen des Prüfauftrags KI-VO-Konformitätsprüfung MedAssist v4

zwischen

MedAssist AI GmbH, Im Neuenheimer Feld 580, 69120 Heidelberg, vertreten durch CEO Dr. Theresia Vogelkamp (nachfolgend: Auftraggeber)

und

Vellbruck & Partner mbB, Erbprinzenstraße 14, 69117 Heidelberg, vertreten durch RAin Dr. Henrietta Vellbruck-Steinheim (nachfolgend: Kanzlei)

— gemeinsam: die Parteien —

§ 1 Gegenstand

Die Kanzlei führt für den Auftraggeber eine Konformitätsprüfung des KI-Systems MedAssist v4 nach der Verordnung (EU) 2024/1689 (KI-VO) durch (Az. 2026-V-0427). Im Rahmen dieses Auftrags erhält die Kanzlei Zugang zu vertraulichen Informationen des Auftraggebers, insbesondere zu technischen Systemdokumentationen, Trainingsdaten-Beschreibungen, internen Testberichten, Behördenkorrespondenz und Geschäftsgeheimnissen.

§ 2 Vertraulichkeit

Die Kanzlei verpflichtet sich, alle im Rahmen des Prüfauftrags erlangten vertraulichen Informationen streng vertraulich zu behandeln, diese ausschließlich für Zwecke der Konformitätsprüfung zu verwenden und nicht an Dritte weiterzugeben. Die anwaltliche Verschwiegenheitspflicht nach § 43a BRAO bleibt unberührt und tritt neben diese Vereinbarung.

§ 3 Ausnahmen

Die Vertraulichkeitspflicht gilt nicht für Informationen, die allgemein öffentlich bekannt sind oder werden, die der Kanzlei ohne Verletzung dieser Erklärung bekannt waren, oder die auf behördliche Anordnung offenzulegen sind. Im letzten Fall wird die Kanzlei den Auftraggeber vorab informieren, soweit rechtlich zulässig.

§ 4 Rückgabe und Vernichtung

Nach Abschluss des Prüfauftrags oder auf Verlangen des Auftraggebers werden alle vertraulichen Unterlagen zurückgegeben oder vernichtet, sofern keine gesetzlichen Aufbewahrungspflichten entgegenstehen.

§ 5 Laufzeit

Diese Vereinbarung gilt ab Unterzeichnung und endet fünf Jahre nach Beendigung des Mandatsverhältnisses.

Heidelberg, 03. März 2026

Dr. Theresia Vogelkamp

CEO, MedAssist AI GmbH

RAin Dr. Henrietta Vellbruck-Steinheim

Vellbruck & Partner mbB

bnetza-leitfaden-marktueberwachung-zusammenfassung.pdf

ZUSAMMENFASSUNG

BNetzA-Leitfaden: Marktüberwachung nach KI-VO (EU) 2024/1689

Erstellt für Kanzlei Vellbruck & Partner mbB | Az. 2026-V-0427 | Zusammenfassung für Mandant
MedAssist AI GmbH

Diese Zusammenfassung gibt den wesentlichen Inhalt des BNetzA-Leitfadens zur Marktüberwachung nach der KI-VO wieder, soweit er für das Verfahren Az. 1-101.05-2026/MA-008 (MedAssist v4) relevant ist. Der Leitfaden wurde im Januar 2026 von der Bundesnetzagentur veröffentlicht.

1. Zuständigkeit und Rechtsbasis

Die Bundesnetzagentur (BNetzA) ist gemäß § 3 Abs. 1 KI-VoDG i.V.m. Art. 74 ff. KI-VO die national zuständige Marktüberwachungsbehörde für KI-Systeme in Deutschland, mit Ausnahme der in § 5 und § 6 KI-VoDG geregelten Ressortzuständigkeiten (BaFin: Finanzsektor; BfArM: Medizinprodukte-Fachfragen). Die KI-VO-Marktüberwachung durch die BNetzA beginnt ab 02.08.2026 (Art. 113 Abs. 1 KI-VO); laufende Verfahren zur Sicherstellung von Konformität können nach Ermessen der BNetzA bereits vor diesem Datum eingeleitet werden.

2. Befugnisse der BNetzA nach Art. 74–80 KI-VO

Befugnis	Rechtsgrundlage	Inhalt
Dokumenten Anforderung	Art. 74 Abs. 4 KI-VO	Anforderung technischer Dokumentation, Logs, Risikoanalysen
Vor-Ort-Besichtigung	Art. 74 Abs. 5 KI-VO	Zugang zu Betriebsstätten, Systemdemonstration, Dateneinsicht
Testläufe	Art. 74 Abs. 5 KI-VO	BNetzA kann eigene Testläufe am System verlangen
Vorläufige Maßnahmen	Art. 79 KI-VO	Einstweilige Verfügung, Nutzungsbeschränkung, Betriebsuntersagung
Rückruf/Rücknahme	Art. 80 KI-VO	Anordnung Marktrücknahme oder Rückruf bei erheblichem Risiko
Bußgeldempfehlung	Art. 99 KI-VO	Empfehlung an EU-KI-Behörde (AI Office) für Bußgeld

3. Kooperationspflicht (Art. 74 Abs. 6 KI-VO)

Anbieter, Betreiber und Händler sind zur Kooperation mit der BNetzA verpflichtet. Eine Verweigerung der Kooperation kann als erschwerender Umstand im Bußgeldverfahren nach Art. 99 KI-VO gewertet werden und den Bußgeldrahmen erhöhen. Umgekehrt wirkt kooperatives Verhalten — insbesondere die freiwillige Offenlegung von Mängeln und die proaktive Vorlage eines Handlungsplans — strafmildernd (Art. 99 Abs. 6 KI-VO). Die BNetzA

weist im Leitfaden ausdrücklich darauf hin, dass sie kooperative Anbieter positiv differenziert behandelt.

4. Bußgeldrahmen (Art. 99 KI-VO)

Verstoßkategorie	Bußgeldobergrenze
Nicht-konforme Hochrisiko-KI (Art. 9–15, Art. 43)	Bis 15 Mio. EUR oder 3 % weltweiter Jahresumsatz (höherer Betrag)
Verbotene KI-Praktiken (Art. 5)	Bis 35 Mio. EUR oder 7 % weltweiter Jahresumsatz
Fehlinformationen an Behörde (Art. 99 Abs. 5)	Bis 7,5 Mio. EUR oder 1,5 % weltweiter Jahresumsatz
Transparenzpflichtverstöße (Art. 13, Art. 50)	Bis 7,5 Mio. EUR oder 1,5 % weltweiter Jahresumsatz
Relevanter Umsatz MedAssist AI GmbH (2024)	ca. 48 Mio. EUR — 3 % = ca. 1,44 Mio. EUR (< 15 Mio. EUR)

5. Relevanz für MedAssist AI GmbH / Az. 1-101.05-2026/MA-008

Das BNetzA-Marktüberwachungsverfahren wurde am 22.02.2026 eröffnet. Die Kanzlei Vellbruck & Partner mbB hat eine kooperative Strategie gewählt: vollständige Offenlegung der identifizierten Mängel, Vorlage des Handlungsplans, proaktive Demonstration eingeleiteter Maßnahmen. Die BNetzA-Vor-Ort-Besichtigung (12.05.2026) verlief ohne sofortige Beanstandungen. Eine vorläufige Maßnahme nach Art. 79 KI-VO ist derzeit nicht zu erwarten, sofern die Konformitätsfrist 02.08.2026 eingehalten wird.

6. Schlussfolgerung und Empfehlung

Der BNetzA-Leitfaden bestätigt die rechtliche Einschätzung der Kanzlei: Die Kooperationsstrategie ist der richtige Ansatz. MedAssist AI GmbH sollte alle Behördenberichte pünktlich liefern, den Handlungsplan als Anlage beifügen und die TÜV-SÜD-Beauftragung schriftlich nachweisen. Ein transparenter Fortschrittsnachweis mindert das Bußgeldrisiko erheblich.

Quellen: KI-VO (EU) 2024/1689 — <https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32024R1689> | KI-VoDG (DE) BGBl. I 2025, S. 4812 | BNetzA-Leitfaden Marktüberwachung KI-VO (Januar 2026) — <https://www.bundesnetzagentur.de/ki-vo> | Erstellt: Kanzlei Vellbruck & Partner mbB, Az. 2026-V-0427

PDF-ANHANG (ORIGINALDOKUMENT)

eu-konformitaetserklaerung-entwurf.pdf

EU-KONFORMITÄTSERKLÄRUNG

nach Art. 47 Verordnung (EU) 2024/1689 (KI-VO)

ENTWURF — Stand 17.04.2026 — Noch nicht rechtsverbindlich unterzeichnet

1. Angaben zum Anbieter

Name des Anbieters:	MedAssist AI GmbH
Anschrift:	Im Neuenheimer Feld 580, 69120 Heidelberg, Deutschland
Handelsregisternummer:	HRB 748921, AG Mannheim
Gesetzliche Vertreterin:	Dr. Theresia Vogelkamp (CEO)
E-Mail:	compliance@medassist-ai.de
Website:	https://www.medassist-ai.de

2. Angaben zum KI-System

Systemname:	MedAssist v4
Systembeschreibung:	KI-System zur automatisierten Notrufdisposition in Krankenhäusern
Versionsnummer:	4.2.3
Systemkennung (MA-ID):	[wird nach Festlegung eingetragen]
Verwendungszweck:	Klassifikation eingehender Notrufe, Dringlichkeitspriorisierung, Ressourcenzuweisung in Krankenhausleitstellen
Einstufung:	Hochrisiko-KI nach Art. 6 Abs. 2 KI-VO i.V.m. Anhang III Nr. 7
MDR-Status:	Medizinprodukt Klasse IIb (EU) 2017/745 BfArM-Bescheid MED-AI-2026-0319 vom 12.01.2026

3. Gegenstand dieser Erklärung

Der Anbieter MedAssist AI GmbH erklärt in alleiniger Verantwortung, dass das oben beschriebene KI-System MedAssist v4 zum Zeitpunkt der Unterzeichnung dieser Erklärung den einschlägigen Anforderungen der Verordnung (EU) 2024/1689 des Europäischen Parlaments und des Rates vom 13. Juni 2024 über künstliche Intelligenz (KI-VO) entspricht.

4. Konformitätsbewertungsverfahren

Das Konformitätsbewertungsverfahren wurde nach Art. 43 Abs. 1 KI-VO i.V.m. Anhang VI unter Einschaltung einer Notifizierten Stelle durchgeführt. Da MedAssist v4 zugleich ein Medizinprodukt der Klasse IIb nach MDR (EU) 2017/745 ist, das einer Konformitätsbewertung durch eine Notifizierte Stelle bedarf, erfolgte die KI-VO-Konformitätsbewertung ebenfalls durch eine Notifizierte Stelle.

Notifizierte Stelle:	TÜV SÜD Product Service GmbH
NB-Kennnummer:	0123
Zertifikatnummer KI-VO:	[wird nach Ausstellung eingetragen]
Ausstellungsdatum:	[wird nach Ausstellung eingetragen]
Gültigkeit:	[wird nach Ausstellung eingetragen]

5. Einschlägige harmonisierte Normen und technische Spezifikationen

- ISO 9001:2015 — Qualitätsmanagementsysteme
- ISO/IEC 27001:2022 — Informationssicherheitsmanagementsysteme
- ISO 14971:2019 — Risikomanagement für Medizinprodukte
- IEC 62304:2006+AMD1:2015 — Software-Lebenszyklusprozesse für Medizinprodukte
- ISO/IEC TR 24029-1:2021 — Assessment of the robustness of neural networks
- ENISA Guidelines on Securing Artificial Intelligence (2023)

6. Zusätzlich angewandte nationale Normen und Spezifikationen

Deutsches KI-VO-Durchführungsgesetz (KI-VoDG) vom 15.12.2025 (BGBl. I 2025, S. 4812).
BNetzA-Leitfaden Marktüberwachung KI-VO (Januar 2026).

7. Unterzeichnung

Ort, Datum: Heidelberg, _____ 2026

Dr. Theresia Vogelkamp

CEO, MedAssist AI GmbH

Quelle: Art. 47 Verordnung (EU) 2024/1689 (KI-VO) —

<https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32024R1689> | MDR (EU) 2017/745 —

<https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32017R0745> | Dieses Dokument ist ein ENTWURF —

Kanzlei Vellbruck & Partner mbB, Az. 2026-V-0427